AN INQUIRY | NOVEMBER 2026

Data and AI Governance

An Inquiry into the Intricate Aspects of Decision Making Frameworks in Data Science

Anthony Chinedu Echem
Machine Learning Engineer and Data Scientist



About this inquiry

Purpose, scope, audience and the lens through which the material is organised.

THE CORE PROPOSITION

Governance is not a layer added on top of data science. It is the discipline of making, owning and evidencing the hundreds of decisions that a data science system embodies, from the first framing of a problem to the day a model is retired.

1 **Purpose**

To examine how decisions are actually made across the data and AI lifecycle, and which frameworks, controls and institutions make those decisions defensible.

2 **Scope**

Data governance, AI governance, decision theory, regulation in force at November 2026, risk, fairness, transparency, human oversight, generative and agentic AI, and operations.

3 **Audience**

Boards, executives, data and AI leaders, data scientists, ML engineers, risk and compliance teams, auditors and policymakers.

4 **Method**

Synthesis of decision science, governance standards, primary regulatory texts and documented public case studies, translated into practical frameworks.

Agenda: fourteen sections, one argument

Each section builds a layer of the argument; page numbers refer to the section divider.

01	Why Data and AI Governance Matters Now	p. 10
02	The Anatomy of Decisions in Data Science	p. 27
03	Decision Making Frameworks: Theory and Models	p. 45
04	Data Governance Foundations: Quality, Lineage and Stewardship	p. 65
05	AI Governance Architecture: From Principles to Practice	p. 84
06	The Regulatory and Standards Landscape	p. 102
07	Risk Management and Assurance for AI Decisions	p. 123
08	Fairness, Bias and Equity in Automated Decisions	p. 141
09	Transparency, Explainability and Accountability	p. 160
10	Human Oversight and Human Centred Decision Making	p. 178
11	Governing Generative and Agentic AI Systems	p. 195
12	Operationalising Governance: MLOps, Metrics and Maturity	p. 214
13	Case Studies: Lessons from Documented Failures	p. 233
14	An Integrated Framework, Roadmap and Future Directions	p. 251

Executive summary: six findings

The inquiry reaches six conclusions that recur across theory, regulation and practice.

Decisions are the unit

Models do not cause harm on their own; chains of human choices about framing, data, thresholds and deployment do. Governing decisions is more effective than governing artefacts alone.

Framing is under governed

The most consequential choices, the target variable, the proxy and the definition of success, are usually made earliest and reviewed least.

Regulation has matured

The EU AI Act, the UK Data (Use and Access) Act 2025, ISO/IEC 42001 and the NIST AI RMF now give organisations a concrete, convergent baseline.

Trade offs are unavoidable

Fairness definitions conflict mathematically, and accuracy, privacy and explainability compete. Good governance makes the trade off explicit and owned.

Oversight must be meaningful

A human signature on an automated output is not oversight. Authority, time, competence and information are all required for review to change outcomes.

Governance must be operational

Policies only work when encoded in pipelines, registries, gates, monitoring and incentives. Governance as code is the practical frontier.

The governance landscape in numbers

Selected figures that frame the stakes and the timetable for organisations operating in the UK and EU.

7%

Maximum EU AI Act fine

Of worldwide annual turnover, or EUR 35 million if higher, for engaging in prohibited AI practices under Article 99.

8

Prohibited practice areas

Article 5 bans, applicable since 2 February 2025, from social scoring to untargeted facial image scraping.

2027

High risk deadline

Annex III high risk obligations now apply from 2 December 2027 following the Digital Omnibus on AI.

4

NIST AI RMF functions

Govern, Map, Measure and Manage: the most widely adopted voluntary structure for AI risk.



Implication The window between today and late 2027 is the period in which governance capability must be built, not bought at the last minute.

The central thesis

> *Every model is a frozen set of decisions. Data and AI governance is the practice of making those decisions visible, assigning them to accountable people, testing them against evidence, and keeping the right to revisit them.*

Working thesis of this inquiry

01

Visible

Decisions that are not recorded cannot be reviewed, challenged or learned from.

02

Accountable

Every material decision needs a named owner with the authority to make it and the duty to explain it.

03

Revisable

Data and context drift, so governance must preserve the ability to detect error and change course.

Five research questions guide the inquiry

RQ1 What is decided?	Which decisions are embedded in a data science system, who makes them, and which carry the greatest downstream consequence?
RQ2 How should we decide?	Which normative and descriptive decision frameworks best fit the uncertainty, stakes and reversibility of data science choices?
RQ3 What is required?	What do the EU AI Act, UK law, ISO/IEC 42001 and NIST AI RMF require, and where do they converge or diverge?
RQ4 What can go wrong?	What failure patterns recur across documented public cases, and which controls would have changed the outcome?
RQ5 How do we operate it?	How can governance be embedded in pipelines, roles, metrics and culture so that it scales without stalling delivery?

Method of inquiry

A five stage approach moving from theory to evidence to an actionable framework.

01 Theory review	02 Regulatory analysis	03 Case evidence	04 Pattern synthesis	05 Framework design
Decision theory, behavioural economics, organisational decision rights and the literature on algorithmic accountability.	Primary texts and official guidance: EU AI Act and Digital Omnibus, UK GDPR and DUAA 2025, NIST AI RMF, ISO/IEC 42001.	Ten documented public cases across justice, health, employment, welfare, finance and customer service.	Cross case coding of failure modes against lifecycle decisions to identify where governance most often breaks.	An integrated decision governance model, a canvas and a phased roadmap tested against the evidence.

Note on data Charts marked Illustrative Data use constructed figures to teach a method. All other figures are drawn from cited public sources.

Glossary of core terms

Term	Working definition used in this deck	Anchor reference
Data governance	The exercise of authority, control and shared decision making over the management of data assets.	DAMA DMBOK 2
AI governance	The structures, policies, processes and controls that direct and oversee the design, deployment and use of AI systems.	ISO/IEC 38507, 42001
AI system	A machine based system that infers from inputs how to generate outputs such as predictions, content, recommendations or decisions.	EU AI Act, Article 3
Decision framework	A structured method for identifying options, evaluating consequences under uncertainty and assigning authority to choose.	Decision science
Provider and deployer	The party that develops and places an AI system on the market, and the party that uses it under its own authority.	EU AI Act, Article 3
Human oversight	Measures enabling natural persons to understand, monitor, interpret, override and stop an AI system.	EU AI Act, Article 14
Model risk	The potential for adverse consequences from decisions based on incorrect or misused model outputs.	PRA SS1/23

SECTION

01

Why Data and AI Governance Matters Now

From back office compliance to a board level determinant of value, trust and legitimacy.

IN THIS SECTION

- Definitions and boundaries
- The cost of failure
- Governance as an enabler
- Forces driving urgency
- Harms and stakeholders
- Leadership diagnostics

Slides 10 to 26



Data governance and AI governance are related but distinct

Data governance asks whether the data can be trusted; AI governance asks whether the decisions built on it can be trusted.

Data governance

- **Object:** Data assets: their quality, meaning, lineage, security, access and lifecycle.
- **Central question:** Is this data fit for purpose, lawfully held and properly controlled?
- **Typical owners:** Chief Data Officer, data owners, data stewards, data protection officer.
- **Anchors:** DAMA DMBOK, ISO 8000, UK GDPR, data catalogues and quality rules.

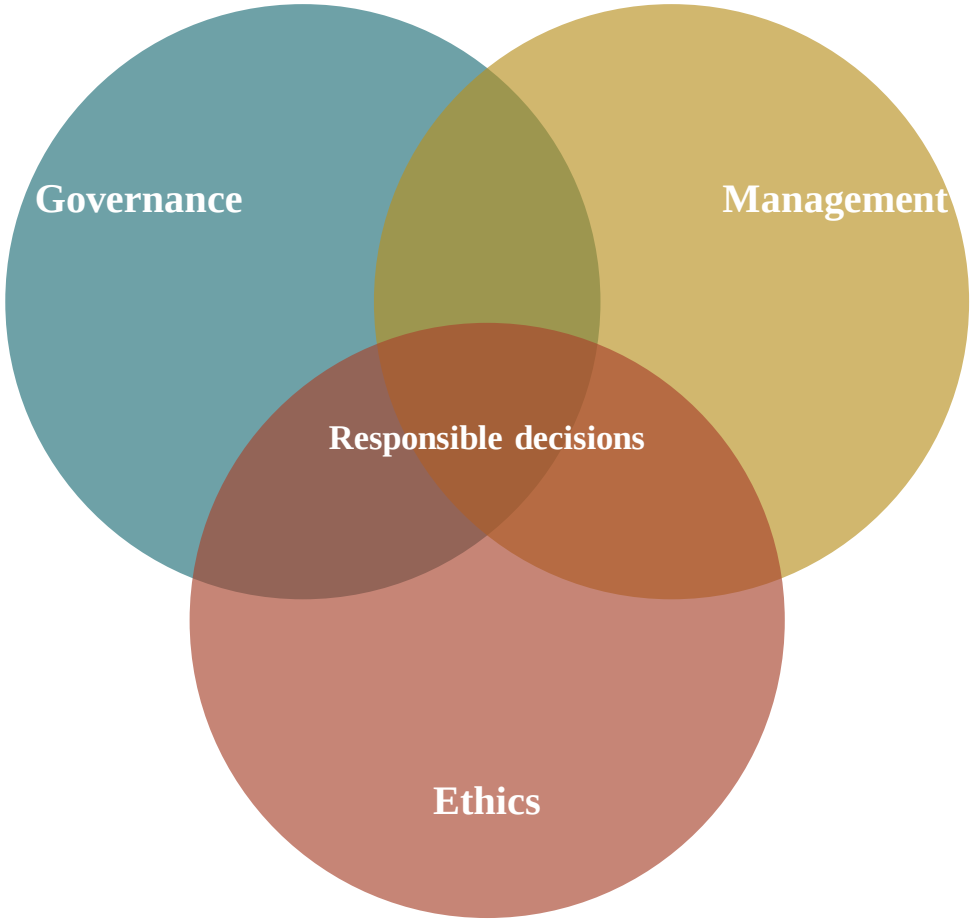
VS

AI governance

- **Object:** AI systems and the decisions, predictions and content they generate.
- **Central question:** Is this system safe, fair, explainable, lawful and under meaningful control?
- **Typical owners:** AI council, model owners, model risk, ethics leads, product leadership.
- **Anchors:** EU AI Act, ISO/IEC 42001, NIST AI RMF, model cards and impact assessments.

Relationship AI governance inherits every weakness of data governance. A fair model cannot be built on unrepresentative data, so the two must be designed as one system.

Governance, management and ethics: drawing the boundaries



Governance

Sets direction, allocates decision rights and holds people accountable. It answers who decides, on what basis and with what oversight.

Management

Executes within that direction: plans, builds, operates and monitors the data and models day to day.

Ethics

Supplies the values against which choices are judged: dignity, fairness, autonomy, beneficence and justice.

Where they meet

Responsible decision making sits at the intersection: ethical values, translated by governance into rules and rights, executed through disciplined management.

Why decisions, not models, are the unit of governance



REFRAMING THE OBJECT

A model is an artefact. A decision is an act with consequences for people. Governing only the artefact misses the choices that surround it: what to predict, whom to include, where to set the threshold and when to let a human intervene.

1

Harms arise from use

The same credit model is benign as a marketing aid and consequential as an automated refusal. Context of use decides risk.

2

Choices precede code

Problem framing and target selection happen before any model exists, yet shape every downstream outcome.

3

Accountability needs agency

Only people and organisations can be held to account. Decisions map naturally to named owners; models do not.

4

Regulation follows use

The EU AI Act classifies risk largely by intended purpose and deployment context, not by algorithm type.

The decision quality chain

Value is created or destroyed at each link; a weak link anywhere caps the quality of the final outcome.

01 Data	02 Insight	03 Decision	04 Action	05 Outcome
Collected, labelled and curated. Quality, representativeness and lawful basis determine the ceiling for everything after.	Models and analyses convert data into estimates. Validity depends on assumptions, features and evaluation design.	Estimates are turned into choices through thresholds, rules and human judgement. This is where policy enters.	A loan is refused, a patient is prioritised, content is published. Actions touch real people and systems.	Consequences are realised and, ideally, fed back to improve data, models and decision rules.



Principle Governance should be proportionate to the consequence of the action, but must reach back through every earlier link that shaped it.

Five forces driving governance urgency

Binding regulation	EU AI Act obligations phasing in from 2025 to 2028; UK DUAA 2025 reforming automated decision making from February 2026.
Scale and speed	Models now decide millions of times per day, so a small error rate becomes a large absolute number of affected people.
Generative and agentic AI	Open ended outputs and autonomous tool use break assumptions built for narrow predictive models.
Trust and reputation	Customers, employees and investors increasingly ask how automated decisions about them are made.
Liability and contracts	Courts and tribunals are holding organisations responsible for what their AI systems say and do.

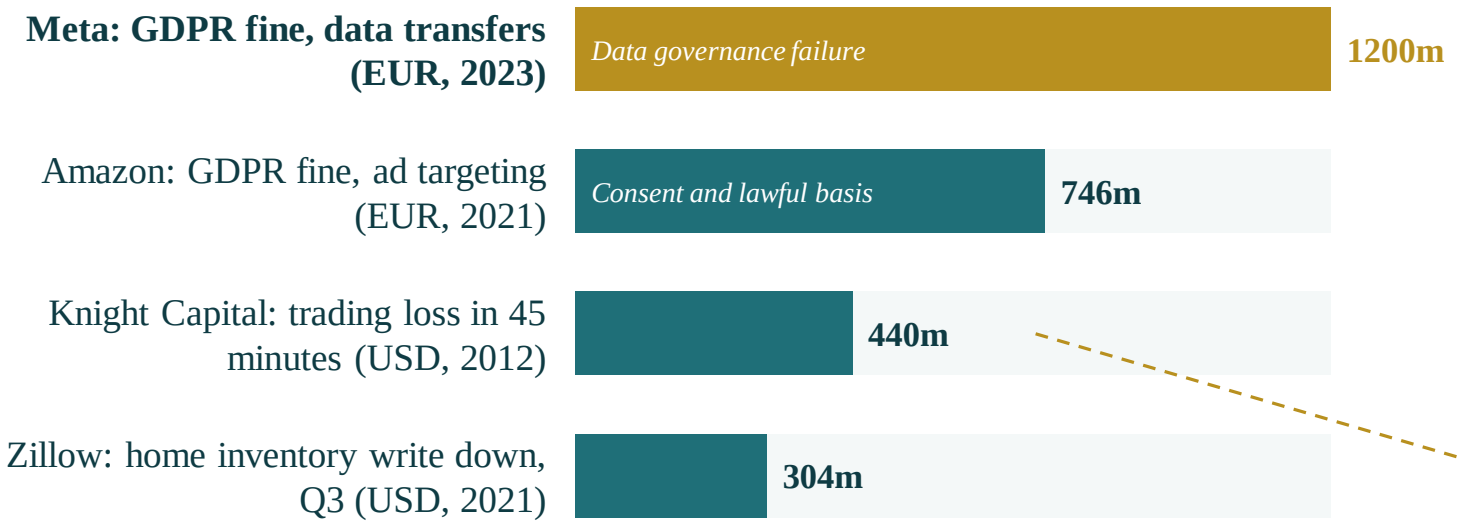
SYNTHESIS

Converging pressures

No single force would make governance a board topic. Together they turn it from optional good practice into a licence to operate.

The cost of governance failure is measured in hundreds of millions

Reported amount, millions in the currency reported



1 Data governance fines dominate

The largest single penalties so far relate to lawful basis and international transfers, core data governance questions.

2 Operational losses can be faster

Knight Capital lost its capital base in under an hour because a deployment decision lacked a control.

Source: Company filings and regulator decisions as publicly reported: SEC (Knight Capital, 2013); Zillow Q3 2021 results; Irish DPC (2023); CNPD Luxembourg (2021).

What stakeholders now expect

Individuals

To be told when AI is used, to understand significant decisions, to contest them and to reach a human.

Regulators

Documented risk management, evidence of testing, registration of high risk systems and incident reporting.

Boards and investors

Clear accountability, a risk appetite for AI, and assurance that value is not built on hidden liabilities.

Employees

Transparency about workplace AI, consultation on monitoring tools and fair treatment in hiring and performance.

Business partners

Contractual assurances on data provenance, model behaviour, security and allocation of liability.

Society

That AI deployment respects rights, avoids entrenching inequality and does not erode democratic processes.

Governance as an enabler, not a brake

Common myths

- Governance slows delivery and adds paperwork without value.
- It is the job of legal and compliance, not of data scientists.
- Good models govern themselves through accuracy metrics.
- Governance can be added after a product succeeds.
- Regulation only matters to large technology companies.

vs

Evidence based reality

- Clear decision rights reduce rework and late stage escalations.
- Practitioners make most governance relevant choices daily.
- Accuracy says nothing about fairness, robustness or legality.
- Retrofitting documentation and controls costs far more.
- Deployers of high risk AI carry obligations regardless of size.

Reframe The aim is not fewer decisions but faster, better documented decisions with the right people involved at the right time.

The governance value hierarchy

Organisations move up the hierarchy as governance shifts from defensive to strategic.



Competitive advantage

Trusted AI becomes a differentiator in procurement, partnerships and customer choice.

Stakeholder trust

Customers and regulators extend latitude to organisations with a credible track record.

Decision quality

Better data and validated models improve the accuracy and consistency of decisions.

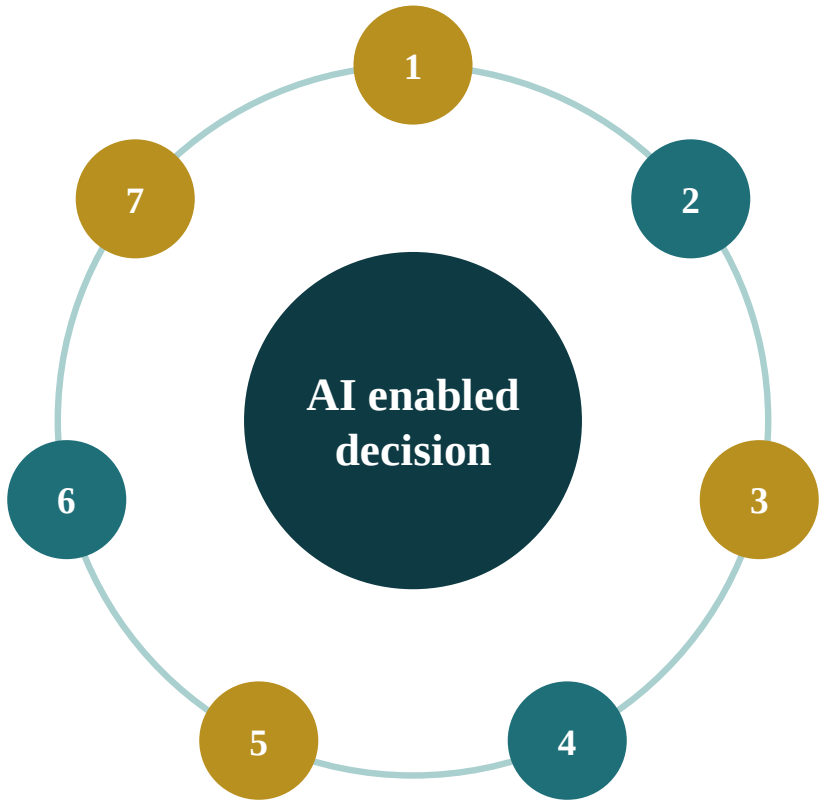
Risk reduction

Fewer incidents, smaller losses and faster recovery when things go wrong.

Legal compliance

The necessary floor: meeting statutory obligations and avoiding sanctions.

Who is affected: the stakeholder ecosystem



1 Decision subjects

People about whom predictions are made: applicants, patients, citizens.

2 Operators

Staff who use outputs and exercise oversight in daily work.

3 Builders

Data scientists, ML engineers and data engineers.

4 Owners and executives

Accountable for purpose, risk appetite and resourcing.

5 Regulators and courts

Set rules, supervise conduct and adjudicate disputes.

6 Suppliers

Model, data and cloud vendors whose components are embedded.

7 Wider society

Third parties affected indirectly through markets and institutions.

Three decades of governance milestones

1995

EU Data Protection Directive

First harmonised European regime, including a right not to be subject to purely automated decisions.

2002

Sarbanes Oxley Act

Made data controls over financial reporting a board responsibility in the US.

2011

Fed SR Letter 11 7

Defined model risk management for US banks: validation, governance and controls.

2018

GDPR applies

Accountability principle, DPIAs and Article 22 safeguards on automated decisions.

2019

OECD AI Principles

First intergovernmental AI standard, updated in May 2024.

2023

NIST AI RMF and ISO 42001

Voluntary risk framework and first certifiable AI management system standard.

2024

EU AI Act enters into force

Regulation (EU) 2024/1689, in force on 1 August 2024, with phased application.

The Structure of an AI harm

Harms rarely have a single cause; they propagate through a chain of compounding decisions.

01 Design choice	02 Data	03 Model	04 Deployment	05 Impact
A proxy target is chosen because it is measurable, not because it reflects what matters.	Historical records encode past inequities and gaps in coverage for some groups.	Optimisation faithfully learns the proxy, including its embedded patterns.	Outputs are applied at scale with weak review and no route to challenge.	Individuals are denied services or misjudged; errors cluster in particular groups.



Lesson Each link was a decision that someone could have questioned. Governance places a checkpoint and an owner at every link.

Six categories of AI harm

Individual

Wrongful denial of credit, benefits, jobs or care; loss of privacy; psychological harm.

Group

Systematic disadvantage for protected or vulnerable groups through biased error rates.

Societal

Erosion of trust in institutions, information integrity and democratic processes.

Organisational

Fines, litigation, remediation costs, lost customers and reputational damage.

Environmental

Energy and water use from training and inference at scale.

Systemic

Correlated failures when many firms rely on the same models, data or vendors.

Governance debt accumulates silently

A USEFUL METAPHOR

Like technical debt, governance debt is the gap between the decisions an organisation has made and the evidence it holds to justify them. It compounds with every undocumented model, untested assumption and unowned dataset.

1 **Symptoms**

No inventory of models in use; nobody can explain why a threshold was chosen; datasets with unknown provenance.

2 **Interest payments**

Slow audits, emergency remediation, blocked deals, and regulatory questions that cannot be answered quickly.

3 **Default risk**

A single incident forces a full reconstruction of decisions under time pressure and public scrutiny.

4 **Repayment**

Inventory first, then risk tier, then document the highest risk decisions and embed controls going forward.

Ten diagnostic questions for leaders

- ☑ Do we have a complete inventory of the AI systems we build, buy and use?
- ☑ Can we name an accountable owner for each material AI decision?
- ☑ Have we classified each system against EU AI Act risk tiers?
- ☑ Do we know which datasets feed which models, and on what lawful basis?
- ☑ Is there a documented rationale for every decision threshold in production?
- ☑ Do affected people have a route to challenge automated decisions?
- ☑ Are fairness and robustness tested before release and monitored after?
- ☑ Would our human reviewers notice, and be empowered to correct, a bad output?
- ☑ Do we govern third party and generative AI with the same rigour?
- ☑ Has the board approved an AI risk appetite and seen recent assurance?

Section 1 synthesis

> *Governance has moved from protecting data to legitimising decisions. The organisations that thrive will be those that can show, at any moment, how an automated decision was made and who stands behind it.*

Synthesis of Section 1

01

Distinct but inseparable

Data governance and AI governance must be designed as one system of control.

02

Decisions are the unit

Govern the chain of choices, not only the model artefact.

03

Urgency is structural

Regulation, scale and generative AI make governance a licence to operate.

SECTION

02

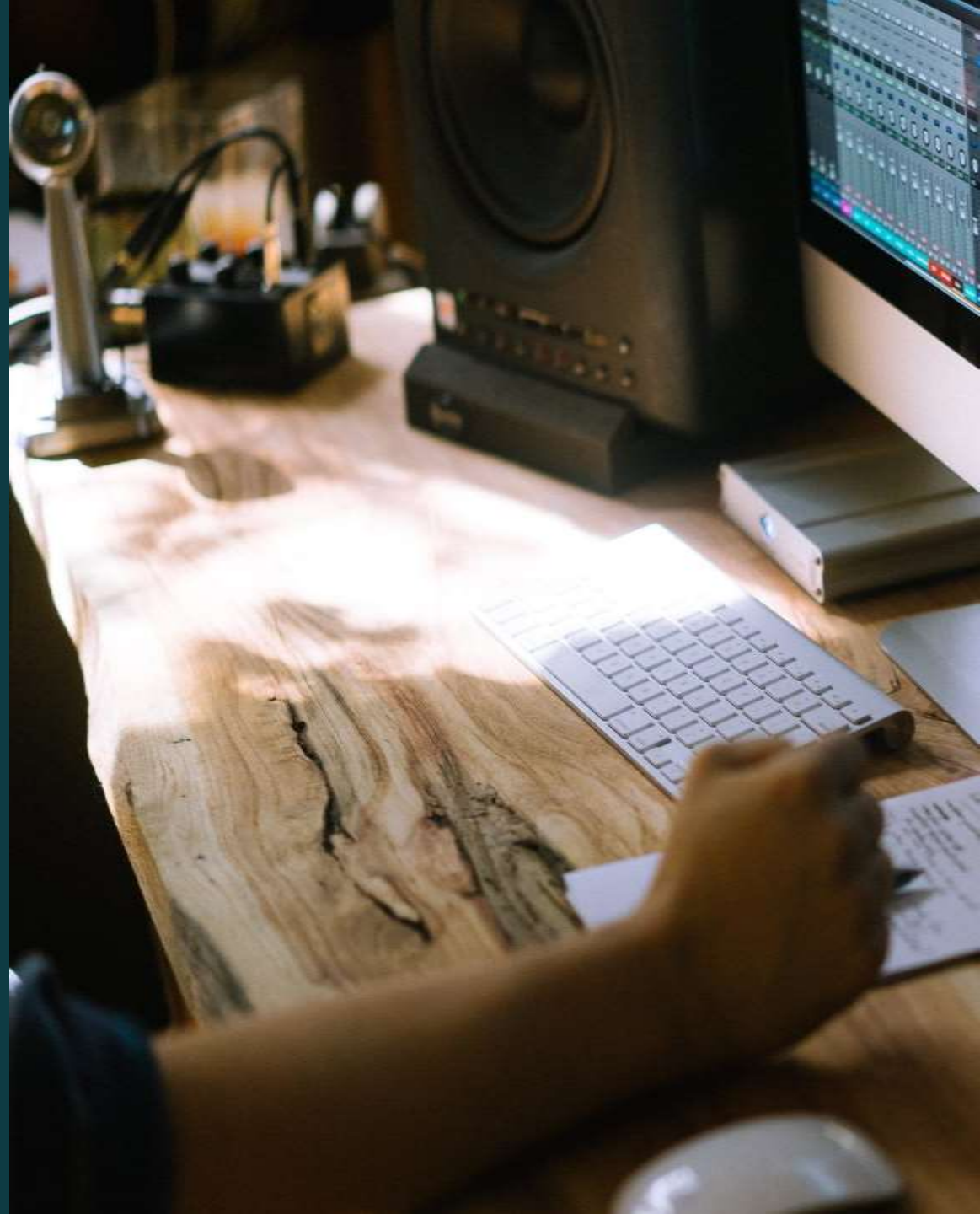
The Structure of Decisions in Data Science

Mapping the hundreds of explicit and tacit choices embedded in every data science system.

IN THIS SECTION

- Decision inventory
- Data and modelling choices
- Automation levels
- Framing and proxies
- Thresholds as policy
- Decision rights

Slides 27 to 44



What counts as a decision in data science

A decision is any choice between alternatives that changes what the system does or whom it affects.

Framing decisions

What problem to solve, what to predict, what success means and which outcome stands in for the real goal.

Data decisions

Which sources, time windows, populations and labels to use, and what to exclude or impute.

Modelling decisions

Algorithm family, features, objective function, regularisation, hyperparameters and validation scheme.

Evaluation decisions

Which metrics, which test sets, which subgroups and what level of performance counts as good enough.

Deployment decisions

Thresholds, automation level, human review, user interface, communication and rollout strategy.

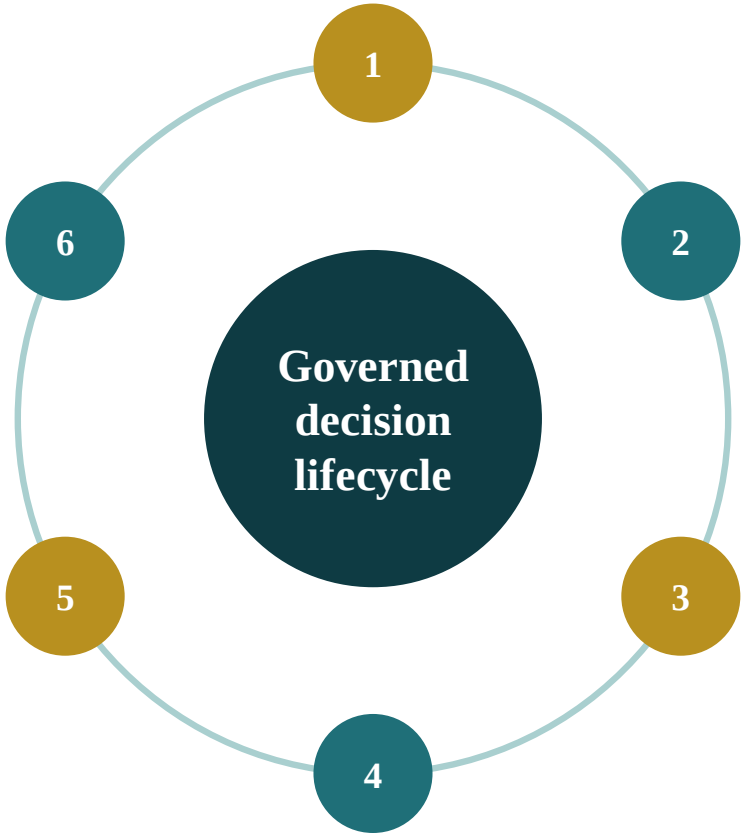
Monitoring decisions

What to watch, alert thresholds, retraining triggers and when to roll back or retire the model.

A decision inventory across the lifecycle

Stage	Representative decisions	Typical owner	Governance artefact
Frame	Objective, target variable, unit of analysis, intended use and excluded uses	Product owner	Use case brief, impact screening
Source	Data sources, consent and lawful basis, sampling frame, retention	Data owner	Datasheet, DPIA, data contract
Prepare	Cleaning rules, imputation, labelling protocol, feature definitions	Data scientist	Pipeline code, label guidelines
Model	Algorithm, objective, constraints, hyperparameters, explainability needs	Data scientist	Experiment log, model card
Evaluate	Metrics, subgroup tests, acceptance criteria, stress tests	Validator	Validation report, fairness report
Deploy	Threshold, automation level, override rules, user notices	Model owner	Release approval, oversight plan
Monitor	Drift metrics, alert limits, retraining triggers, retirement	MLOps lead	Monitoring plan, incident log

CRISP DM revisited through a governance lens



1 Business understanding

Add impact screening, stakeholder mapping and a written statement of intended and prohibited use.

2 Data understanding

Add provenance checks, representativeness analysis and lawful basis confirmation.

3 Data preparation

Add documented transformation rules, label quality audits and lineage capture.

4 Modelling

Add constraint setting for fairness and explainability alongside accuracy objectives.

5 Evaluation

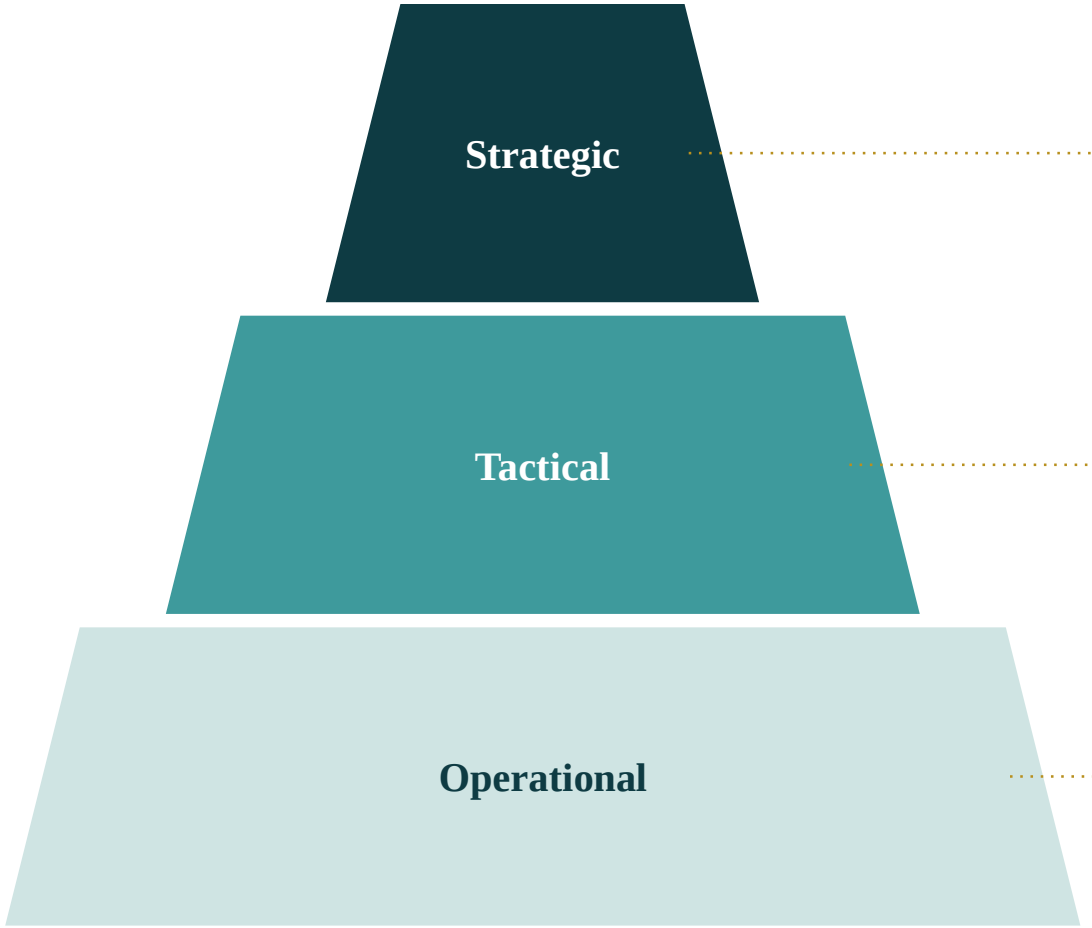
Add independent validation, subgroup analysis and a formal go or no go gate.

6 Deployment

Add oversight design, user transparency, monitoring and a rollback plan. Loop back on drift.

Strategic, tactical and operational decisions

Different decision levels need different forums, evidence standards and cadences.



Strategic: whether and why

Board and executive choices on AI ambition, risk appetite, prohibited uses and investment. Infrequent, high impact, hard to reverse.

Tactical: which and how

Portfolio, use case approval, vendor selection, architecture and policy standards. Quarterly or per project.

Operational: what now

Individual predictions, thresholds in use, overrides and alerts. Continuous, high volume, mostly automated.

Programmed and non programmed decisions

Herbert Simon distinguished routine decisions that can be codified from novel ones that require judgement.

Programmed decisions

- **Nature:** Repetitive, well structured, with clear criteria and stable context.
- **Examples:** Fraud scoring on card transactions, stock replenishment, spam filtering.
- **Suitable for:** Automation with statistical monitoring and exception handling.
- **Governance focus:** Controls, drift detection, error budgets and periodic revalidation.

vs

Non programmed decisions

- **Nature:** Novel, ill structured, high stakes, with contested values or sparse data.
- **Examples:** Child protection referrals, parole, clinical triage in rare conditions.
- **Suitable for:** Decision support with substantive human judgement and deliberation.
- **Governance focus:** Meaningful oversight, contestability, explanation and escalation.

Governance test Misclassifying a non programmed decision as programmed, and automating it, is one of the most common roots of AI harm.

Problem framing: most consequential, least governed



THE FRAMING PROBLEM

Once a problem is framed as predict X, every later step optimises X faithfully. If X is a poor stand in for what matters, a technically excellent model will deliver a poor or harmful decision at scale.

1 **Who frames**

Often a product owner and one analyst, informally, before any governance process begins.

2 **What is lost**

Alternative framings, affected group perspectives and the option of not using AI at all.

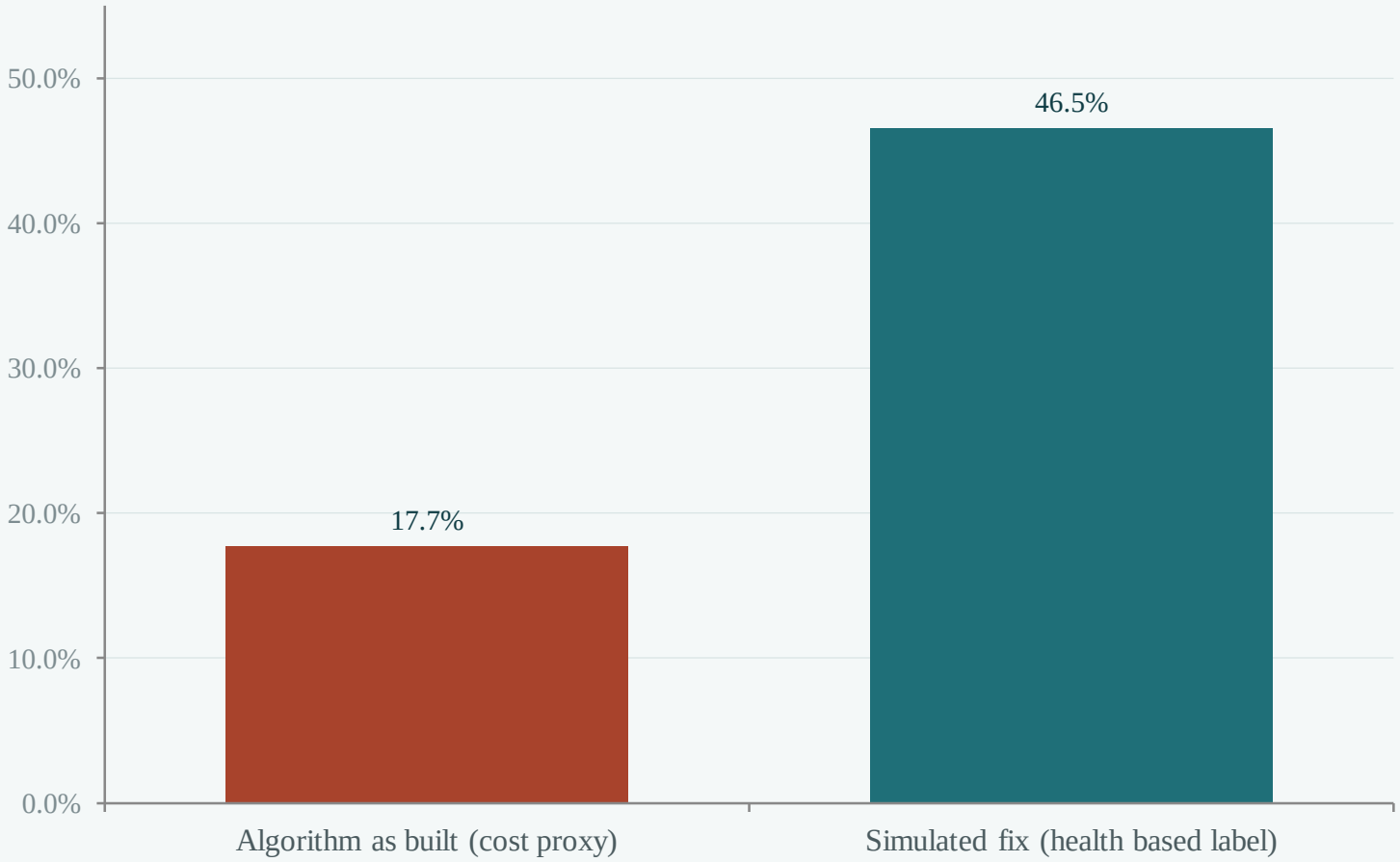
3 **Control**

A mandatory framing review: state the real goal, the proxy, the gap between them and who could be harmed by it.

4 **Evidence**

Record the alternatives considered and why they were rejected, so the framing can be challenged later.

Proxy choice in practice: cost as a stand in for health need



2.6x

Effect of changing the label

A health based label would raise the share of Black patients identified from 17.7% to 46.5%.

Why it happened

Less money was historically spent on Black patients with the same level of need, so cost understated their illness.

Governance lesson

The model was accurate at predicting cost. The flaw was a framing decision that no metric would ever flag.

Source: Obermeyer, Powers, Vogeli and Mullainathan, Science 366 (2019), 447 to 453.

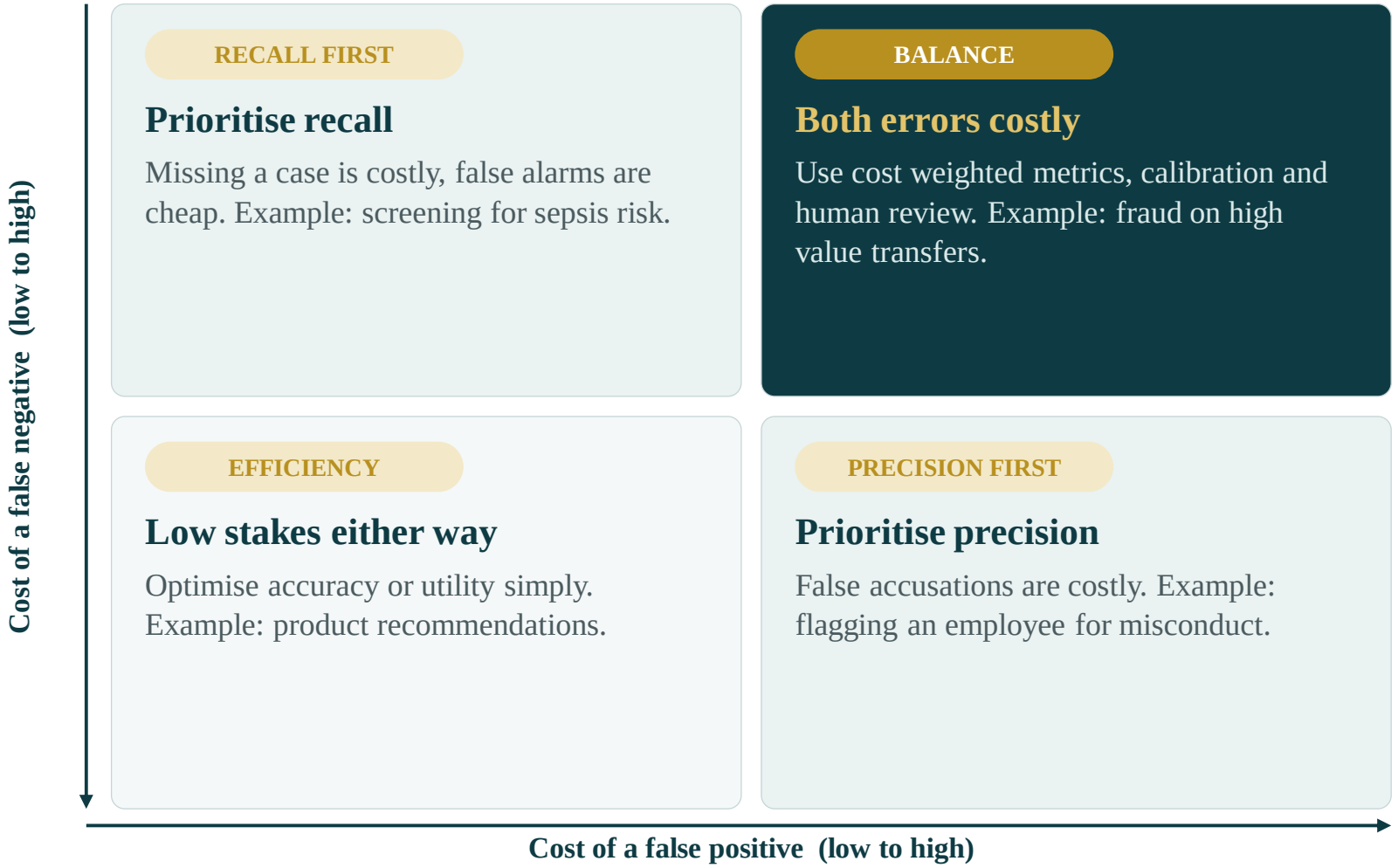
Data decisions: collection, sampling and labelling

Sampling frame	Who is in the data determines whom the model serves well. Gaps in coverage become gaps in accuracy.
Time window	Training periods that include unusual events, such as a pandemic, can encode conditions that no longer hold.
Labelling protocol	Labels are judgements. Annotator guidelines, disagreement handling and labeller demographics shape ground truth.
Exclusion rules	Dropping records with missing values can silently remove the people least served by existing systems.
Lawful basis and purpose	Reusing data collected for one purpose to train a model for another may breach purpose limitation.

Modelling decisions and their governance implications

Decision	Options	Governance implication
Model family	Linear, tree ensemble, neural network, foundation model	Interpretability, validation effort and explanation obligations rise with complexity
Features	Include, transform, exclude sensitive attributes and proxies	Excluding a protected attribute does not remove bias carried by correlated proxies
Objective	Accuracy, log loss, cost weighted loss, constrained objectives	The loss function encodes which errors the organisation considers worse
Validation	Random split, temporal split, group split, external test	Leakage and unrealistic splits overstate performance in production
Complexity	Regularisation, depth, ensemble size	Overfitting to historical artefacts reduces robustness under drift
Build or buy	In house, open model, vendor API	Third party models shift control but not accountability for the decision

Evaluation decisions: metrics shape behaviour



GOODHART

Choose metrics as policy

When a metric becomes a target it stops being a good measure. Selecting the evaluation metric is a value judgement about which errors matter.

Threshold setting is a policy choice

$$\textit{Act if } p(\text{positive} \mid x) > t^*, \textit{ where } t^* = C(FP) / (C(FP) + C(FN))$$

$p(\cdot|x)$

Calibrated probability that the case is positive given its features.

t^*

Decision threshold that minimises expected cost for a single case.

$C(FP)$

Cost of acting on a case that is actually negative: a false alarm.

$C(FN)$

Cost of failing to act on a case that is actually positive: a miss.

WORKED EXAMPLE

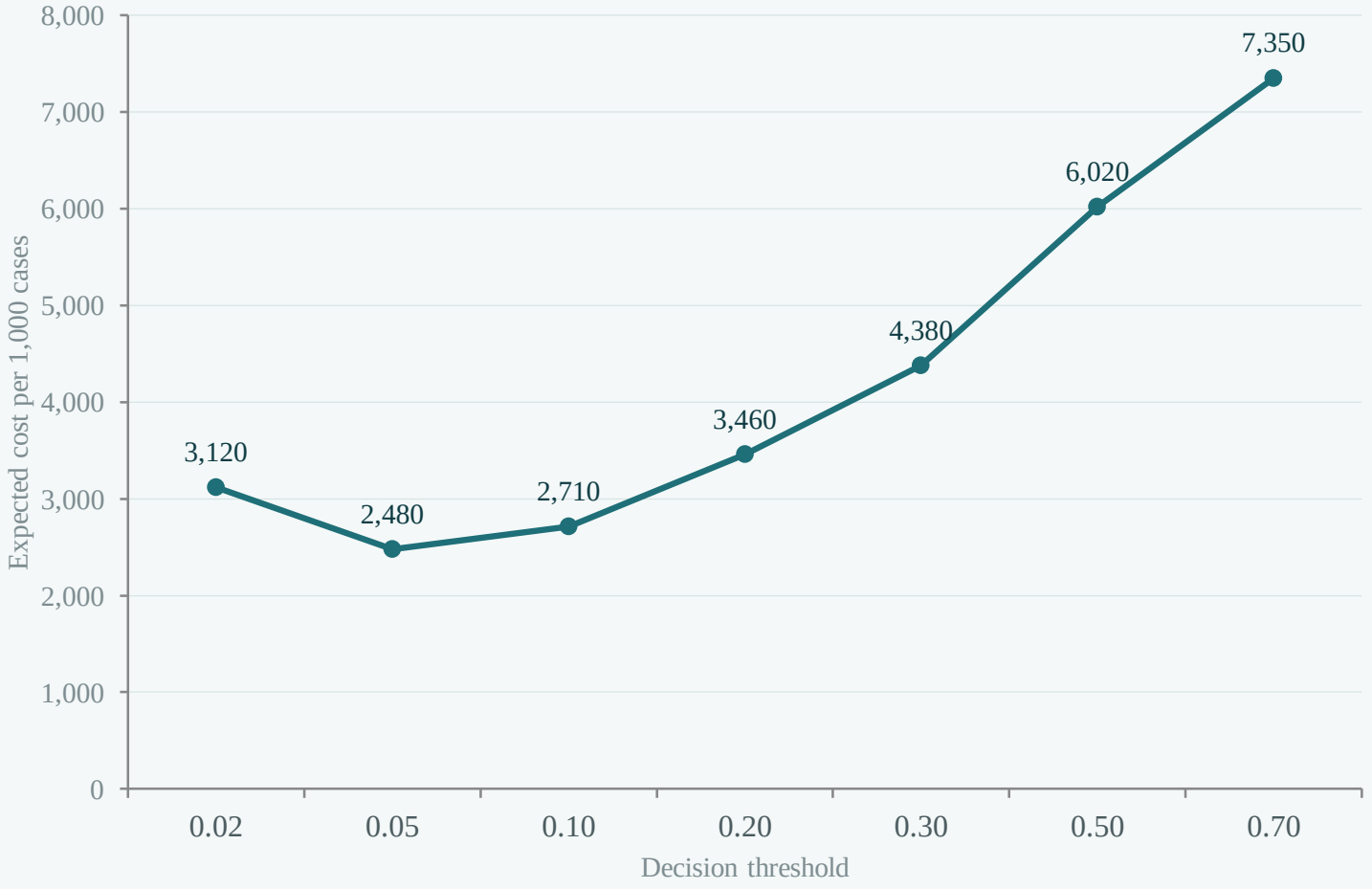
A fraud review costs 20 in analyst time (false positive). A missed fraud costs 380 on average (false negative).

t* = 20 / (20 + 380) = 0.05

So review every transaction with fraud probability above 5%, not the default 50%. The threshold encodes a value judgement about relative harms, and must be owned and documented.

ILLUSTRATIVE DATA

Worked example: expected cost across thresholds



0.05

Optimal threshold

Matches the analytical result t* = 0.05 when the model is well calibrated.

Default is expensive

Using the conventional 0.50 cut off more than doubles expected cost in this example.

Govern the number

Record the costs assumed, who agreed them and when they will be reviewed.

Deployment decisions: choosing the level of automation

Human decides — **Machine decides**



LEVEL A

Information

Model output is one input among many; the human may ignore it.

LEVEL B

Recommendation

Model proposes an option; a human must actively accept or reject it.

LEVEL C

Exception review

Model decides routine cases; humans review uncertain or adverse ones.

LEVEL D

Supervised automation

Model decides; humans sample, monitor and can halt the system.

LEVEL E

Full automation

Model decides without routine human involvement. Requires strong legal and risk justification.

Monitoring and retirement decisions

01 Define signals	02 Set limits	03 Detect	04 Decide	05 Retire
Input drift, output drift, performance against delayed labels, subgroup gaps and complaint volumes.	Agree warning and action thresholds in advance, linked to risk tier and business impact.	Automated alerts route to the model owner with context, not just raw metrics.	Accept, recalibrate, retrain, restrict scope, fall back to rules or roll back the model.	Decommission deliberately: archive evidence, notify users, remove access and update the inventory.



Often forgotten Retirement is a decision. Models that are never formally retired continue to influence decisions long after anyone remembers why.

Hidden decisions: defaults and tacit choices

Library defaults

A 0.5 classification threshold, default regularisation or class weights adopted without anyone deciding.

Silent exclusions

Rows dropped by a join or a missing value rule that remove whole groups from training.

Convenience windows

The training period chosen because it was easiest to extract, not because it was representative.

Inherited labels

Historical human decisions treated as ground truth although they carry past bias.

Vendor choices

Assumptions embedded in third party models that the deploying organisation never sees.

Interface design

How a score is displayed, colour coded or ordered strongly steers human reviewers.

Decision rights: who decides what

	Board	Exec AI council	Model owner	Data scientist	Validator	DPO and legal
AI risk appetite	Decides	Contributes	Informed			Consulted
Prohibited use list	Challenges	Decides	Informed			Contributes
Use case approval	Informed	Decides	Contributes	Informed	Consulted	Contributes
Target and proxy		Consulted	Decides	Contributes	Consulted	Informed
Feature set			Contributes	Decides	Consulted	Consulted
Decision threshold		Informed	Decides	Consulted	Contributes	Informed
Release to production		Consulted	Decides	Informed	Challenges	Consulted
Retirement		Consulted	Decides	Informed	Consulted	Informed

Decides Challenges Contributes Consulted Informed

Section 2 synthesis

> *A data science system is an accumulation of decisions, many of them made by default, early and without an owner. Mapping those decisions is the first act of governance.*

Synthesis of Section 2

01

Inventory decisions

List the choices at each lifecycle stage and attach an owner and an artefact.

02

Govern framing

Target and proxy choices deserve the strongest scrutiny because no metric reveals them.

03

Thresholds are policy

Cut offs, automation levels and retirement are value judgements to be owned.

SECTION

03

Decision Making Frameworks: Theory and Models

From expected utility to Cynefin: which lens fits which data science decision.

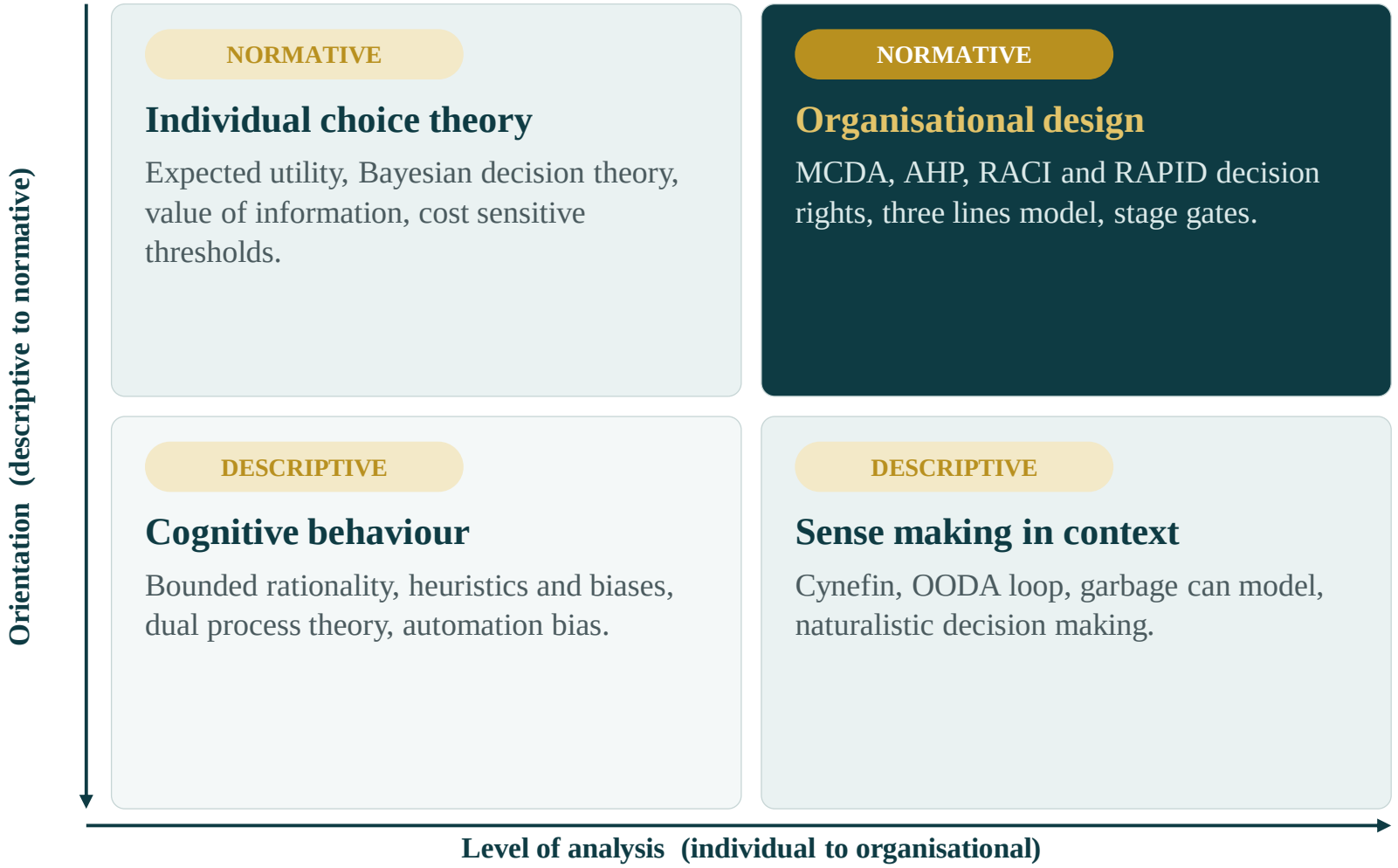
IN THIS SECTION

- Normative decision theory
- Sense making frameworks
- Value of information
- Bounded rationality and bias
- Multi criteria analysis
- Decision rights models

Slides 45 to 64



A map of decision frameworks



HOW TO READ

Use more than one lens

Normative models say how a rational agent should decide; descriptive models say how people actually decide. Good governance designs for the gap.

Rational choice: maximising expected utility

$$EU(a) = \Sigma\ p(s) \times u(a, s) \qquad \text{choose } a^* = \operatorname{argmax}\ EU(a)$$

a

An available action, for example deploy model A, deploy model B or keep the manual process.

s

A possible state of the world, such as demand rising or falling, or drift occurring.

$p(s)$

Probability assigned to each state, ideally from evidence rather than intuition.

$u(a, s)$

Utility of the outcome when action a meets state s, including non financial harms.

WORKED EXAMPLE

Deploy a new churn model or keep the old one.

States: no drift (p = 0.7), drift (p = 0.3).

New model utility: 100 if no drift, 20 if drift.

Old model utility: 60 in both states.

EU(new) = 0.7 × 100 + 0.3 × 20 = 76

EU(old) = 60

Deploy the new model, but note the result reverses if p(drift) exceeds 0.5. That break even point is what governance should monitor.

Bayesian decision theory: updating, then acting

$$p(\theta \mid D) \propto p(D \mid \theta)\, p(\theta) \qquad \text{Bayes risk: } r(\delta) = E[\, L(\theta, \delta(D))\,]$$

$p(\theta)$ — Prior belief about an unknown quantity, such as a model error rate in a new market.

$p(D \mid \theta)$ — Likelihood of the observed data under each possible value of the quantity.

$p(\theta \mid D)$ — Posterior belief after seeing the data: the basis for the decision.

$L(\theta, \delta)$ — Loss incurred when decision rule δ is applied and the truth is θ.

WORKED EXAMPLE

Prior: a vendor claims error below 5%. We hold a Beta(2, 38) prior, mean 5%.

Pilot data: 9 errors in 100 cases.

Posterior: Beta(11, 129), mean 11 / 140 = 7.9%.

If our risk appetite caps error at 6%, the posterior gives strong reason to pause rollout and request evidence, rather than relying on the vendor claim.

Bounded rationality and satisficing

HERBERT SIMON

Real decision makers have limited time, information and cognitive capacity. They search until they find an option that is good enough, rather than the best possible one. Governance should make good enough explicit and defensible.

1. **Aspiration levels**
   Define acceptance criteria before experimentation, so that satisficing is principled rather than convenient.

2. **Search costs**
   Exhaustive hyperparameter or model search has diminishing returns; set budgets and stopping rules.

3. **Procedural rationality**
   When outcomes are uncertain, judge decisions by the quality of the process followed.

4. **Implication**
   Documented process, not perfect foresight, is the realistic standard for defensible AI decisions.

Heuristics and biases inside data teams

Bias	How it shows up in data science	Countermeasure
Confirmation bias	Searching for analyses that support the expected result and stopping when found	Pre registered hypotheses and analysis plans
Anchoring	Fixating on the first model or baseline metric reported	Independent baselines and blind comparisons
Automation bias	Accepting model outputs without adequate scrutiny	Interface friction and mandatory rationale for agreement
Sunk cost	Continuing a failing project because of investment already made	Stage gates with explicit kill criteria
Availability	Overweighting vivid recent incidents when assessing risk	Base rates and structured risk registers
Benchmark overfitting	Tuning repeatedly against a single test set	Held out final test sets used once
Groupthink	Consensus without challenge in small expert teams	Red teams and devil advocate roles

Dual process thinking: System 1 and System 2

Kahneman distinguishes fast, intuitive judgement from slow, deliberate reasoning. Both appear in data work.

System 1: fast

- **Character:** Automatic, effortless, associative, pattern based.
- **Strength:** Expert intuition in familiar, high feedback environments.
- **Risk:** Plausible stories from noisy charts; overconfidence in a single result.
- **Where it appears:** Rapid triage of alerts, quick approval of familiar model updates.

vs

System 2: slow

- **Character:** Effortful, rule based, sequential, analytical.
- **Strength:** Novel problems, rare events and decisions with contested values.
- **Risk:** Costly and easily depleted; skipped under deadline pressure.
- **Where it appears:** Validation, impact assessment, threshold setting, incident review.

Design principle Use governance checkpoints to deliberately trigger System 2 at high stakes moments, and let System 1 handle routine, well monitored work.

Cynefin applied to AI decisions

Snowden and Boone: the nature of the situation should determine the decision method.

Clear

Cause and effect obvious. Sense, categorise, respond. Apply standard controls, such as data validation rules.

Complicated

Cause and effect knowable by experts. Sense, analyse, respond. Model validation and expert review.

Complex

Cause and effect only clear in hindsight. Probe, sense, respond. Staged rollouts and A/B experiments.

Chaotic

No perceivable cause and effect. Act, sense, respond. Incident response: halt the model, then stabilise.

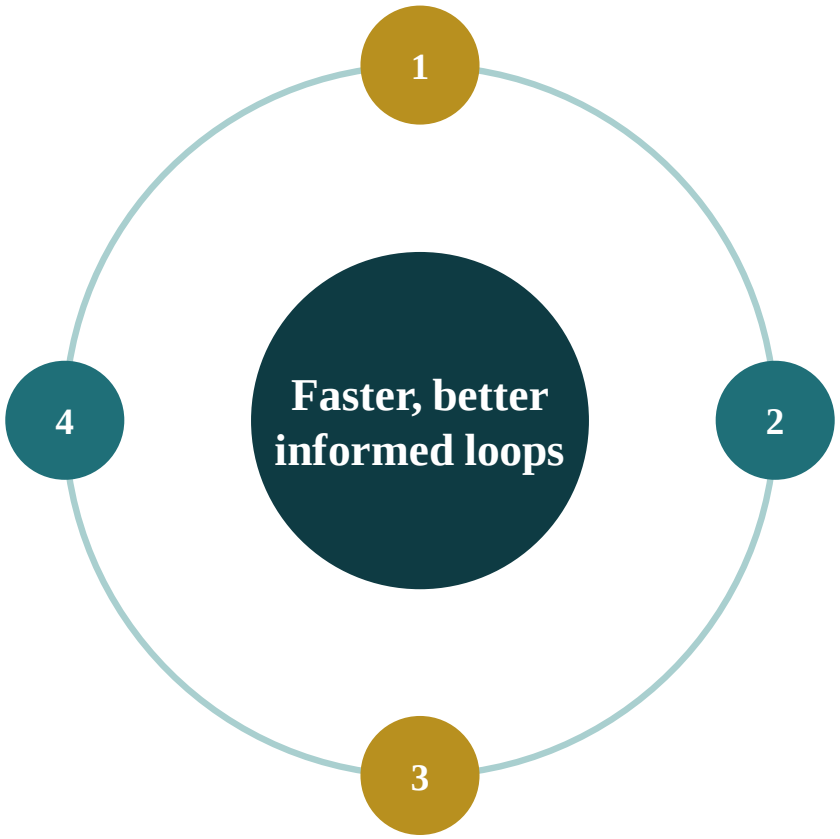
Confusion

Unclear which domain applies. Break the situation into parts and assign each to a domain.

Governance insight

Most AI deployments in social settings are complex, not complicated. Expert sign off alone is insufficient; plan to learn in production.

The OODA loop for model operations



1 Observe

Collect monitoring signals: drift, performance, complaints, incidents and external change.

2 Orient

Interpret signals against context, risk appetite and prior experience. The most important step.

3 Decide

Choose a response from a pre agreed playbook: recalibrate, retrain, restrict or roll back.

4 Act

Execute through controlled pipelines, then feed results back into observation.

Multi criteria decision analysis in six steps

MCDA makes trade offs explicit when options must be judged on several incommensurable criteria.

01 Define options	02 Set criteria	03 Weight criteria	04 Score options	05 Aggregate	06 Decide and record
List genuine alternatives, including do nothing and non AI options.	For example accuracy, fairness, explainability, cost, privacy and time to deploy.	Elicit weights from accountable stakeholders, not only the technical team.	Use evidence based scores on a common scale for each criterion.	Compute weighted scores and test sensitivity of the ranking to weights.	Document the choice, the weights and the dissent for later review.



Value MCDA does not remove judgement. It exposes where judgement lies, so it can be challenged by the right people.

ILLUSTRATIVE DATA

MCDA worked example: choosing a credit model

Criterion	Weight	Logistic regression	Gradient boosting	Deep network
Predictive accuracy	0.30	6	9	9
Fairness across groups	0.25	8	7	6
Explainability to applicants	0.20	9	6	3
Robustness under drift	0.15	7	7	5
Operating cost	0.10	9	7	4
Weighted score	1.00	7.55	7.40	5.95



Reading The simpler model narrowly wins once explainability and fairness are weighted. If the accuracy weight rises above about 0.33, with other weights scaled down proportionally, gradient boosting overtakes it: a sensitivity worth recording.

ILLUSTRATIVE DATA

Analytic Hierarchy Process: pairwise judgements

Saaty's AHP derives weights from pairwise comparisons on a 1 to 9 scale and checks consistency.

	Accuracy	Fairness	Explainability	Cost
Accuracy	1	2	3	5
Fairness	1/2	1	2	4
Explainability	1/3	1/2	1	3
Cost	1/5	1/4	1/3	1

Column preferred Equal importance Moderate Strong

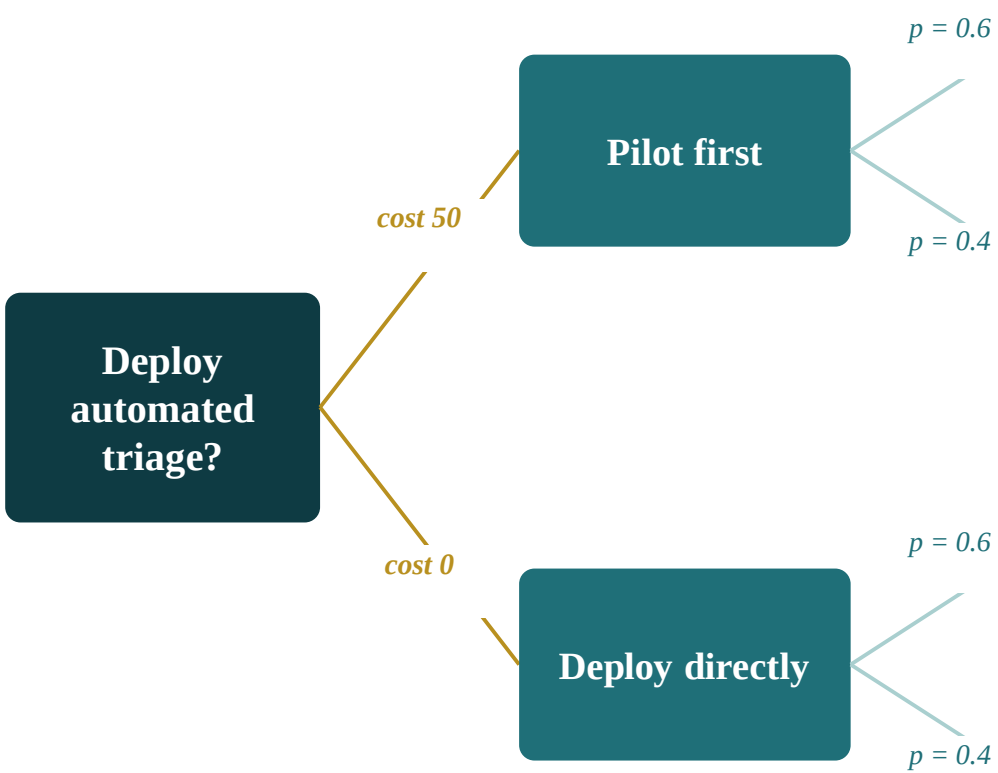
DERIVED WEIGHTS

0.47

Accuracy weight

The principal eigenvector gives weights of 0.47 accuracy, 0.28 fairness, 0.17 explainability and 0.07 cost. The consistency ratio is 0.02, well below the 0.10 limit, so the judgements are coherent. Read each cell as row importance relative to column.

Decision trees: structuring a deployment choice



Pilot succeeds

Full rollout with evidence. Net value 400.

Pilot fails

Stop early, limited harm. Net value 0.

Works in production

Full value realised sooner. Net value 450.

Fails in production

Harm, remediation and reputational loss. Net value minus 300.

RESULT

190

Pilot first wins

Pilot: 0.6 × 400 + 0.4 × 0 minus 50 = 190. Direct: 0.6 × 450 + 0.4 × (minus 300) = 150. The pilot buys information worth more than its cost.

Value of information: when is more evidence worth it?

$$EVPI = E[\max_a u(a, s)] \text{ minus } \max_a E[u(a, s)]$$

EVPI

Expected value of perfect information: the most it is rational to pay to remove uncertainty.

EVSI

Expected value of sample information: the value of a realistic study, pilot or audit.

Decide now

If the cost of more data exceeds its value of information, act on current evidence.

Collect

If value of information exceeds cost, run the pilot, test or validation first.

USING THE CHURN EXAMPLE

With perfect information we would pick the new model when there is no drift (100) and the old model when there is drift (60).

$E[\max] = 0.7 \times 100 + 0.3 \times 60 = 88$

$\max E = 76$

EVPI = 88 minus 76 = 12

Any drift study costing more than 12 units is not worth commissioning for this decision.

Precaution and proaction: two stances on uncertainty

Precautionary principle

- **Stance:** Where harm is serious or irreversible, lack of certainty is no reason to delay protective action.
- **Burden:** On the proposer to show acceptable safety.
- **Fits:** Prohibited practices, biometric surveillance, child safety, critical infrastructure.
- **Risk:** Forgone benefits and innovation if applied indiscriminately.

VS

Proactionary stance

- **Stance:** Weigh the costs of not acting as seriously as the costs of acting.
- **Burden:** Shared, with reversible experiments and close monitoring.
- **Fits:** Low risk, reversible uses with strong monitoring and rollback.
- **Risk:** Harms to those least able to object if monitoring is weak.

Synthesis Calibrate the stance to reversibility and severity. Risk tiering under the EU AI Act is effectively a codified version of this choice.

Organisational decision rights models compared

Model	Roles	Best suited to	Watch out for
RACI	Responsible, Accountable, Consulted, Informed	Mapping process steps and ownership	Many C entries that slow decisions
RAPID	Recommend, Agree, Perform, Input, Decide	Clarifying who holds the single D on key decisions	Agree roles that become hidden vetoes
DACI	Driver, Approver, Contributors, Informed	Fast moving product and agile teams	Approver unclear when risks escalate
Three lines	Management, risk oversight, internal audit	Assurance and independent challenge	Second line drawn into first line work
Stage gates	Gatekeepers at defined lifecycle points	High risk models with formal approvals	Ritual sign offs without evidence

Vroom Yetton: how participative should the decision be?

Leader decides alone — **Group decides**



AI

Autocratic I

Leader decides using available information. Suits urgent incident containment.

AII

Autocratic II

Leader gathers facts from others, then decides alone.

CI

Consultative I

Leader consults individuals, then decides. Common for model releases.

CII

Consultative II

Leader consults the group collectively. Fits high risk use case approval.

GII

Group

Group reaches consensus. Fits defining AI principles and prohibited uses.

Structured group decision methods

Delphi method

Anonymous expert estimates over several rounds with feedback. Useful for eliciting probabilities of rare AI failures where data is absent.

Nominal group technique

Silent idea generation, round robin sharing, then voting. Reduces dominance by senior voices in risk workshops.

Red teaming

A designated team attempts to break the system or the argument. Essential for generative AI and high stakes deployments.

Pre mortem

Imagine the deployment has failed badly and explain why. Surfaces risks that optimism bias would otherwise hide.

Choosing a framework: a selection guide

Situation	Recommended framework	Why
Single choice, quantifiable outcomes	Expected utility, decision tree	Transparent arithmetic; easy to audit
Evidence arriving over time	Bayesian updating, value of information	Formalises when to wait and when to act
Several competing values	MCDA or AHP	Makes weights and trade offs explicit
High uncertainty, social setting	Cynefin probe sense respond	Avoids false precision; favours safe to fail tests
Live operations	OODA loop with playbooks	Speed with predefined, accountable responses
Unclear ownership	RAPID or RACI	Assigns a single accountable decider
Rare, catastrophic risks	Precaution, red team, pre mortem	Counters optimism and data scarcity

Section 3 synthesis

> *No single framework is sufficient. Normative models tell us how to weigh evidence; descriptive models warn us how we will fail to; organisational models decide who gets to choose.*

Synthesis of Section 3

01

Quantify where possible

Expected cost, Bayesian updating and value of information make trade offs auditable.

02

Design for human limits

Checkpoints trigger deliberate thinking at high stakes moments.

03

Match method to context

Complex social deployments need probing and learning, not just expert sign off.

SECTION

04

Data Governance Foundations: Quality, Lineage and Stewardship

The substrate on which every AI decision rests, and the first place governance usually fails.

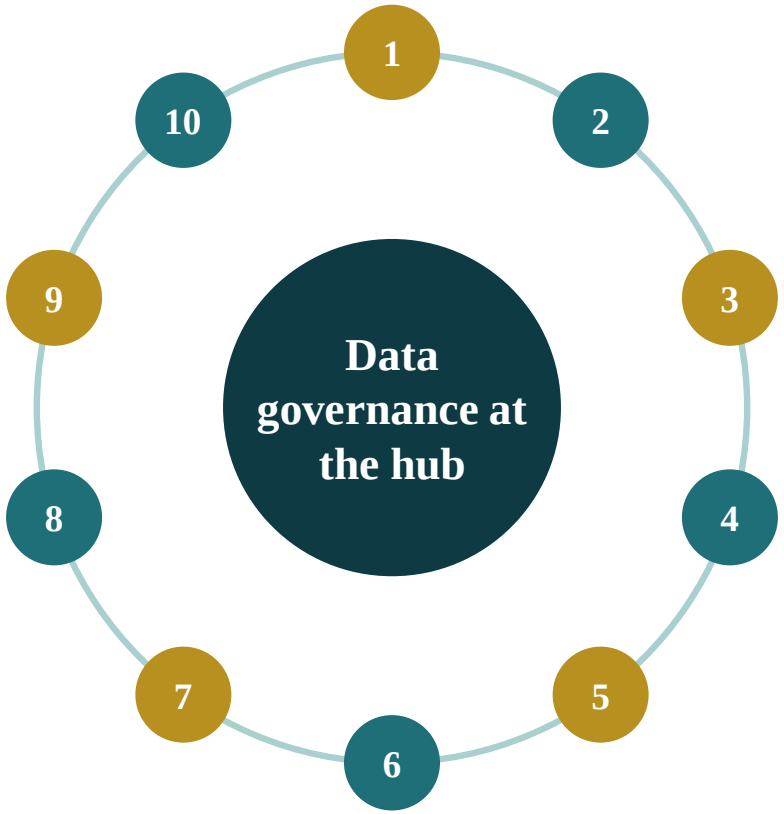
IN THIS SECTION

- DAMA knowledge areas
- Data quality and its cost
- Privacy by design and PETs
- Operating models and roles
- Metadata and lineage
- Data mesh and contracts

Slides 65 to 83



The DAMA DMBOK wheel: eleven knowledge areas



1 Data architecture
Blueprints for data assets aligned to strategy.

2 Modelling and design
Conceptual, logical and physical models.

3 Storage and operations
Databases, availability, backup and recovery.

4 Data security
Access, privacy and confidentiality controls.

5 Integration
Movement and interoperability across systems.

6 Documents and content
Unstructured data lifecycle management.

7 Reference and master data
Shared, consistent core entities.

8 Warehousing and BI
Analytical stores and reporting.

9 Metadata
Data about data: meaning, origin, use.

10 Data quality
Fitness for purpose, measured and improved.

Three data governance operating models

Centralised

A central data office sets policy and often executes stewardship. Strong consistency and control, but can become a bottleneck far from domain knowledge. Suits smaller or highly regulated firms.

Federated

Domains own their data and governance within shared minimum standards. Close to business context and scalable, but risks inconsistency without strong coordination.

Hybrid, hub and spoke

A central hub defines standards, tooling and assurance; domain spokes execute stewardship. The most common model in large organisations and the natural fit for AI governance.

Core data governance roles

Chief Data Officer	Owns the data strategy and governance programme; chairs the data council; accountable to the executive.
Data owner	Senior business leader accountable for a data domain: approves access, sets quality standards and lawful use.
Data steward	Subject matter expert who defines terms, monitors quality, resolves issues and maintains metadata day to day.
Data custodian	Technical role operating storage, security and pipelines according to owner and steward rules.
Data protection officer	Independent statutory role advising on data protection compliance and acting as regulator contact point.

Six dimensions of data quality

Accuracy

Values correctly describe the real world entity or event. Test against trusted sources or samples.

Completeness

Required values are present. Watch for missingness that is concentrated in particular groups.

Consistency

The same fact agrees across systems and over time, with no contradictory records.

Timeliness

Data is current enough for the decision. Stale features cause silent model degradation.

Validity

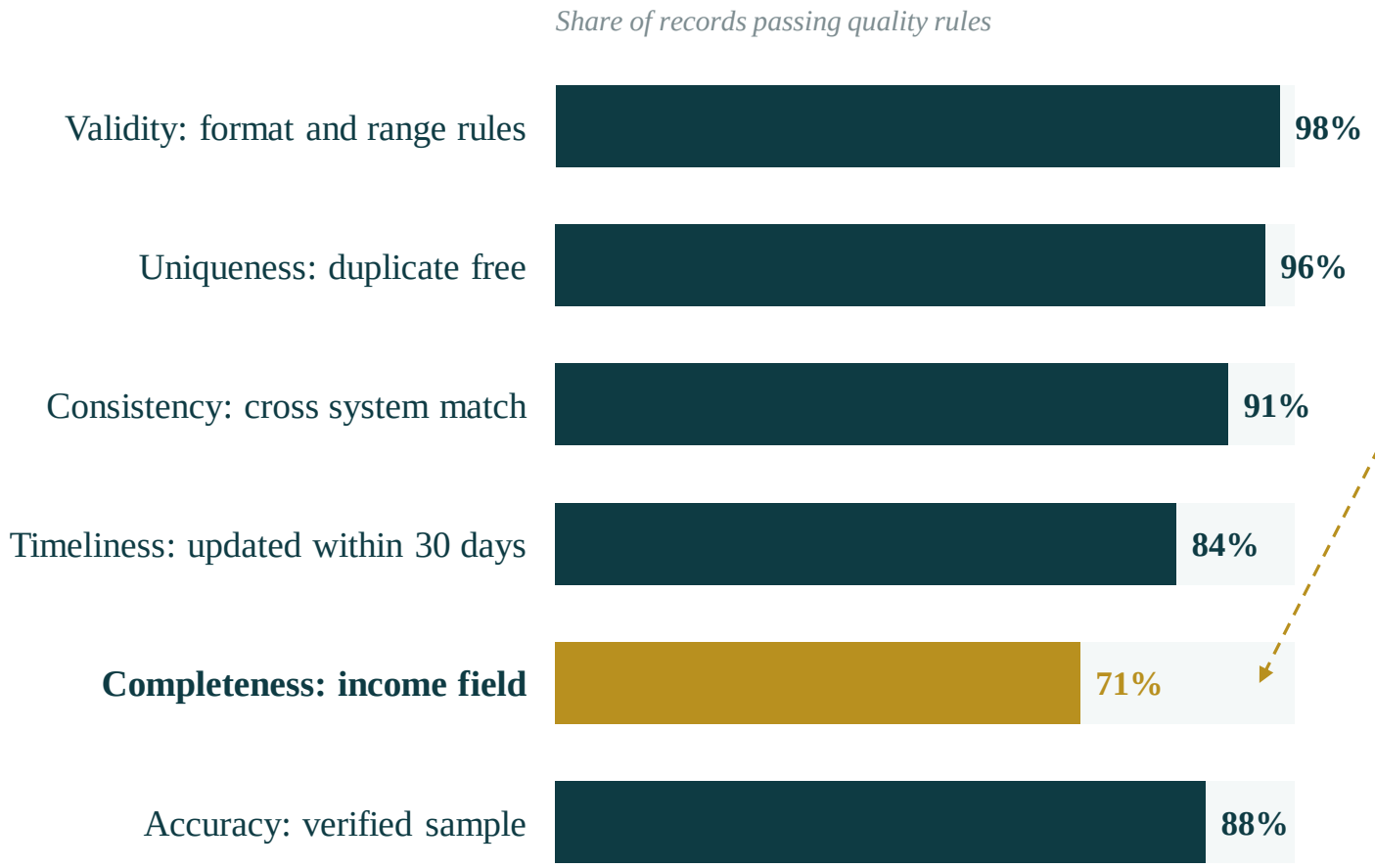
Values conform to defined formats, ranges and business rules.

Uniqueness

Each entity is recorded once. Duplicates distort training distributions and metrics.

ILLUSTRATIVE DATA

A data quality scorecard for a training dataset



1 Missingness is not random

Income is missing for 29% of records overall, but for over 40% of self employed applicants. Imputation choices will shape outcomes for that group.

2 Set fitness thresholds

Agree minimum quality levels per use case and block training runs that fall below them.

The 1 : 10 : 100 rule of data quality

A widely cited heuristic (Labovitz and Chang, 1992): the cost of a quality failure rises sharply the later it is caught.

1

Prevention at entry

Verifying a record at the point of capture costs one unit: validation rules, reference lists and well designed forms.

10

Correction later

Cleansing and reconciling the record after it has propagated costs roughly ten units of effort.

100

Cost of failure

Leaving the error uncorrected until it drives a wrong decision, a model defect or a complaint costs around one hundred units.

For AI In machine learning the multiplier is larger: a bad record can be replicated in every prediction until the model is retrained.

Three layers of metadata

Business metadata	Glossary terms and definitions	Data owners and stewards	Sensitivity classification	Permitted uses
Technical metadata	Schemas and data types	Source systems and tables	Transformation logic	Feature definitions
Operational metadata	Load times and freshness	Quality rule results	Access and usage logs	Job lineage and runs
AI specific metadata	Training dataset versions	Model to data links	Label provenance	Consent and licence terms

Data lineage: the backbone of every audit

Lineage answers the question every investigation asks first: where did this number come from?

01 Source	02 Ingest	03 Transform	04 Feature	05 Model	06 Decision
Operational systems, third party feeds, sensors, purchased or scraped data, each with licence terms.	Extraction jobs with timestamps, schemas and validation results recorded.	Joins, filters, aggregations and imputations, versioned as code.	Feature store entries linked to definitions, owners and upstream columns.	Training run references exact dataset and feature versions used.	Each prediction logged with model version, inputs and output for traceability.



Standard Open standards such as OpenLineage allow lineage events from many tools to be collected into a single graph that auditors can query.

Master and reference data: one version of key entities

WHY IT MATTERS FOR AI

If the same customer appears three times with different attributes, a model will learn three different people. Master data management gives AI systems a single, governed view of the entities they reason about.

1. **Master data**
   Core entities such as customer, product, supplier, employee and location, with golden records.

2. **Reference data**
   Controlled code lists such as country codes, diagnosis codes, currencies and product categories.

3. **Entity resolution**
   Matching and merging duplicates; errors here create false fraud signals and broken features.

4. **Governance**
   Owners approve changes to reference lists because a new category can silently change model inputs.

Data classification and sensitivity tiers

Tier	Examples	Handling rules	AI use conditions
Public	Published reports, open datasets, marketing content	No restriction beyond integrity	Check licence and provenance
Internal	Operational metrics, internal documents	Staff access; no external sharing	Approved internal tools only
Confidential	Customer records, contracts, pricing	Role based access; encryption	DPIA; no public model training; vendor terms reviewed
Special category	Health, biometric, ethnicity, religion, sexual orientation data	Strict access; Article 9 condition required	Explicit legal basis; minimisation; enhanced testing
Restricted	Credentials, security keys, legally privileged material	Need to know; full audit logging	Excluded from AI training and prompts

Privacy by design: seven foundational principles

Ann Cavoukian's principles, now reflected in data protection by design and by default under UK GDPR Article 25.

1 Proactive

Prevent privacy harms before they occur.

2 Default setting

Privacy protected automatically, no action needed.

3 Embedded

Built into architecture, not bolted on.

4 Positive sum

Privacy and functionality both achieved.

5 Lifecycle security

Protected from collection to deletion.

6 Visibility

Practices open to independent verification.

7 User centric

Individual interests kept at the centre.

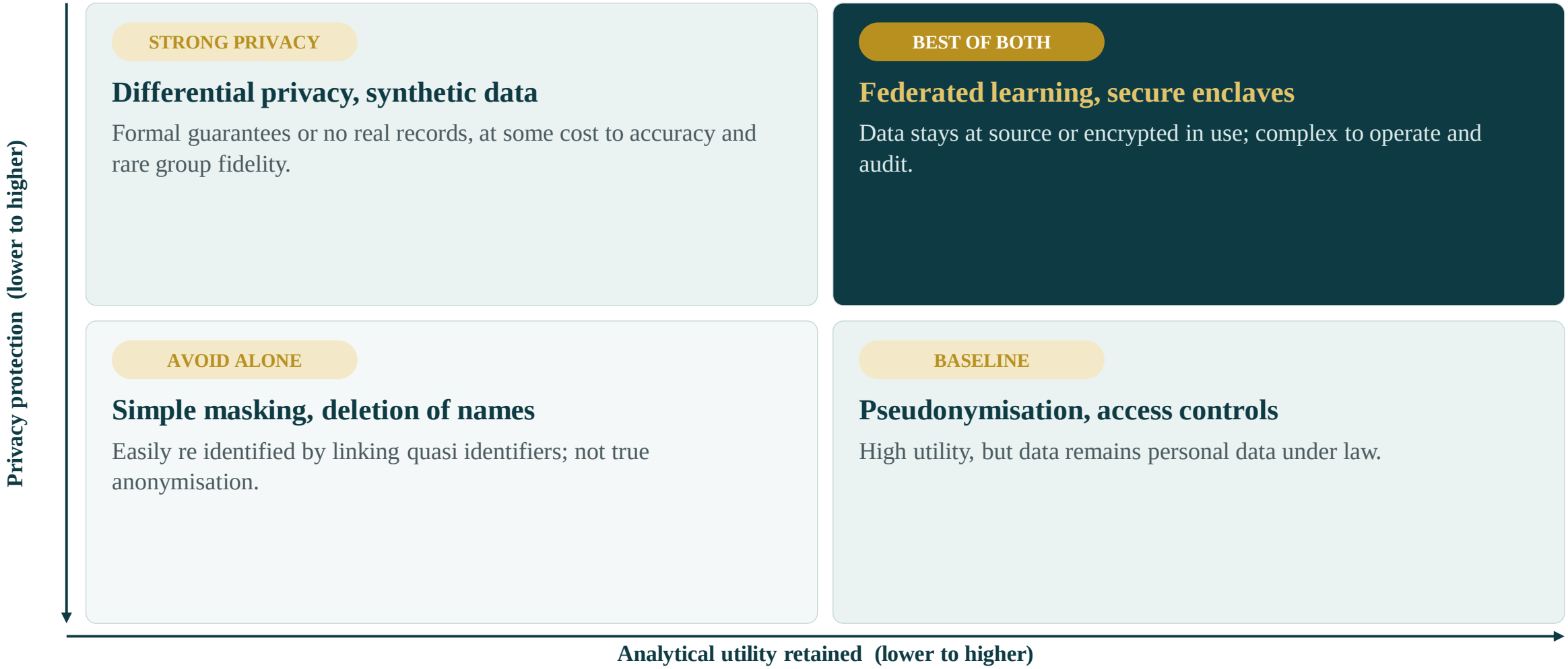
For ML teams

Minimise features, pseudonymise early, restrict retention.

Lawful basis and purpose limitation in machine learning

UK GDPR lawful basis	Typical ML scenario	Key governance consideration
Consent	Personalisation features users opt into	Must be freely given, specific and withdrawable; hard to honour once trained
Contract	Fraud checks needed to provide a payment service	Processing must be genuinely necessary for the contract
Legal obligation	Anti money laundering transaction monitoring	Scope limited to what the law requires
Legitimate interests	Churn prediction, product analytics	Documented balancing test; individuals' rights may override
Recognised legitimate interests	Crime prevention, safeguarding, emergencies	New list under DUAA 2025, Schedule 4; no balancing test needed for listed purposes
Research provisions	Training models for scientific research	DUAA 2025 clarifies research and statistical purposes and safeguards

Privacy enhancing technologies: protection versus utility



Data mesh and federated computational governance

Zhamak Dehghani's four principles redistribute ownership while automating shared standards.

Domain ownership

Teams closest to the data own it end to end, including quality and documentation, rather than a central data team.

Data as a product

Datasets are published with service levels, schemas, documentation and a named product owner.

Self serve platform

A shared platform makes it easy to publish, discover and consume governed data products.

Federated computational governance

Global rules for security, privacy and interoperability are encoded as automated policies that every product inherits.

Data contracts: agreements enforced in code



WHAT A CONTRACT SPECIFIES

A data contract is a versioned agreement between a data producer and its consumers, checked automatically in the pipeline. It turns governance expectations into tests that fail loudly before bad data reaches a model.

1. **Schema and semantics**
   Field names, types, units, allowed values and business definitions.

2. **Quality and freshness**
   Thresholds for completeness and delivery time, with alerting.

3. **Ownership and support**
   Named owner, escalation route and change notification period.

4. **Permitted use**
   Sensitivity tier, lawful basis and whether use for model training is allowed.

Data lifecycle: retention and minimisation decisions

Collect

Minimise at source

Collect only fields with a documented purpose; question every new feature.

Store

Classify and protect

Assign tier, owner and retention period on creation.

Use

Purpose check

Confirm new uses, including training, are compatible with the original purpose.

Share

Contract and log

Data sharing agreements, transfer assessments and access logs.

Retain

Review regularly

Retention schedules apply to training sets and model artefacts too.

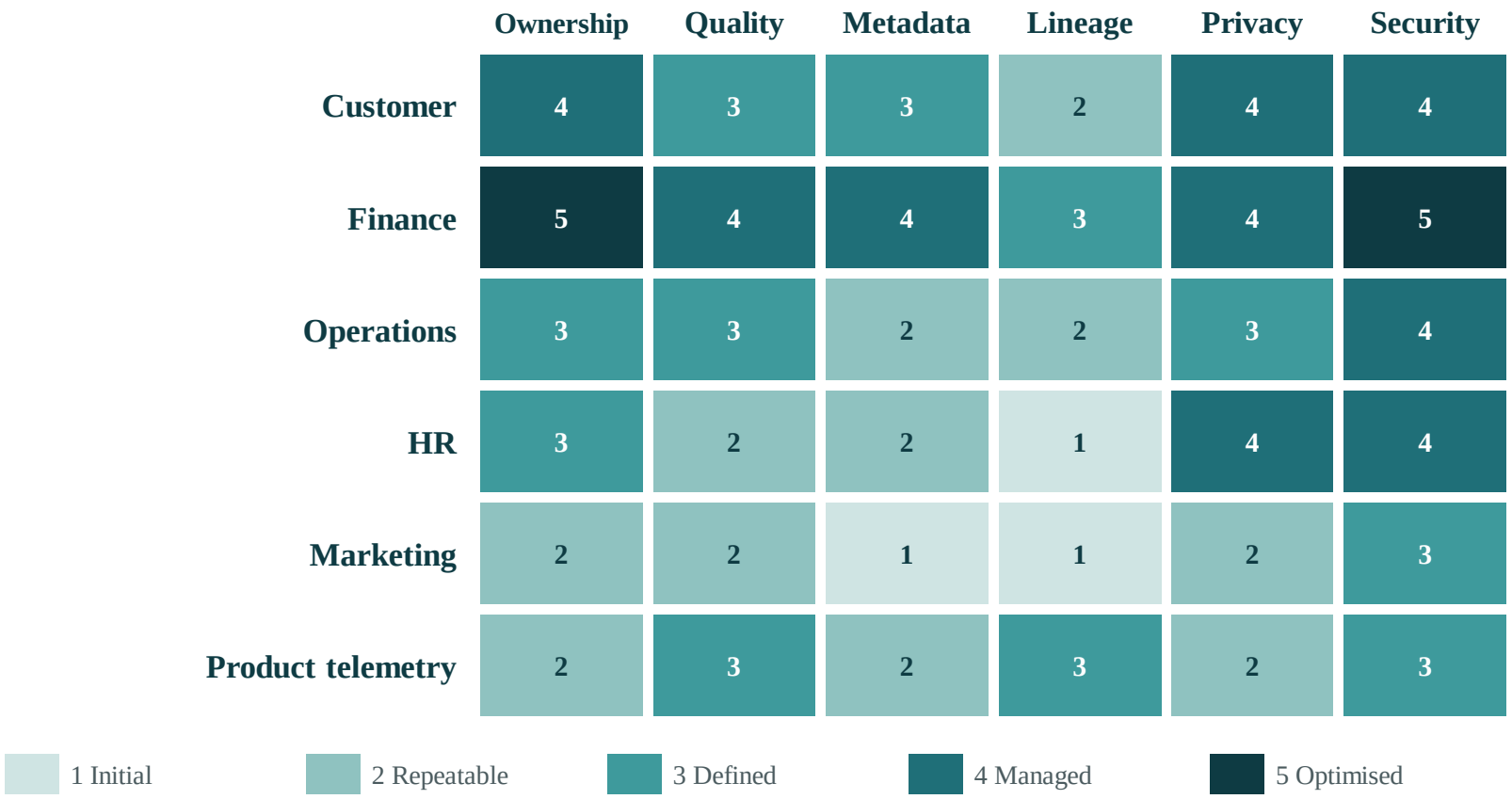
Dispose

Delete verifiably

Deletion certificates; consider whether trained models must also be retrained.

ILLUSTRATIVE DATA

Data governance maturity across domains



READING THE HEATMAP

Lineage is the weakest link

Most domains score highest on security and lowest on lineage. For AI this is the wrong way round: models cannot be audited without knowing where their inputs came from.

Section 4 synthesis

> *Every AI decision is only as defensible as the data beneath it. Quality, lineage and lawful basis are not data management chores; they are the evidence base for every automated judgement.*

Synthesis of Section 4

01

Own every dataset

Named owners and stewards make quality and lawful use someone’s job.

02

Trace everything

Lineage from source to decision is the precondition for audit and redress.

03

Encode the rules

Contracts and computational policies scale governance with the platform.

SECTION

05

AI Governance Architecture: From Principles to Practice

Building the structures, roles, registers and gates that turn values into controls.

IN THIS SECTION

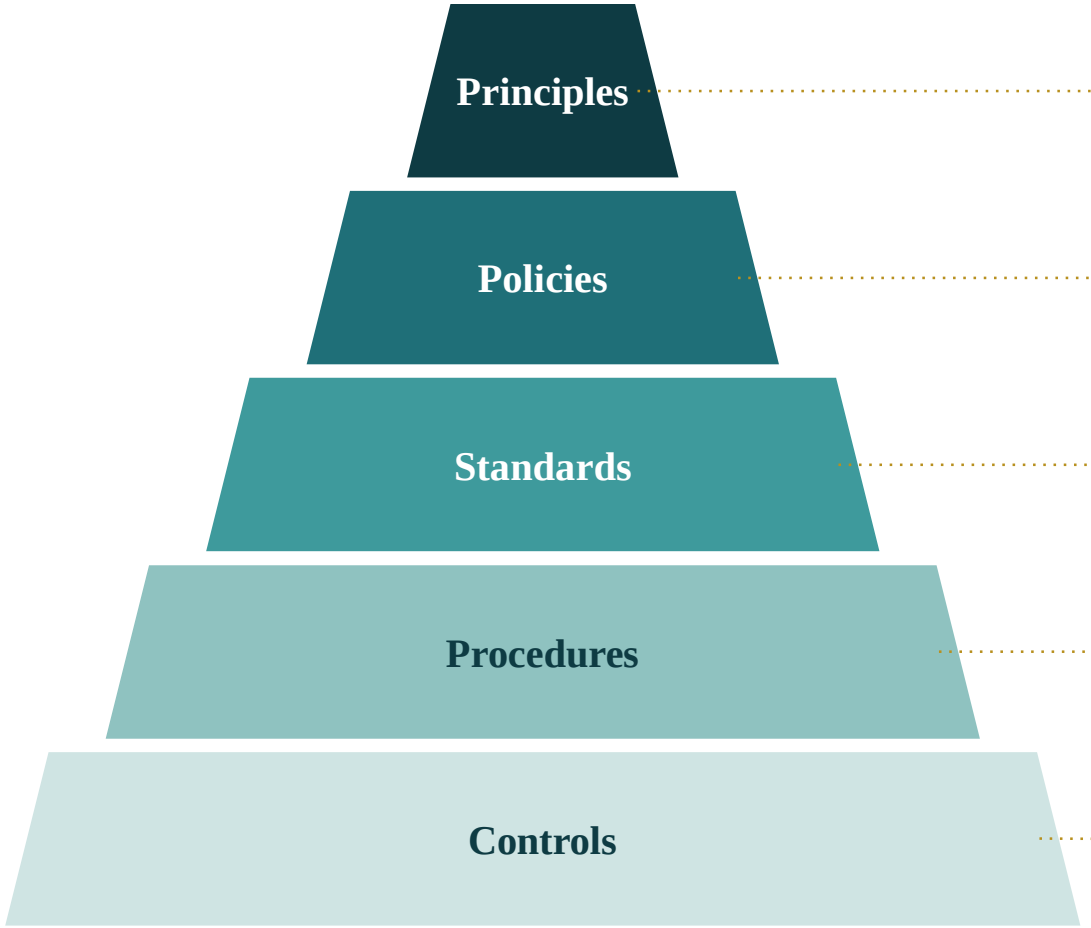
- Principles to controls
- Roles and committees
- Stage gates and documentation
- Operating model and three lines
- AI inventory and risk tiering
- Vendors and AI literacy

Slides 84 to 101



The translation gap: from principles to controls

Most organisations have principles. Few have the lower layers that make principles bite on daily decisions.



Principles

Values such as fairness, transparency and accountability. Necessary, but too abstract to guide a threshold choice.

Policies

Board approved commitments: prohibited uses, risk appetite, accountability for AI decisions.

Standards

Measurable requirements: documentation templates, fairness tests, validation depth by risk tier.

Procedures

Step by step workflows: intake, impact assessment, approval, monitoring, incident handling.

Controls and evidence

Automated checks, sign offs and logs that prove the procedure ran. This is what auditors test.

Convergence of AI principles across major frameworks

	OECD 2019 and 2024	UNESCO 2021	UK white paper 2023	EU AI Act	NIST AI RMF
Fairness and non discrimination	Explicit	Explicit	Explicit	Explicit	Explicit
Transparency and explainability	Explicit	Explicit	Explicit	Explicit	Explicit
Safety, security and robustness	Explicit	Explicit	Explicit	Explicit	Explicit
Accountability	Explicit	Explicit	Explicit	Explicit	Explicit
Human oversight and agency	Explicit	Explicit	Partial	Explicit	Partial
Privacy and data governance	Explicit	Explicit	Partial	Explicit	Explicit
Contestability and redress	Partial	Partial	Explicit	Partial	Partial
Sustainability	Explicit	Explicit		Partial	Partial

Explicit principle | Addressed in part | Not a headline theme

CONVERGENCE

A stable common core

Five themes appear in every framework. The divergence lies in contestability and sustainability, and above all in enforcement: only the EU AI Act is binding.

The AI governance operating model

Board	Approves AI strategy and risk appetite	Receives assurance reports	Holds executives to account
Executive AI council	Approves high risk use cases	Owns AI policy and standards	Resolves escalations and trade offs
AI governance office	Maintains AI inventory	Runs intake and triage	Coordinates assessments and reporting
Product and data teams	Build and operate systems	Produce documentation	Monitor and report incidents
Independent assurance	Model validation	Internal audit of AI controls	External certification such as ISO/IEC 42001

The three lines model applied to AI

The Institute of Internal Auditors' 2020 model separates ownership, oversight and independent assurance.

1 First line: own and manage

Product owners, data scientists and engineers who build and run AI systems. They own the risks, perform first level testing and maintain documentation and monitoring.

2 Second line: oversee and challenge

Model risk, compliance, privacy and AI ethics functions. They set standards, review high risk use cases, challenge assumptions and aggregate risk reporting.

3 Third line: independent assurance

Internal audit reports to the board audit committee on whether AI governance and controls are designed and operating effectively.

Key AI governance roles and accountabilities

Role	Core accountabilities	Typical reporting line
Chief AI Officer	AI strategy, portfolio prioritisation, governance programme, regulator engagement	Chief executive or chief operating officer
Model owner	Business accountability for a model’s purpose, performance, risks and decisions	Business line leadership
Model developer	Design, build, document and test the model to standards	Data science or engineering lead
Model validator	Independent review of conceptual soundness, performance and limitations	Second line model risk
AI ethics lead	Impact assessments, stakeholder engagement, ethical review of high risk uses	Second line or governance office
Data protection officer	DPIAs, lawful basis, rights requests, regulator liaison	Independent, reporting to highest management
Internal audit	Independent assurance over AI governance and controls	Board audit committee

An AI governance committee charter: essential elements

- **Mandate** Written scope covering built, bought and embedded AI.
- **Authority** Power to approve, condition, pause or reject use cases.
- **Membership** Business, technology, risk, legal, privacy and ethics.
- **Independence** At least one member without delivery targets.
- **Quorum and voting** Clear rules, recorded dissent and conflict declarations.
- **Thresholds** Which risk tiers must come to committee.
- **Evidence** Required artefacts listed per decision type.
- **Cadence** Scheduled meetings plus urgent incident sessions.
- **Escalation** Route to the executive and board for unresolved issues.
- **Reporting** Periodic reports on portfolio risk to the board.

ANTI PATTERN

Committee as ritual

A committee that reviews slide decks without evidence, has no veto and meets after launch provides comfort, not control.

The AI inventory: minimum register fields

Field group	Fields	Why it is needed
Identity	System name, version, unique identifier, status, date of last review	Basic traceability across the lifecycle
Purpose	Intended purpose, decision supported, prohibited uses, affected populations	Drives risk classification and legal duties
Role	Provider, deployer, importer or distributor; vendor details	Determines which EU AI Act obligations apply
Risk	Risk tier, EU AI Act category, last impact assessment, open issues	Prioritises oversight and assurance
Data	Training and input data sources, sensitivity, lawful basis	Links to data governance and DPIAs
People	Model owner, developer, validator, oversight personnel	Clear accountability and contact points
Controls	Monitoring in place, human oversight design, last validation result	Evidence for audit and regulators

Risk tiering of AI use cases

	Impact on individuals	Degree of autonomy	Scale	Vulnerable groups	Reversibility	Overall tier
Marketing copy assistant	Low	Medium	High	Low	Low	Low
Internal document search	Low	Medium	High	Low	Low	Low
Demand forecasting	Medium	High	Critical	Low	Medium	Medium
Customer service chatbot	Medium	High	Critical	Medium	Medium	Medium
Fraud detection	High	Critical	Critical	Medium	High	High
CV screening	Critical	High	High	High	Critical	Critical
Credit decisioning	Critical	Critical	Critical	High	High	Critical
Clinical triage support	Critical	Medium	High	Critical	Critical	Critical

Low Medium High Critical

TIERING RULE

Highest factor sets the floor

Use the most severe factor as a floor, then adjust with mitigations. CV screening and credit decisioning are also Annex III high risk under the EU AI Act.

Use case intake and triage workflow

01 Register	02 Screen	03 Tier	04 Assess	05 Decide	06 Track
Owner submits a short intake form: purpose, data, users, affected people and vendor details.	Governance office checks prohibited uses, legal role and EU AI Act category within days.	Assign low, medium, high or critical tier using the scoring rubric.	Proportionate assessment: checklist for low risk, full impact assessment for high risk.	Approve, approve with conditions, or reject, at the level set by the tier.	Enter in the inventory with review date, conditions and monitoring plan.



Proportionality A fast lane for low risk uses keeps the process credible and frees capacity for the cases that matter.

Stage gates across the AI lifecycle

Gate 0

Idea

Intake registered; prohibited use screen passed; owner named.

Gate 1

Design

Framing review, impact screening, data availability and lawful basis confirmed.

Gate 2

Build

Data quality checks, documented features, experiment tracking in place.

Gate 3

Validate

Independent validation, fairness and robustness tests, oversight design agreed.

Gate 4

Release

Approval at tier level; monitoring live; user notices and rollback ready.

Gate 5

Review

Periodic revalidation; retire or renew based on evidence.

The AI policy stack

AI policy	Scope and definitions	Principles and prohibited uses	Roles and accountability	
Standards	Risk tiering	Documentation	Testing and validation	Monitoring
Specialist policies	Generative AI acceptable use	Third party AI	AI in employment	
Guidance and templates	Model card template	Impact assessment	Fairness test playbook	Incident runbook

Documentation artefacts that evidence decisions

Model card

Mitchell et al. (2019): intended use, performance across groups, limitations and ethical considerations.

Datasheet for datasets

Gebru et al.: motivation, composition, collection process, labelling, uses and maintenance of a dataset.

System card

Describes how models, prompts, tools and safeguards combine into a deployed product.

Impact assessment

DPIA under UK GDPR Article 35; fundamental rights impact assessment under EU AI Act Article 27.

Validation report

Independent assessment of soundness, performance, limitations and conditions of use.

Technical documentation

EU AI Act Article 11 and Annex IV: the full design, data, testing and risk file for high risk systems.

Anatomy of a good model card



WRITE FOR THE DECISION MAKER

A model card should let a non specialist decide whether this model is appropriate for their decision, and tell a specialist where it is likely to fail. If it only describes architecture, it has missed its purpose.

1. **Intended use**
   Primary uses, intended users, and explicitly out of scope uses.

2. **Performance**
   Metrics on realistic test data, disaggregated by relevant groups, with confidence intervals.

3. **Data**
   Training and evaluation data summaries, known gaps and preprocessing.

4. **Limitations and risks**
   Known failure modes, sensitivity to drift, ethical considerations and required oversight.

Governing third party and vendor AI

- ☑ Include vendor AI in the inventory, including features embedded in existing software.
- ☑ Require model and system documentation proportionate to risk.
- ☑ Obtain evidence of testing for bias, robustness and security.
- ☑ Clarify whether your data will be used to train vendor models.
- ☑ Agree incident notification timelines and cooperation duties.
- ☑ Secure audit and information rights in the contract.
- ☑ Confirm EU AI Act role and conformity status where relevant.
- ☑ Plan exit: data return, model retirement and continuity.

ACCOUNTABILITY

Outsourcing does not transfer duty

Under the EU AI Act, deployers of high risk systems keep their own obligations, including oversight, monitoring and informing affected workers.

AI literacy remains a legal governance control

EU AI ACT ARTICLE 4

Article 4 has applied since 2 February 2025. As amended by the Digital Omnibus (Regulation (EU) 2026/1744) from 27 July 2026, providers and deployers must take measures that support the development of AI literacy among relevant staff, without having to guarantee any specific level. The duty is softer, but literacy remains a control regulators expect to see.

1. **Board and executives**
   Strategic risks, accountability, regulatory exposure and how to challenge AI proposals.

2. **Operators and reviewers**
   System limitations, automation bias, when and how to override, and escalation routes.

3. **Builders**
   Fairness testing, documentation, privacy engineering, security and regulatory requirements.

4. **All staff**
   Acceptable use of generative AI, data handling and recognising AI generated content.

Centralised and federated AI governance

Centralised

- **Strengths:** Consistent standards, concentrated expertise, clear regulator interface.
- **Weaknesses:** Bottlenecks, distance from domain context, perceived as policing.
- **Best when:** Early maturity, small portfolio, highly regulated sector.

VS

Federated

- **Strengths:** Scales with adoption, close to context, shared ownership of risk.
- **Weaknesses:** Inconsistent rigour, duplicated effort, weaker aggregate view.
- **Best when:** Large portfolio, mature domains, strong shared tooling and standards.

Recommended path Start centralised to set standards and build skills, then federate execution while keeping a central inventory, risk tiering and assurance.

Section 5 synthesis

> *Principles are where AI governance begins, not where it ends. Value is created only when principles are translated into roles with authority, registers with evidence and gates that can say no.*

Synthesis of Section 5

01

Build the lower layers

Standards, procedures and controls make principles testable.

02

Know your portfolio

An inventory with risk tiers is the foundation of every other control.

03

Gates with teeth

Approvals must rest on evidence and include the power to pause or reject.

SECTION

06

The Regulatory and Standards Landscape

The EU AI Act as amended in 2026, UK data reform, US developments and the international standards that connect them.

IN THIS SECTION

- Global overview
- Digital Omnibus changes
- NIST AI RMF
- EU AI Act architecture
- UK principles and DUAA 2025
- ISO/IEC 42001 and crosswalks

Slides 102 to 122



The global landscape at a glance (November 2026)

Jurisdiction	Key instruments	Approach	Status
European Union	AI Act (2024/1689) amended by Digital Omnibus (2026/1744); GDPR	Horizontal, risk based, binding	Prohibitions and GPAI rules apply; high risk from Dec 2027 and Aug 2028
United Kingdom	Five cross sector principles; UK GDPR as amended by DUAA 2025	Principles applied by existing regulators	No horizontal AI statute enacted; DUAA ADM reforms in force since 5 Feb 2026
United States	NIST AI RMF; sector regulators; state statutes	Voluntary federal frameworks; state level law	Federal deregulatory stance; state laws evolving and contested
International	OECD Principles; Council of Europe Framework Convention; G7 Hiroshima Code	Soft law and treaty	CoE Convention open for signature since Sept 2024
Standards	ISO/IEC 42001, 23894, 42005, 5259 series; IEEE 7000 series	Voluntary, certifiable	Used to evidence conformity and maturity

Three regulatory philosophies

Flexible principles **Prescriptive rules**



PRINCIPLES

Outcome based

Regulators interpret broad principles in context. UK model. Agile, but less certain for firms.

RISK BASED

Tiered obligations

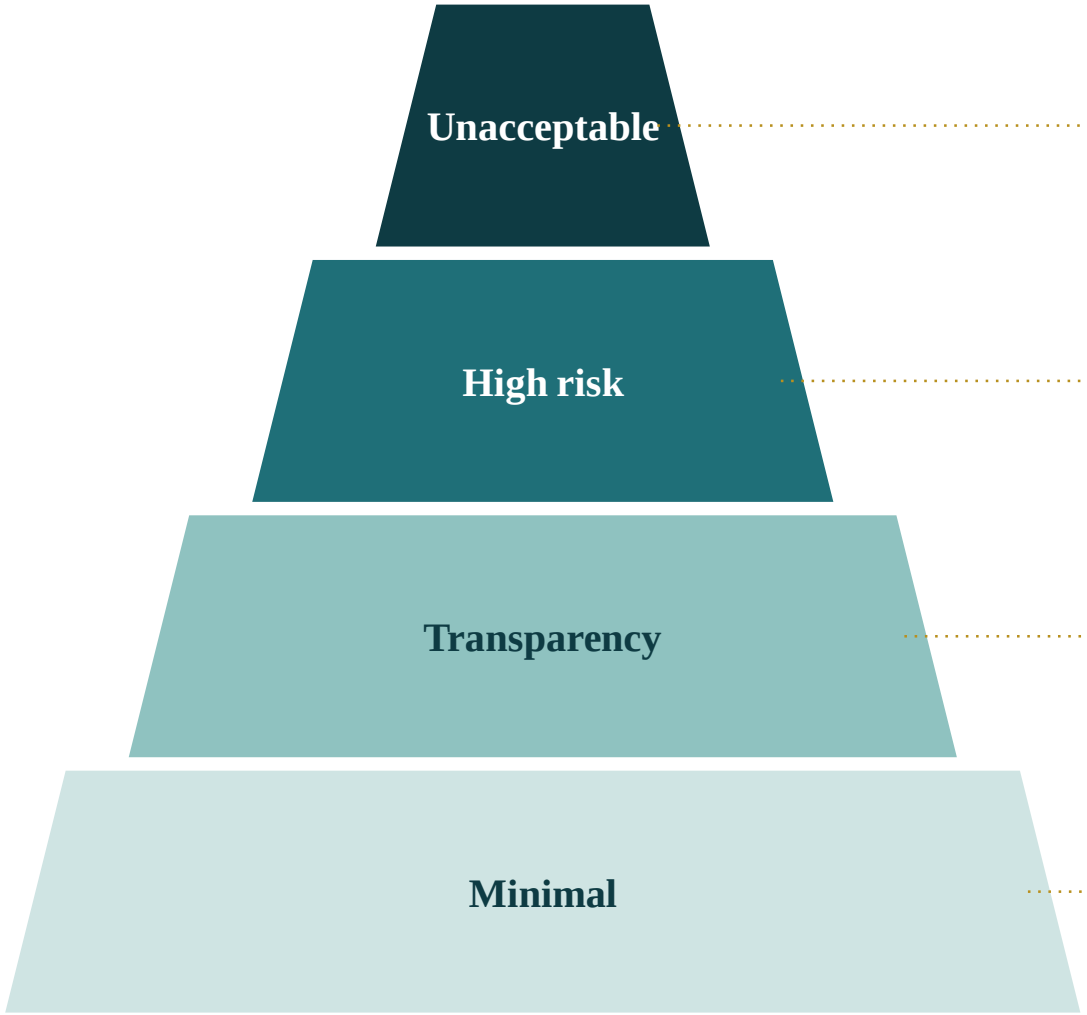
Duties scale with risk category. EU AI Act model. Proportionate, but classification disputes arise.

RULES

Specific requirements

Detailed prescriptions for defined uses, such as some US state laws on hiring tools. Clear, but quickly dated.

EU AI Act: a risk based architecture



Prohibited practices (Article 5)

Banned outright since 2 February 2025, with a new ban on generating intimate abuse imagery from 2 December 2026.

High risk systems (Article 6, Annexes I and III)

Strict requirements on risk management, data, documentation, oversight and conformity assessment.

Transparency risk (Article 50)

Disclosure duties for chatbots, synthetic content, emotion recognition and deepfakes from 2 August 2026.

Minimal risk

No specific obligations beyond AI literacy measures; voluntary codes of conduct encouraged.

Prohibited AI practices under Article 5

Manipulation

Subliminal, manipulative or deceptive techniques that materially distort behaviour and cause significant harm.

Exploiting vulnerability

Exploiting age, disability or social and economic situation to distort behaviour harmfully.

Social scoring

Evaluating people over time by social behaviour or traits, leading to unjustified detrimental treatment.

Predictive policing

Assessing the risk of a person committing a crime based solely on profiling or personality traits.

Facial image scraping

Untargeted scraping of facial images from the internet or CCTV to build recognition databases.

Emotion recognition

Inferring emotions in the workplace or education, except for medical or safety reasons.

Biometric categorisation

Inferring race, political opinions, religion or sexual orientation from biometric data.

Real time remote biometric ID

In public spaces for law enforcement, save narrow, authorised exceptions.

New from Dec 2026

Systems generating non consensual intimate imagery or child sexual abuse material, added by the Omnibus.

High risk areas listed in Annex III

Systems intended for these uses are high risk unless they pose no significant risk, for example by performing a narrow procedural task.

Biometrics

Remote identification, categorisation and emotion recognition where permitted.

Critical infrastructure

Safety components in energy, water, gas, heating and traffic.

Education

Admission, assessment, steering learning and proctoring.

Employment

Recruitment, screening, promotion, termination and monitoring.

Essential services

Benefits eligibility, credit scoring, life and health insurance pricing, emergency triage.

Law enforcement

Risk assessment, evidence reliability, profiling in investigations.

Migration and borders

Risk assessment, application examination, identification.

Justice and democracy

Assisting judicial decisions; influencing elections and voting.

Provider obligations for high risk systems

Article	Requirement	What it demands in practice
9	Risk management system	Continuous, iterative identification, evaluation and mitigation of risks across the lifecycle
10	Data and data governance	Training, validation and test data relevant, representative, examined for bias, with documented preparation
11	Technical documentation	Annex IV file demonstrating compliance, kept up to date and available to authorities
12	Record keeping	Automatic logging of events enabling traceability of system functioning
13	Transparency to deployers	Instructions for use: capabilities, limitations, accuracy, oversight measures
14	Human oversight	Designed so natural persons can understand, monitor, override and stop the system
15	Accuracy, robustness, cybersecurity	Declared accuracy levels; resilience to errors and attacks such as data poisoning
17, 43, 72	QMS, conformity, monitoring	Quality management system, conformity assessment, CE marking, post market monitoring

Deployer obligations and the fundamental rights impact assessment

- **Use as instructed** Follow the provider's instructions for use.
- **Keep logs** Retain logs for at least six months.
- **Competent oversight** Assign trained people with authority.
- **Inform workers** Tell worker representatives before workplace use.
- **Input data** Ensure inputs are relevant and representative.
- **Inform people** Tell affected people a high risk system is used.
- **Monitor** Watch operation and report serious incidents.
- **Explain** Article 86 right to an explanation of decisions.

ARTICLE 27

Who must do a FRIA

Public bodies, private entities providing public services, and deployers using AI for creditworthiness or life and health insurance pricing, before first use of a high risk system.

General purpose AI models and systemic risk

ARTICLES 51 TO 55

GPAI obligations have applied since 2 August 2025, with Commission enforcement powers from 2 August 2026. Models trained with more than 10 to the power of 25 floating point operations are presumed to pose systemic risk and carry additional duties.

1. **All GPAI providers**
   Technical documentation, information for downstream providers, a copyright policy and a public summary of training content.

2. **Systemic risk models**
   State of the art evaluations, adversarial testing, serious incident reporting and adequate cybersecurity.

3. **Code of Practice**
   Published July 2025 as a voluntary route to demonstrate compliance with these obligations.

4. **Legacy models**
   Models placed on the market before 2 August 2025 have until 2 August 2027 to comply.

EU AI Act timeline after the Digital Omnibus

1 Aug 2024

Entry into force

Regulation (EU) 2024/1689 published and in force.

2 Feb 2025

Prohibitions

Article 5 bans and AI literacy provisions apply.

2 Aug 2025

GPAI and governance

GPAI duties, AI Office, penalties regime apply.

27 Jul 2026

Omnibus in force

Regulation (EU) 2026/1744 amends the Act.

2 Aug 2026

Transparency

Article 50 duties apply; GPAI enforcement begins.

2 Dec 2026

Marking and new ban

Grace period for marking legacy synthetic content ends; new Article 5 ban applies.

2 Dec 2027

Annex III high risk

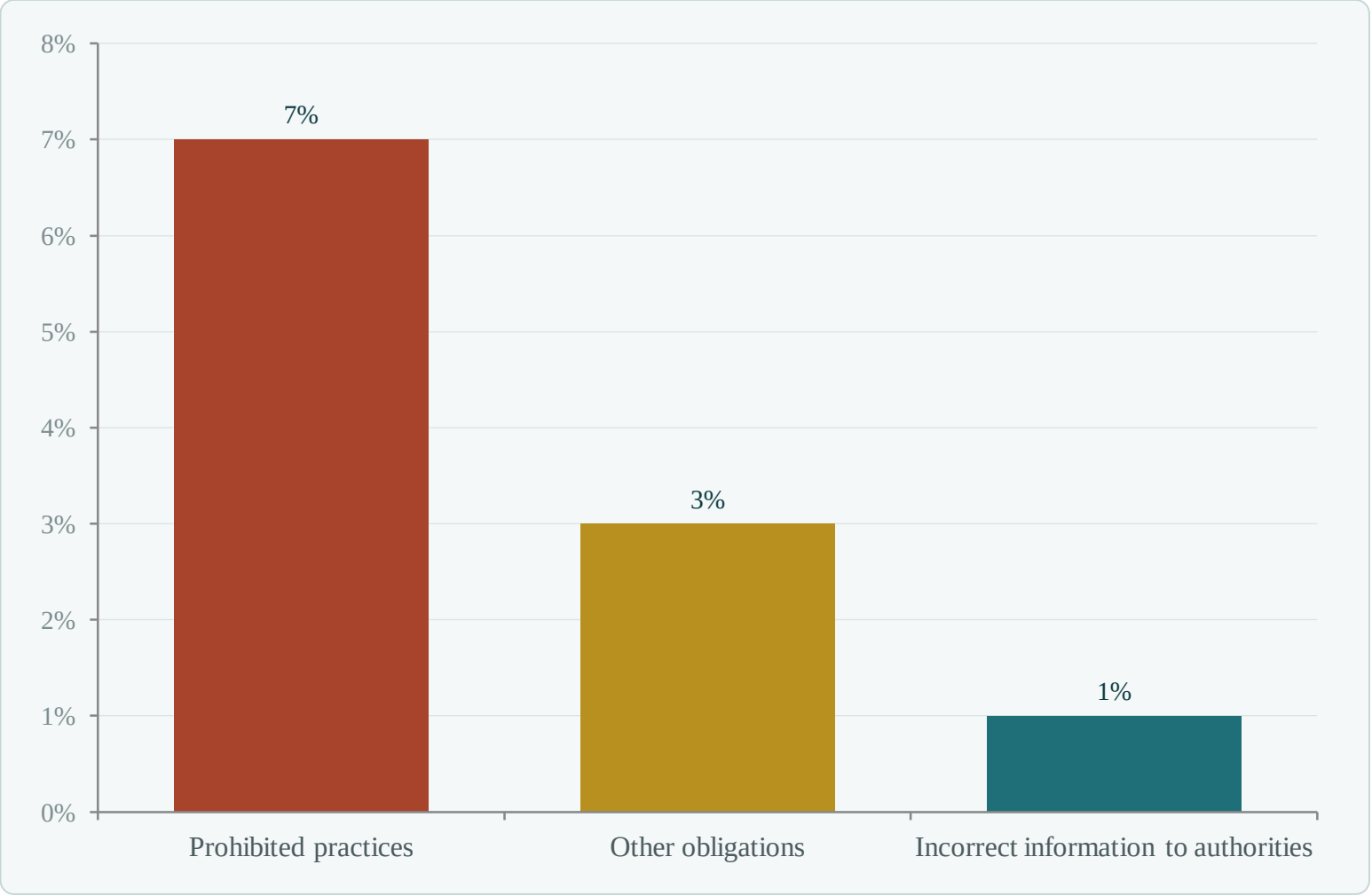
Stand alone high risk obligations apply.

2 Aug 2028

Annex I high risk

High risk AI in regulated products.

Penalty tiers under Article 99



EUR 35m

Top tier

Or 7% of worldwide annual turnover, whichever is higher, for prohibited practices.

EUR 15m

Middle tier

Or 3% for breaches of most other obligations, including high risk and transparency duties.

EUR 7.5m

Information tier

Or 1% for supplying incorrect, incomplete or misleading information. For SMEs the lower amount applies.

What the Digital Omnibus on AI changed

Regulation (EU) 2026/1744 simplified and deferred, but did not dismantle, the AI Act.

Deferred or softened

- **Annex III high risk:** From 2 August 2026 to 2 December 2027.
- **Annex I high risk:** From 2 August 2027 to 2 August 2028.
- **AI literacy:** Duty to support literacy, not guarantee a level.
- **Sandboxes:** National sandbox deadline moved to 2 August 2027.

VS

Retained or strengthened

- **Transparency:** Article 50 still applies from 2 August 2026.
- **New prohibition:** Intimate image and child abuse generators banned.
- **Registration:** Database registration kept for self exempted systems.
- **AI Office:** Stronger direct supervision of GPAI based systems.

Implication The delay buys time to build capability, not permission to wait. Design decisions made now will be judged against the high risk requirements in 2027.

The UK approach: five cross sector principles

Set out in the 2023 white paper and applied by existing regulators such as the ICO, FCA, CMA, Ofcom and MHRA.

1 Safety, security and robustness

AI should function securely and as intended, with risks identified and managed throughout the lifecycle.

2 Transparency and explainability

Appropriate information about AI use and how it reaches outcomes, proportionate to risk.

3 Fairness

AI should not undermine legal rights, discriminate unfairly or create unfair market outcomes.

4 Accountability and governance

Clear lines of accountability and effective oversight of AI supply and use.

5 Contestability and redress

Routes to contest harmful AI decisions or outcomes, where appropriate.

Status in late 2026

No horizontal AI statute has been enacted. The AI Security Institute leads frontier model evaluation.

UK DUAA 2025: the new automated decision making regime

Royal Assent 19 June 2025; the reformed rules (new Articles 22A to 22D UK GDPR) commenced on 5 February 2026.

01 Wider permission	02 Special category limit	03 Inform	04 Represent and contest	05 Human intervention
Solely automated significant decisions are permitted on more lawful bases, including legitimate interests.	Tighter conditions remain where special category data is involved.	Individuals must be told about significant decisions taken about them.	They can make representations and challenge the decision.	They can obtain meaningful human intervention on the decision.

Shift From a general prohibition with exceptions to a general permission with safeguards. The safeguards become the governance design brief.

Automated decisions: EU GDPR and UK GDPR now diverge

EU GDPR Article 22

- **Default:** Right not to be subject to solely automated decisions with legal or similar effects.
- **Exceptions:** Contract necessity, authorisation by law, or explicit consent.
- **Safeguards:** Human intervention, expressing a view, contesting the decision.
- **Plus:** AI Act Article 86 explanation right for high risk systems.

VS

UK GDPR after DUAA 2025

- **Default:** Permitted on any lawful basis, subject to safeguards.
- **Restrictions:** Stricter where special category data is processed.
- **Safeguards:** Information, representations, challenge and human intervention.
- **Plus:** ICO guidance on ADM and profiling being updated.

For UK firms serving EU customers Design to the stricter EU baseline where processing touches the EU, and document which regime applies to each decision flow.

The United States: a layered, shifting picture

Federal policy

Executive Order 14110 was revoked in January 2025. Federal policy now emphasises AI adoption and competitiveness, and has sought to limit divergent state regulation, with limited effect so far.

NIST frameworks

The AI Risk Management Framework (January 2023) and its Generative AI Profile (July 2024) remain the de facto voluntary baseline for US organisations.

State legislation

Colorado enacted the first comprehensive state AI Act in 2024 and substantially revised it in 2026. Other states regulate specific uses such as hiring tools and deepfakes.

Sector regulators

Existing law still bites: consumer protection, fair lending, equal employment and health privacy rules apply to AI enabled decisions.

NIST AI Risk Management Framework: four functions



1 Govern

Policies, accountability, culture, workforce diversity and third party risk. Cross cutting and continuous.

2 Map

Establish context: intended purpose, users, impacts, assumptions and risk tolerance.

3 Measure

Assess trustworthiness characteristics with quantitative and qualitative methods, and track them.

4 Manage

Prioritise and respond to risks, allocate resources, plan for incidents and decommissioning.

ISO/IEC 42001: the AI management system standard

Published December 2023; certifiable, built on the Plan Do Check Act structure common to ISO management systems.

01 Context (4)	02 Leadership (5)	03 Planning (6)	04 Support and operation (7, 8)	05 Evaluation (9)	06 Improvement (10)
Organisation's role, interested parties, scope of the AI management system.	Top management commitment, AI policy, roles and responsibilities.	AI risk assessment, risk treatment, AI system impact assessment and objectives.	Resources, competence, documented information and operational controls.	Monitoring, internal audit and management review.	Nonconformity, corrective action and continual improvement.



Annex A Annex A lists reference controls covering policies, internal organisation, resources, impact assessment, lifecycle, data, information for interested parties, use and third parties.

The international standards ecosystem

Standard	Scope	Use in governance
ISO/IEC 22989:2022	AI concepts and terminology	Shared vocabulary for policies and contracts
ISO/IEC 23053:2022	Framework for AI systems using machine learning	Reference architecture for documentation
ISO/IEC 38507:2022	Governance implications of AI for organisations	Board level responsibilities and oversight
ISO/IEC 23894:2023	AI risk management guidance	Extends ISO 31000 to AI specific risks
ISO/IEC 42001:2023	AI management system requirements	Certifiable organisational framework
ISO/IEC 42005:2025	AI system impact assessment	Method for assessing impacts on people and society
ISO/IEC 5259 series	Data quality for analytics and machine learning	Measurable data quality requirements
ISO/IEC TR 24027:2021	Bias in AI systems and AI aided decision making	Bias sources, metrics and treatment

Crosswalk: how frameworks cover core requirements

	EU AI Act	UK principles and GDPR	NIST AI RMF	ISO/IEC 42001	OECD
Risk management process	Detailed	Light	Detailed	Detailed	Light
Data governance	Detailed	Detailed	Moderate	Moderate	Light
Technical documentation	Detailed	Light	Moderate	Detailed	
Human oversight	Detailed	Moderate	Moderate	Moderate	Moderate
Transparency to users	Detailed	Detailed	Moderate	Moderate	Moderate
Fairness and bias testing	Moderate	Moderate	Detailed	Moderate	Moderate
Post deployment monitoring	Detailed	Light	Detailed	Detailed	Light
Incident reporting	Detailed	Light	Moderate	Moderate	Light
Third party management	Moderate	Light	Detailed	Detailed	Light

Detailed or mandatory Moderate guidance Light touch Not addressed

PRACTICAL ADVICE

Build once, map many

Implement ISO/IEC 42001 as the management backbone, use NIST AI RMF for risk methods, and map evidence to EU AI Act articles. One control set can satisfy several frameworks.

Section 6 synthesis

> *The regulatory map is no longer blank. Its frameworks differ in force and detail, but they converge on the same expectations: know your systems, assess their risks, document your decisions, keep humans meaningfully in control and be ready to explain.*

Synthesis of Section 6

01

EU sets the high bar

Binding, risk tiered duties, now phased to 2027 and 2028.

02

UK diverges on ADM

Permission with safeguards since February 2026.

03

Standards connect them

ISO/IEC 42001 and NIST AI RMF provide a common control backbone.

SECTION

07

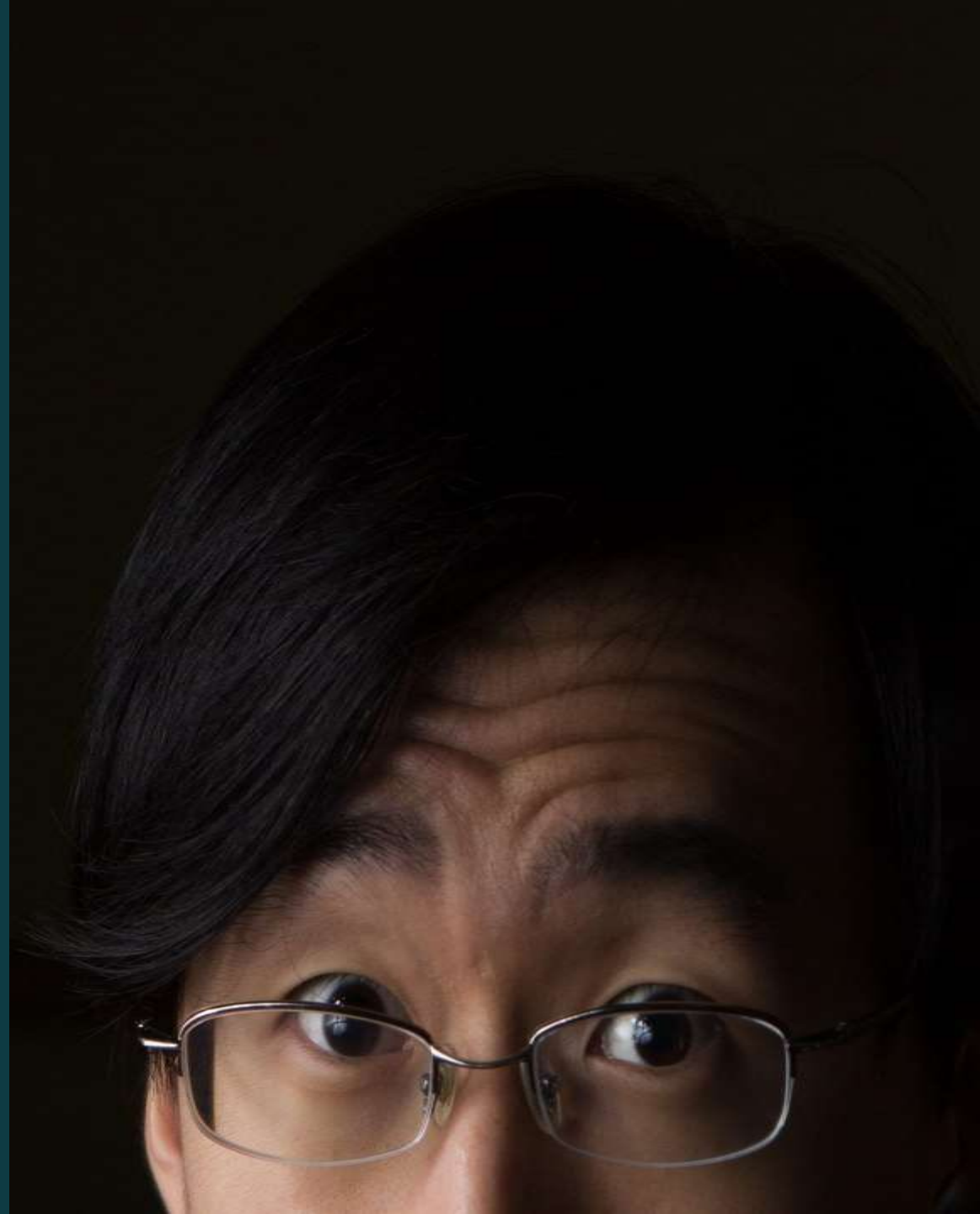
Risk Management and Assurance for AI Decisions

Identifying, measuring, controlling and evidencing the risks that AI decisions create.

IN THIS SECTION

- AI risk taxonomy
- Model risk management
- KRIs and drift
- Likelihood, impact and appetite
- Bow tie and controls
- Audit and assurance

Slides 123 to 140



A taxonomy of AI risk

Performance risk

Inaccurate, unstable or poorly calibrated outputs; degradation under drift; overfitting.

Fairness risk

Unjustified differences in outcomes or error rates across groups; proxy discrimination.

Privacy and data risk

Unlawful processing, re identification, memorisation and leakage of personal data.

Security risk

Data poisoning, adversarial examples, model extraction, prompt injection and supply chain attacks.

Legal and compliance risk

Breach of AI Act, data protection, equality, consumer or sector rules; contractual liability.

Operational and conduct risk

Misuse by staff, automation bias, poor customer outcomes, reputational damage.

Risk equals likelihood times impact

A standard 5 by 5 matrix; the product of the two scores sets priority and the escalation route.

	1 Negligible	2 Minor	3 Moderate	4 Major	5 Severe
5 Almost certain	Significant	High	Critical	Critical	Critical
4 Likely	Moderate	Significant	High	Critical	Critical
3 Possible	Moderate	Significant	Significant	High	Critical
2 Unlikely	Low	Moderate	Significant	Significant	High
1 Rare	Low	Low	Moderate	Moderate	Significant

Low Moderate Significant High Critical

AI SPECIFIC CAUTION

Impact needs a human lens

Rate impact from the perspective of the most affected person, not only the organisation. A minor cost to the firm can be a severe harm to an individual denied care or income.

Writing an AI risk appetite statement

FROM ASPIRATION TO THRESHOLD

A useful risk appetite statement is specific enough that a model owner can tell whether a proposed system is inside or outside it. Vague statements such as we take a cautious approach to AI do not guide decisions.

1. **Qualitative boundary**
   We will not deploy AI that makes solely automated decisions on access to essential services without human review.

2. **Quantitative limit**
   Disparity in false negative rates between protected groups must not exceed 1.25 times in production.

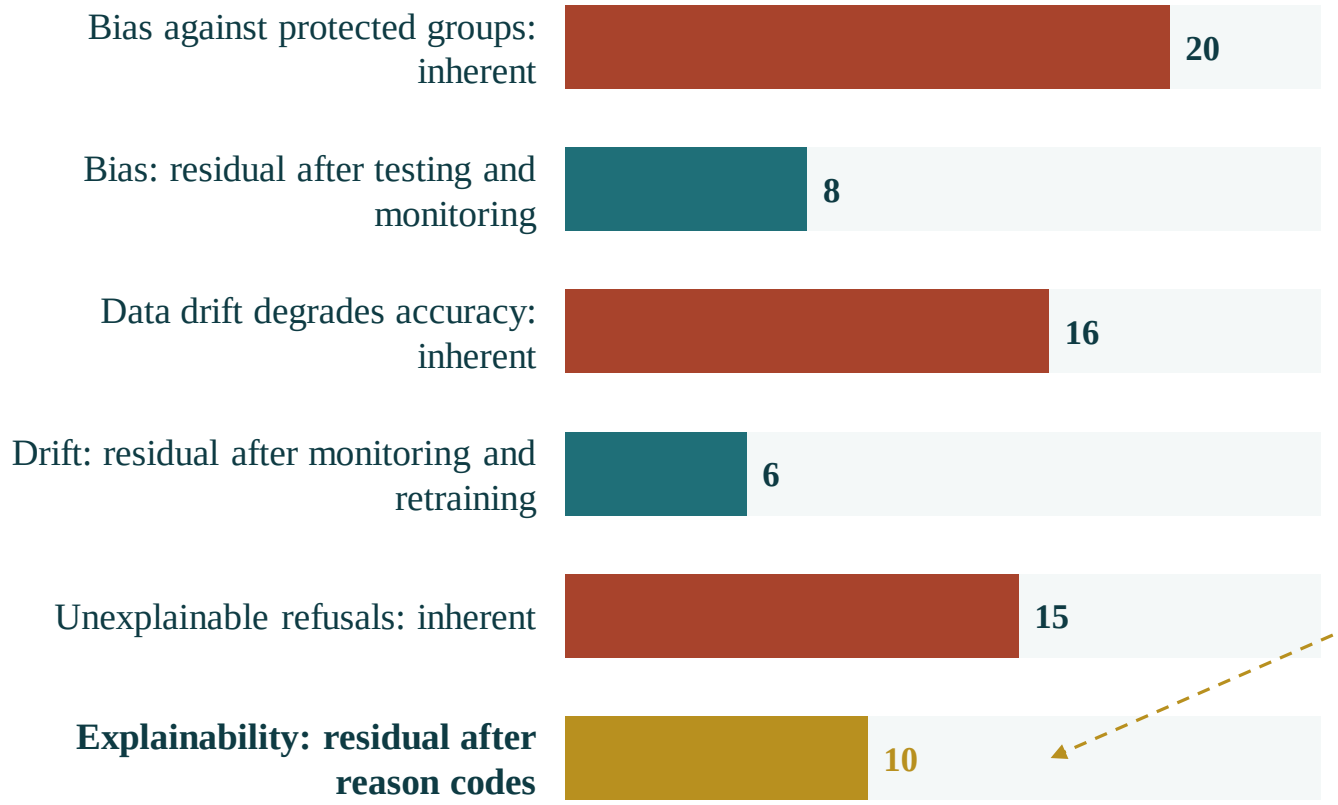
3. **Tolerance**
   Model performance may degrade by up to 5% from validated levels before mandatory review.

4. **Escalation**
   Any breach is reported to the AI council within five working days with a remediation plan.

ILLUSTRATIVE DATA

Inherent versus residual risk after controls

Risk score (likelihood × impact) for a credit decisioning model



1 Controls reduce, not remove

Every risk retains a residual that must sit within appetite and be formally accepted by the owner.

2 Weakest reduction

Explainability controls cut risk least. Reason codes explain the model, not whether the decision was fair. Consider simpler models.

Model risk management: US and UK supervisory anchors

Federal Reserve SR Letter 11 7 (2011)

- **Definition:** Model risk arises from fundamental errors and from incorrect or inappropriate use.
- **Pillars:** Sound development, effective validation, strong governance.
- **Signature idea:** Effective challenge by objective, informed parties.
- **Legacy:** Shaped model risk practice worldwide for over a decade.

VS

PRA SS1/23 (effective May 2024)

- **Scope:** UK banks with internal model approval, explicitly including AI and ML models.
- **Structure:** Five principles from identification to risk mitigants.
- **Signature idea:** Senior Manager accountable for the model risk framework.
- **Relevance:** A strong template for any sector governing AI decisions.

Transferable lesson Treat every material AI system as a model with an owner, an independent validator and a lifecycle, regardless of industry.

The five principles of PRA SS1/23

1 Identification and classification	Maintain a comprehensive model inventory and tier models by materiality and complexity.
2 Governance	Board approved model risk policy, clear roles and an accountable Senior Manager Function holder.
3 Development, implementation and use	Robust design, data quality, testing and documentation; appropriate use within limitations.
4 Independent validation	Objective review of conceptual soundness, outcomes analysis and ongoing performance monitoring.
5 Model risk mitigants	Use restrictions, overlays, post model adjustments and heightened monitoring where weaknesses exist.

What independent validation should cover

- **Conceptual soundness** Is the approach fit for the decision?
- **Outcomes analysis** Back testing against realised outcomes.
- **Data review** Quality, representativeness, leakage.
- **Subgroup analysis** Performance and error rates by group.
- **Replication** Can results be reproduced independently?
- **Sensitivity tests** Stability to input and assumption changes.
- **Benchmarking** Compare with simpler challenger models.
- **Limitations** Documented conditions of appropriate use.

INDEPENDENCE

Effective challenge

Validators need competence, independence from developers and the authority to require changes or block release.

Robustness and adversarial risk

Data poisoning

Manipulated training data implants errors or backdoors. Control: provenance checks and anomaly detection on training sets.

Evasion attacks

Small crafted input changes flip predictions. Control: adversarial testing and input validation.

Model extraction

Repeated queries reconstruct a proprietary model. Control: rate limits and output rounding.

Membership inference

Attackers infer whether a person was in the training data. Control: differential privacy and regularisation.

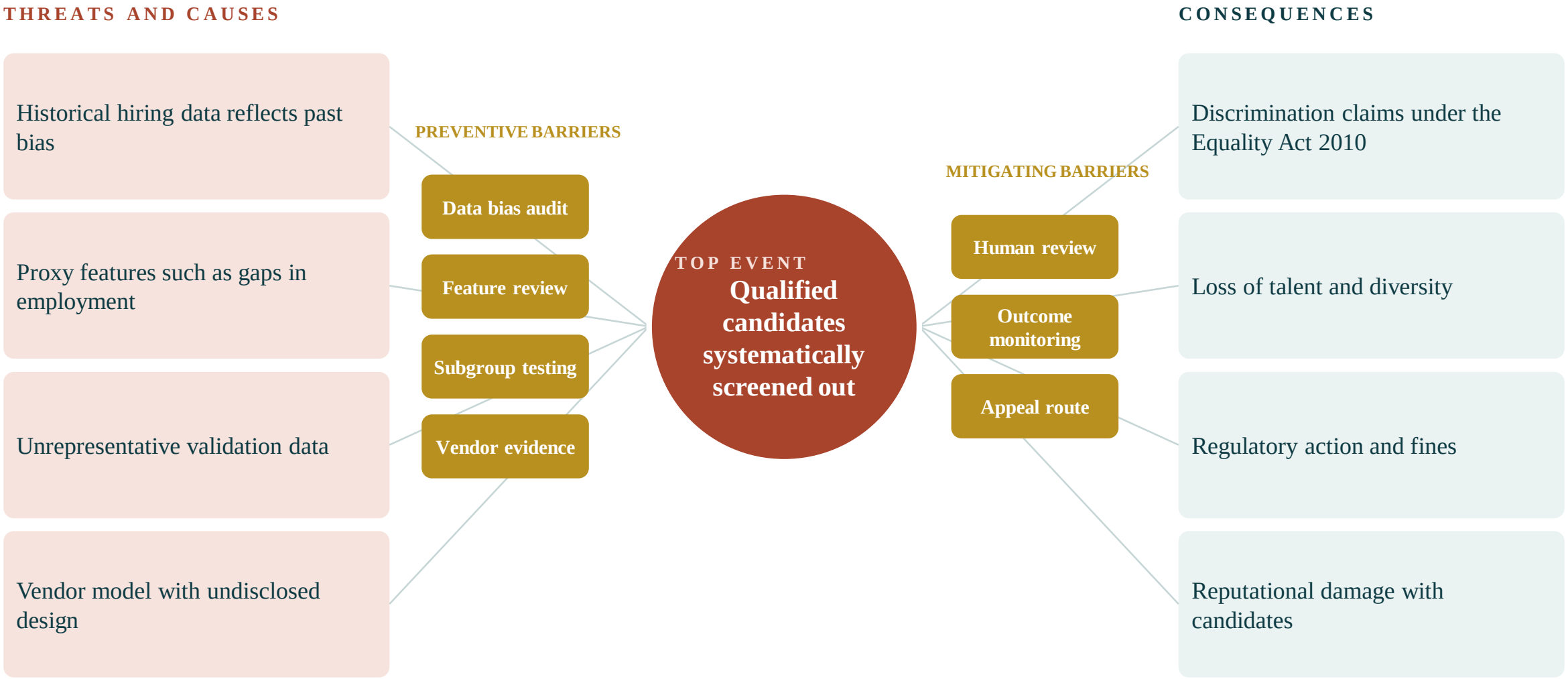
Distribution shift

Natural change in the population breaks assumptions. Control: drift monitoring and stress testing.

Supply chain

Compromised libraries, pretrained weights or datasets. Control: software bills of materials and signed artefacts.

Bow tie analysis: a biased hiring recommendation



An AI controls library by control type

Type	Purpose	Examples	Evidence produced
Preventive	Stop a risk event occurring	Prohibited use screen, data contracts, access controls, release gates	Approvals, test results
Detective	Identify events quickly	Drift monitors, fairness dashboards, anomaly alerts, complaint analysis	Alerts, monitoring logs
Corrective	Limit impact and restore	Rollback, kill switch, manual fallback, remediation of affected people	Incident records
Directive	Guide behaviour	Policies, standards, training, acceptable use rules	Attestations, training logs
Compensating	Offset a weak primary control	Extra human review where explainability is limited	Review samples

Key risk indicators for AI systems

Indicator	Measure	Amber	Red and action
Input drift	Population stability index per key feature	0.10 to 0.25	Above 0.25: investigate and revalidate
Performance decay	Change in AUC or error rate versus validation	3% drop	5% drop: review, recalibrate or retrain
Fairness gap	Ratio of group error rates	1.15	1.25: escalate to AI council
Override rate	Share of outputs changed by reviewers	Change of 50%	Doubling: review model and process
Complaints	AI related complaints per 10,000 decisions	Rising 3 months	Spike: root cause analysis
Documentation currency	Models past review date	5% of inventory	10%: freeze new releases

Measuring drift: the population stability index

$$PSI = \Sigma \text{ over bins } (a(i) \text{ minus } e(i)) \times \ln(a(i) / e(i))$$

e(i) Expected share of records in bin i, from the training or validation baseline.

a(i) Actual share of records in bin i in the current production window.

below 0.10 Conventional reading: no material shift in the distribution.

above 0.25 Conventional reading: significant shift; investigate and consider revalidation.

WORKED EXAMPLE

Two bins for applicant age.

Baseline: 60% under 40, 40% over 40.

Current: 45% under 40, 55% over 40.

Bin 1: (0.45 minus 0.60) × ln(0.45 / 0.60) = 0.043

Bin 2: (0.55 minus 0.40) × ln(0.55 / 0.40) = 0.048

PSI = 0.091: just below the 0.10 warning level, so record and watch.

AI incident management lifecycle

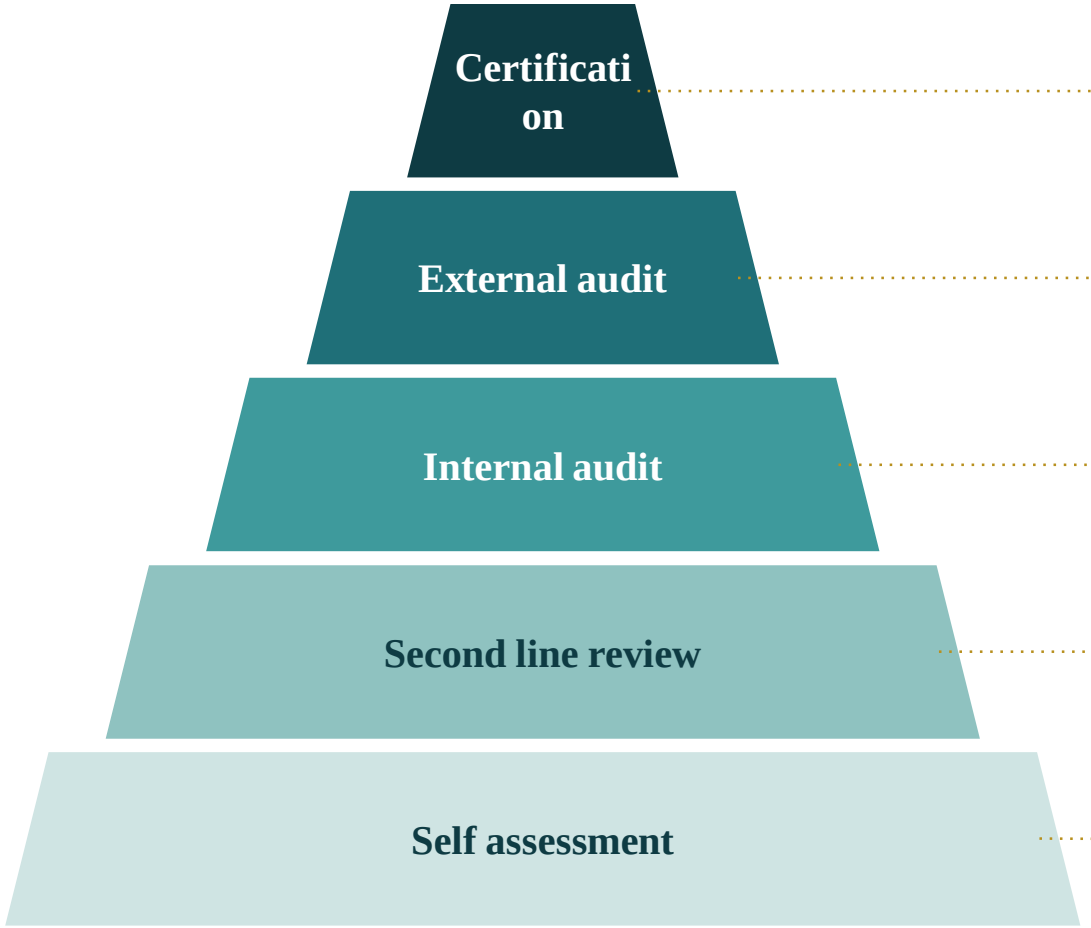
01 Detect	02 Triage	03 Contain	04 Notify	05 Remediate	06 Learn
Alert, complaint, audit finding or media report. Log immediately with time stamp.	Assess severity against criteria; decide whether to pause, restrict or continue.	Kill switch, rollback or manual fallback; preserve logs and evidence.	Internal escalation; regulator notification where required, such as serious incidents under Article 73.	Fix root cause; identify and make good to affected individuals.	Blameless review; update controls, training and the risk register.



Prepare in advance Define what counts as an AI incident, who can pull the kill switch and how fallback works before the system goes live.

Levels of assurance

Assurance depth should rise with the risk tier of the system.



External certification

Accredited audit against ISO/IEC 42001 or a conformity assessment by a notified body.

Independent external review

Third party algorithmic audit or limited assurance engagement on specific claims.

Third line assurance

Internal audit tests design and operating effectiveness of AI controls.

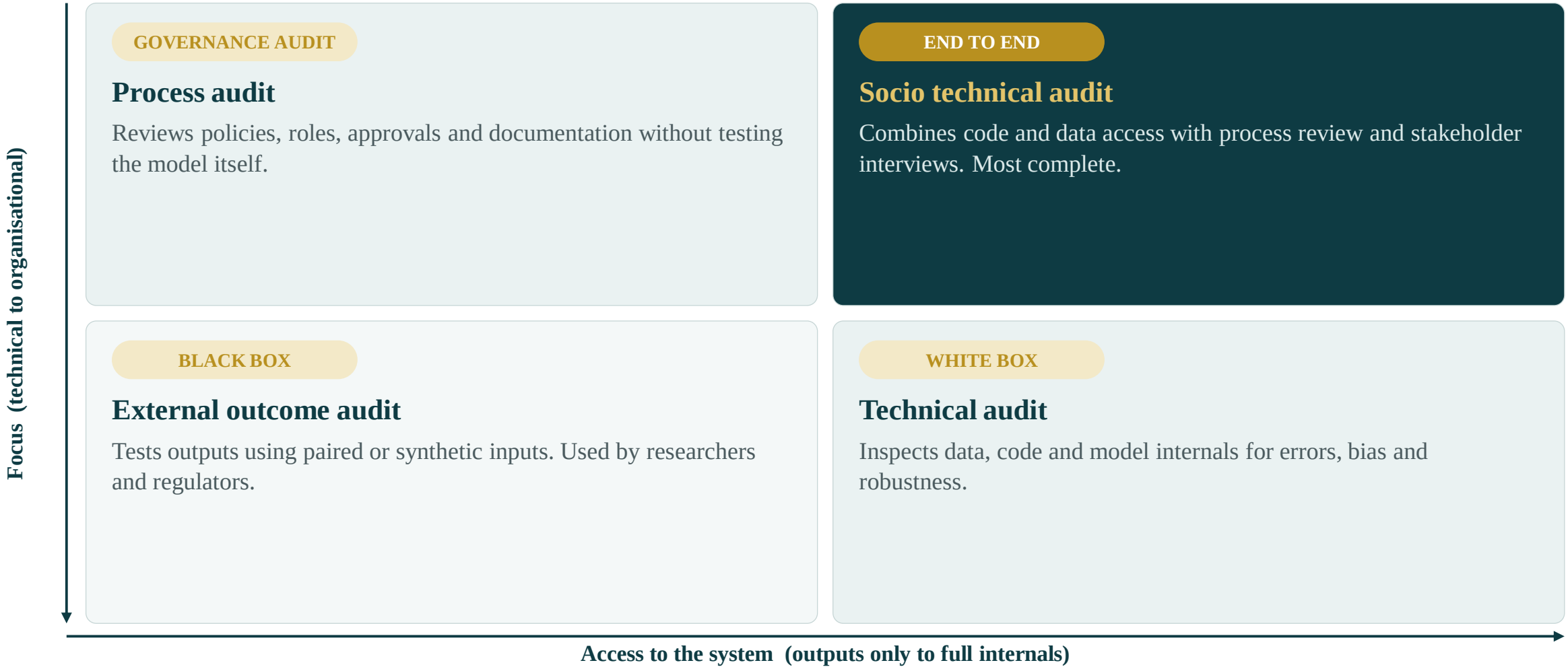
Second line challenge

Independent validation and risk review before and after release.

First line self assessment

Checklists and attestations by model owners; appropriate for low risk systems.

Approaches to algorithmic auditing



ILLUSTRATIVE DATA

Risk register excerpt: customer churn model

Risk	L	I	Key controls	Owner	Residual
Retention offers skew away from older customers	3	3	Subgroup uplift testing; offer policy review	Model owner	Moderate
Behavioural features drift after pricing change	4	3	Weekly PSI; retrain trigger at 0.25	MLOps lead	Moderate
Use of call transcripts lacks lawful basis	2	4	DPIA; legitimate interests assessment	DPO	Low
Staff over trust churn scores in negotiations	3	2	Training; interface shows uncertainty	Ops manager	Low
Vendor library vulnerability	2	3	Dependency scanning; signed builds	Platform lead	Low

Section 7 synthesis

> *Risk management turns uncertainty about AI into decisions about AI: which risks to accept, which to treat, who owns them and what evidence proves the controls work.*

Synthesis of Section 7

01

Appetite with numbers

Make risk appetite specific enough to say yes or no to a model.

02

Borrow from banking

Model risk management offers a proven template for any sector.

03

Assurance scales with risk

From self assessment to certification, in proportion to impact.

SECTION

08

Fairness, Bias and Equity in Automated Decisions

Where bias enters, how fairness is measured, why definitions conflict and how to decide between them.

IN THIS SECTION

- Sources of bias
- Worked example
- Mitigation strategies
- Group fairness metrics
- Impossibility results
- Choosing a definition

Slides 141 to 159



Six sources of bias across the lifecycle

Adapted from the framework of Suresh and Guttag (2021).

01 Historical	02 Representation	03 Measurement	04 Aggregation	05 Evaluation	06 Deployment
The world as recorded reflects past inequity, even with perfect measurement and sampling.	Some groups are under sampled, so the model learns less about them.	Features and labels are noisy or biased proxies, measured differently across groups.	One model for all groups ignores meaningful differences between them.	Benchmarks do not represent the deployment population or its subgroups.	The system is used for a purpose, or by people, it was not designed for.



Implication Removing a protected attribute from the features addresses none of these sources on its own. Each requires its own control.

Bias sources, examples and controls

Source	Example	Control
Historical	Hiring data reflecting a male dominated workforce	Question whether past decisions are a valid label; reweight or relabel
Representation	Skin lesion images mostly from lighter skin tones	Coverage analysis; targeted data collection; performance floors per group
Measurement	Arrests used as a proxy for offending	Validate the label against the construct of interest
Aggregation	One clinical threshold across groups with different baselines	Test for interaction effects; consider group aware calibration
Evaluation	Benchmark from one region used to approve national rollout	Representative test sets; disaggregated evaluation
Deployment	A risk score built for support used for sanctions	Intended use statements; usage monitoring; contractual limits

Group fairness metrics: definitions and meaning

Criterion	Condition (groups A and B)	Plain language meaning
Demographic parity	$P(\hat{Y} = 1 \mid A) = P(\hat{Y} = 1 \mid B)$	Both groups are selected at the same rate
Equal opportunity	$TPR(A) = TPR(B)$	Qualified people are equally likely to be selected in each group
Equalised odds	TPR and FPR equal across groups	Both errors occur at the same rates in each group
Predictive parity	$PPV(A) = PPV(B)$	A positive prediction is equally reliable for each group
Calibration within groups	$P(Y = 1 \mid \text{score } s, \text{group}) = s$	A given score means the same risk in each group
Individual fairness	Similar individuals receive similar outcomes	Requires a defensible similarity metric

Disparate impact ratio and the four fifths rule

$$DIR = \text{selection rate (protected group)} / \text{selection rate (reference group)}$$

DIR	Ratio of favourable outcome rates. 1.0 means parity.	***< 0.8***	Four fifths rule from US employment guidance: a common screening threshold for adverse impact.
Limits	A screening heuristic, not a legal test in the UK or EU, and silent on accuracy and error rates.	***Use***	Trigger deeper analysis and justification, not an automatic verdict.

FROM THE WORKED EXAMPLE

Group A selection rate: 310 of 1,000 = 31%

Group B selection rate: 190 of 1,000 = 19%

DIR = 0.19 / 0.31 = 0.61

Well below 0.8, so the model fails the screen. But group B also has a lower base rate of positives (15% against 30%), so parity may not be the right target. Context decides.

ILLUSTRATIVE DATA

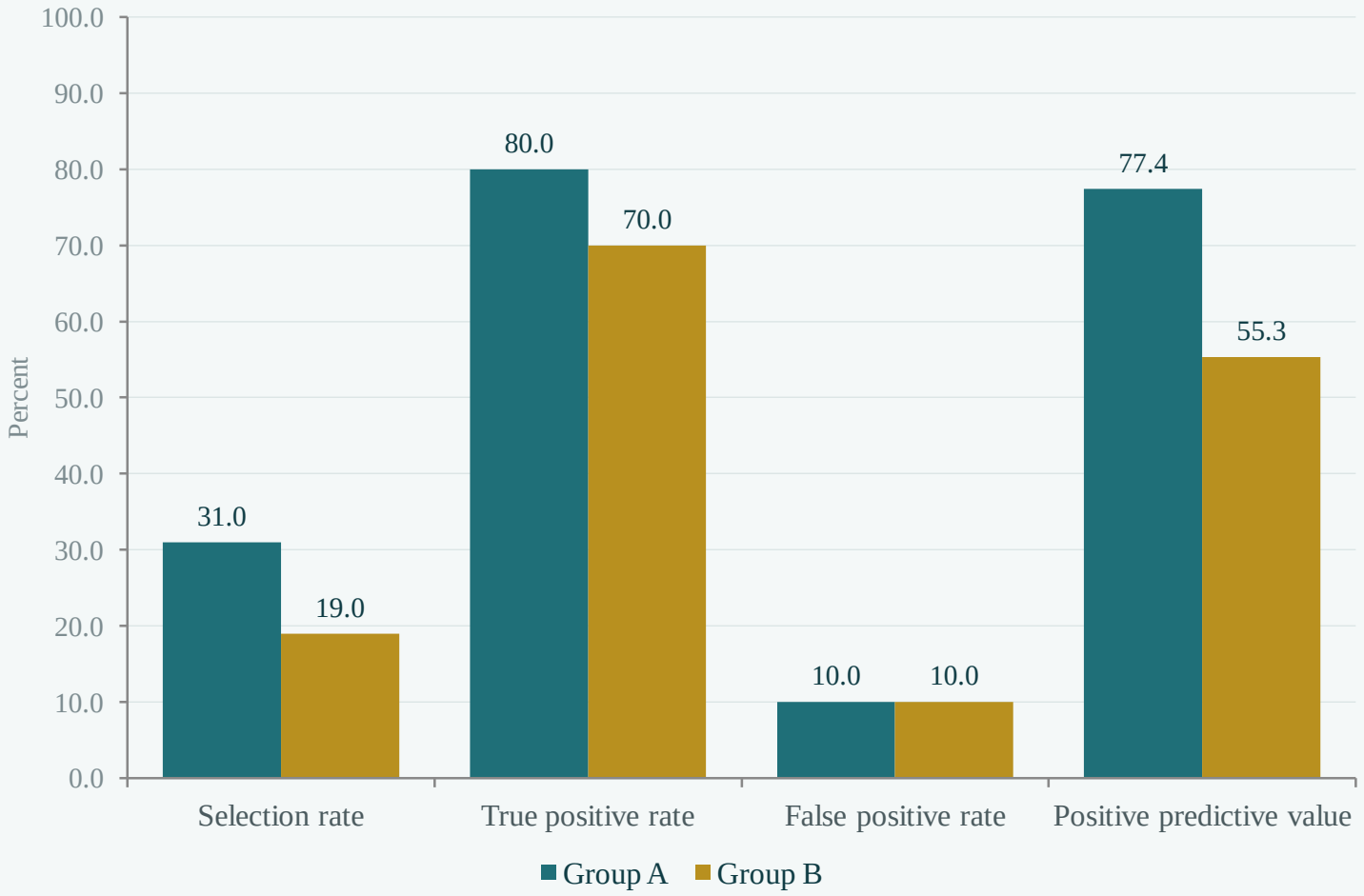
Worked example: one model, two groups

Quantity	Group A (n = 1,000)	Group B (n = 1,000)	Gap	Fairness reading
Actual positives (base rate)	300 (30%)	150 (15%)	15 pts	Different base rates
True positives / false negatives	240 / 60	105 / 45		More qualified B missed
False positives / true negatives	70 / 630	85 / 765		
Selection rate	31.0%	19.0%	12.0 pts	Fails demographic parity
True positive rate (recall)	80.0%	70.0%	10.0 pts	Fails equal opportunity
False positive rate	10.0%	10.0%	0.0 pts	Equal
Positive predictive value	77.4%	55.3%	22.1 pts	Fails predictive parity

Reading The same model passes one fairness test and fails three others. Which gap matters depends on whether missing qualified people or wrongly selecting them is the greater harm.

ILLUSTRATIVE DATA

Worked example: metric profile by group



22 pts

Largest gap: PPV

A positive prediction for group B is right far less often, driven by its lower base rate.

Equal false alarms

Both groups face the same false positive rate, which could be the priority where wrongful selection is the main harm.

Decision required

An accountable owner must decide which criterion governs this use, and record why.

The impossibility results

KLEINBERG ET AL. 2016; CHOULDECHOVA 2017

When base rates differ between groups, a classifier that is not perfect cannot simultaneously satisfy calibration within groups and equal false positive and false negative rates. Fairness definitions are not just different; they are mutually incompatible.

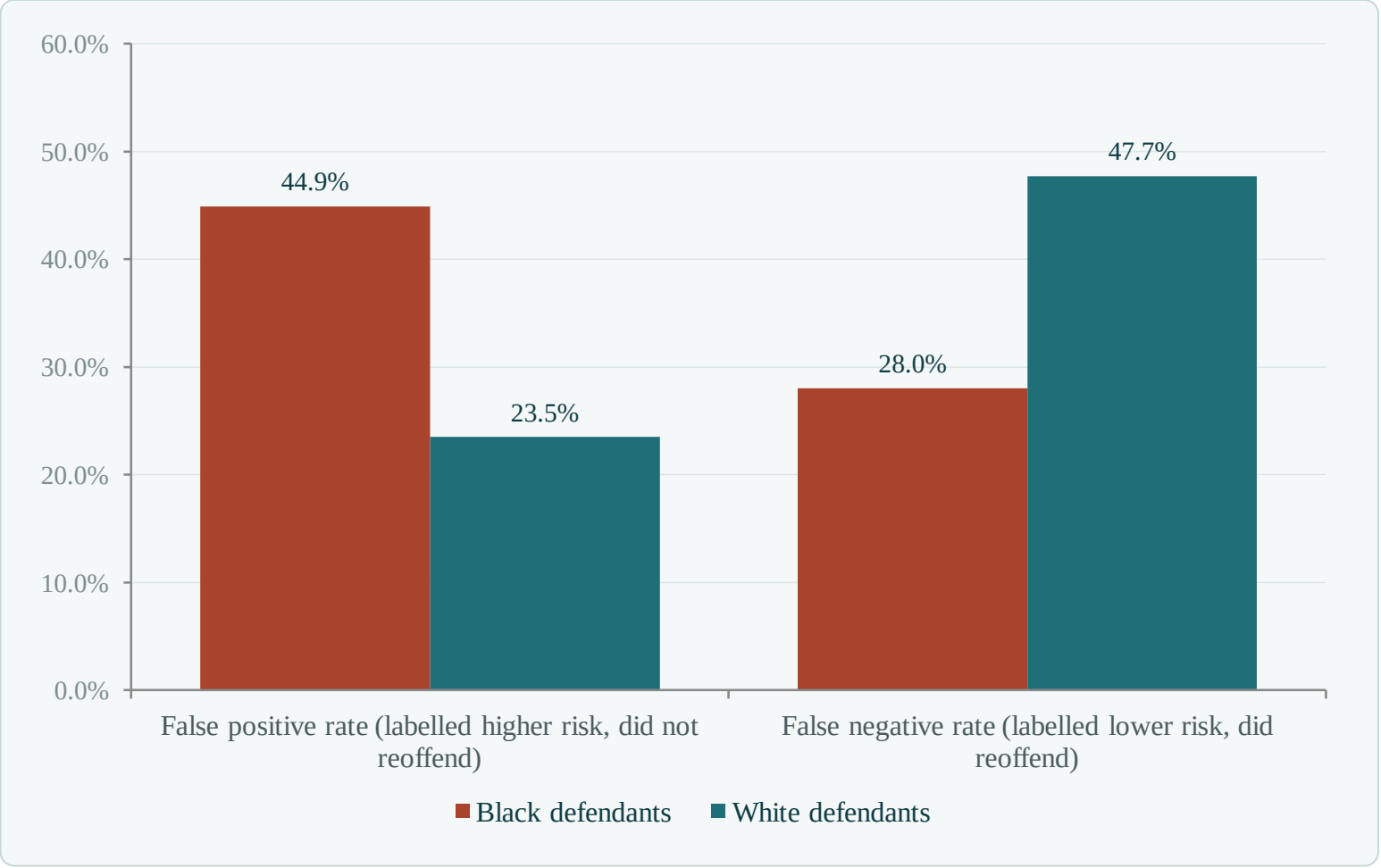
1. **Consequence**
   There is no technical setting that makes a model fair in every sense. Choosing a criterion is unavoidable.

2. **Who chooses**
   The choice embodies a view of justice, so it belongs with accountable decision makers, informed by affected groups.

3. **What to document**
   The criterion chosen, the alternatives rejected, the gaps that remain and why they are acceptable.

4. **Legal overlay**
   Equality law, not mathematics, defines what differences require objective justification.

COMPAS: the debate that made the impossibility concrete



1.9x

False positive disparity

Black defendants who did not reoffend were nearly twice as often labelled higher risk.

The vendor’s reply

Northpointe argued the scores were equally predictive for both groups, which is a predictive parity claim.

Both were right

With different base rates both statements hold at once. The dispute was about which fairness to require.

Source: Angwin, Larson, Mattu and Kirchner, ProPublica (2016), Broward County, Florida analysis.

Group fairness and individual fairness

Group fairness

- **Question:** Are outcomes or errors balanced across defined groups?
- **Strength:** Measurable, auditable, aligned with discrimination law.
- **Weakness:** Can be satisfied while treating individuals within groups arbitrarily.
- **Tools:** Parity metrics, subgroup dashboards, disparate impact tests.

VS

Individual fairness

- **Question:** Are similar people treated similarly?
- **Strength:** Matches intuitions about consistency and desert.
- **Weakness:** Requires a similarity measure that is itself a value judgement.
- **Tools:** Counterfactual tests, consistency checks, matched pair audits.

In practice Use group metrics for monitoring and legal assurance, and counterfactual or matched pair tests to catch arbitrary individual treatment.

Bias mitigation: three points of intervention

Pre processing

Change the data: reweighting, resampling, relabelling, removing or transforming proxy features, collecting better data. Model agnostic and transparent, but may not fix downstream effects.

In processing

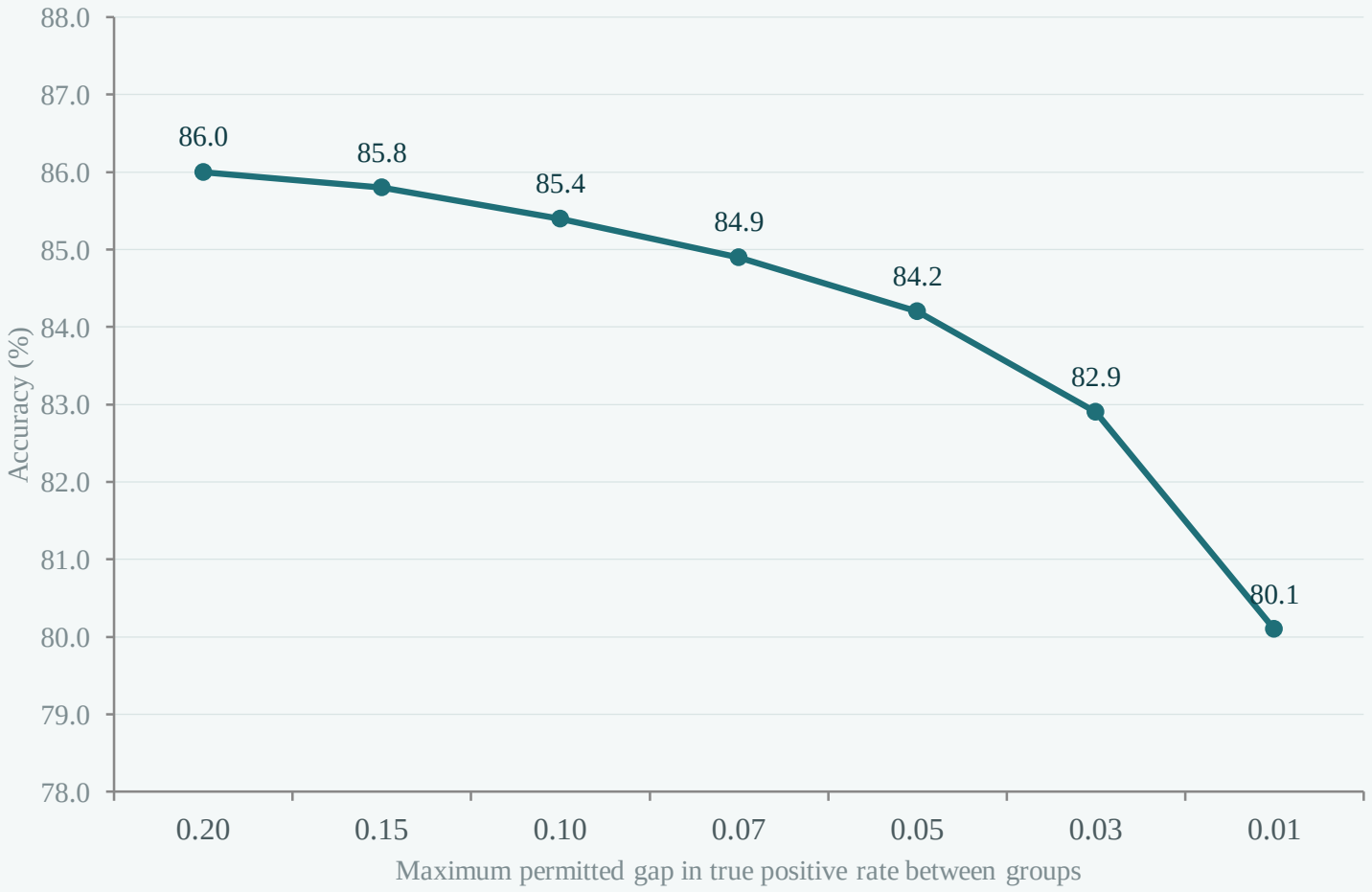
Change the learning: fairness constraints or penalties in the objective, adversarial debiasing. Precise control of the trade off, but needs access to training and is harder to explain.

Post processing

Change the decision: group specific thresholds or calibration after training. Simple and works with vendor models, but explicit group treatment raises legal questions.

ILLUSTRATIVE DATA

The accuracy and fairness frontier



0.6 pts

Cheap early gains

Halving the gap from 0.20 to 0.10 costs little accuracy.

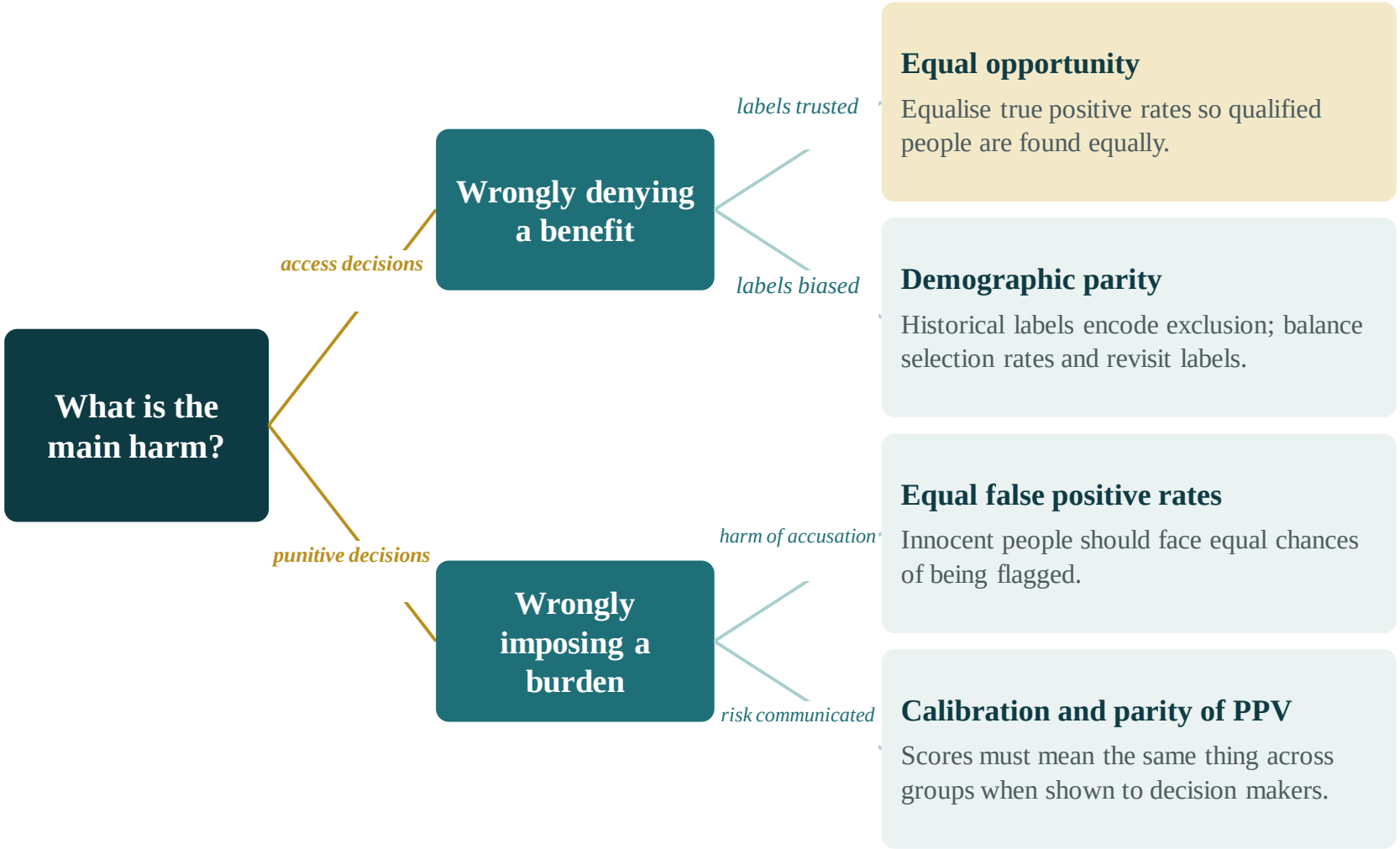
Steep final stretch

Closing the last few points costs much more. Where to stop is a governance decision.

Check the baseline

Part of measured accuracy may reflect biased labels, so the true trade off can be smaller than it looks.

Choosing a fairness criterion: a decision guide



ALWAYS

Document and revisit

Record the criterion, its rationale and the remaining gaps. Revisit when base rates, laws or uses change.

UK Equality Act 2010: the nine protected characteristics

Direct and indirect discrimination rules apply to AI enabled decisions in employment, services and public functions.

1 Age

Including age bands used as features or inferred from data.

2 Disability

Including duties to make reasonable adjustments.

3 Gender reassignment

Protected regardless of medical treatment.

4 Marriage and civil partnership

Mainly in employment contexts.

5 Pregnancy and maternity

Watch for proxies such as employment gaps.

6 Race

Including colour, nationality and ethnic or national origin.

7 Religion or belief

Including lack of belief.

8 Sex

Watch for gendered language and proxy features.

9 Sexual orientation

Rarely collected, so bias is hard to measure.

Proxy discrimination: bias without sensitive features



INDIRECT DISCRIMINATION

Removing protected attributes does not remove their influence. Correlated features let a model reconstruct them. Under the Equality Act, a provision, criterion or practice that puts a group at a particular disadvantage must be objectively justified.

1. **Postcode**
   Strongly correlated with ethnicity and income in many UK areas.

2. **Name and language**
   Signals of sex, ethnicity and national origin in text and CV models.

3. **Career gaps and hours**
   Correlated with sex, pregnancy, disability and caring responsibilities.

4. **Control**
   Test outcomes by group even when attributes are not features; this may require lawful collection of the data needed to measure bias.

ILLUSTRATIVE DATA

Intersectionality: gaps hide in combinations

Buolamwini and Gebru (2018) showed error rates far higher for darker skinned women than either attribute alone suggested.

	Younger men	Younger women	Older men	Older women
Group X	4%	4%	4%	7%
Group Y	4%	7%	7%	10%
Group Z	4%	7%	10%	19%

Low error Elevated Severe

WHY IT MATTERS

19%

Hidden in averages

Each single attribute gap looks modest, but one intersection has an error rate several times higher. Test at intersections wherever sample sizes allow.

A fairness governance process

01 Scope	02 Select	03 Measure	04 Mitigate	05 Approve	06 Monitor
Identify affected groups, relevant law and the main harm of each error type.	Choose primary and secondary fairness criteria with documented rationale.	Test before release with disaggregated and intersectional analysis.	Apply proportionate interventions; record the accuracy cost.	Accountable owner accepts residual gaps within appetite.	Track gaps in production; trigger review on breach.



Key point The output of fairness work is a documented decision, not just a metric. Auditors will ask who chose, why, and what was accepted.

Participatory approaches: involving affected people

Consultation

Engage representatives of affected groups when framing problems and defining harms, not only after deployment.

Lived experience panels

Standing panels review high risk use cases and help interpret fairness results in context.

Co design

Design explanations, appeal routes and interfaces with the people who will use and be judged by them.

Feedback channels

Accessible routes to report concerns, with evidence that feedback changes systems.

Section 8 synthesis

> *Fairness cannot be computed into existence. Metrics reveal disparities; only accountable people, informed by those affected, can decide which disparities are unjust and what trade off is acceptable.*

Synthesis of Section 8

01

Bias has many sources

Each lifecycle stage needs its own control.

02

Definitions conflict

Choosing a criterion is a value judgement to own and document.

03

Measure at intersections

Averages hide the largest harms.

SECTION

09

Transparency, Explainability and Accountability

Making automated decisions understandable, traceable and answerable to the people they affect.

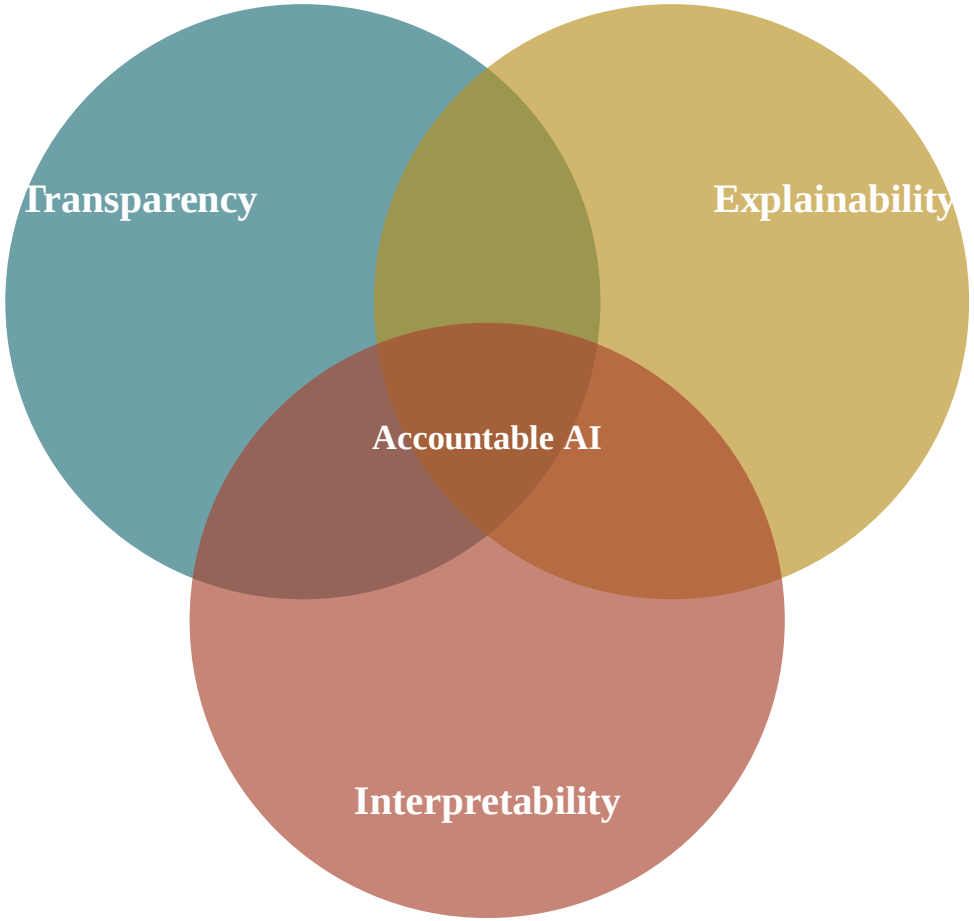
IN THIS SECTION

- Concepts and audiences
- Interpretability spectrum
- Accountability mechanisms
- Six explanation types
- SHAP and counterfactuals
- Logging and contestability

Slides 160 to 177



Transparency, explainability and interpretability



Transparency

Openness about the fact, purpose, data and logic of AI use. A property of the organisation and its communication.

Explainability

The ability to give a meaningful account of why a particular output or decision was produced.

Interpretability

The degree to which a human can understand the internal mechanics of the model itself.

Why the distinction matters

A black box model can be transparent about its use and explainable at the level of a decision without being interpretable internally. Requirements should name which property is needed.

Different audiences need different explanations

Audience	What they need to know	Best form	Depth
Affected individual	Why this decision about me, and what can I do?	Plain language reasons and options	Local, actionable
Frontline reviewer	How reliable is this output, and when should I override?	Confidence, key drivers, flags	Local, contextual
Model owner	Is the model behaving as intended across groups?	Dashboards, global importance	Global, aggregate
Validator and auditor	Is the logic sound, documented and reproducible?	Technical documentation, code	Full technical
Regulator	Does the organisation comply and control its risks?	Documentation, logs, assessments	System and process
Board	What risks are we carrying and are they within appetite?	Summaries and assurance reports	Strategic

Six explanation types (ICO and Alan Turing Institute)

From the guidance Explaining decisions made with AI, which remains a practical UK reference.

Rationale

The reasons that led to a decision, in an accessible and non technical way.

Responsibility

Who is involved in developing, managing and implementing the system, and whom to contact for human review.

Data

What data was used in the decision and how; what data trained the model.

Fairness

Steps taken to ensure decisions are generally unbiased and fair, and whether the individual was treated equitably.

Safety and performance

Steps taken to maximise accuracy, reliability, security and robustness.

Impact

Effects that the system and its use have on an individual and on wider society.

The interpretability spectrum of model families

Intrinsically interpretable **Opaque**



GLASS BOX

Rules and scorecards

Every step visible. Ideal where decisions must be explained point by point.

INTERPRETABLE

Linear models and GAMs

Coefficients and shape functions readable; strong default for regulated decisions.

PARTIAL

Tree ensembles

High accuracy on tabular data; explained after the fact with SHAP and similar tools.

OPAQUE

Deep networks

Strong on images, text, signals; explanations approximate.

EMERGENT

Foundation models

Behaviour depends on prompts and context; explanation is an open research problem.

Global and local explanations

Global: how the model works overall

- **Methods:** Feature importance, partial dependence, accumulated local effects, surrogate models.
- **Questions:** What drives predictions in general? Are drivers plausible and lawful?
- **Users:** Developers, validators, owners and auditors.
- **Risk:** Averages can hide subgroup behaviour and interactions.

VS

Local: why this prediction

- **Methods:** SHAP values, LIME, counterfactual explanations, example based explanations.
- **Questions:** Why was this applicant refused? What would change the outcome?
- **Users:** Affected individuals, reviewers and complaint handlers.
- **Risk:** Unstable or misleading explanations that look authoritative.

Requirement High risk decisions need both: global evidence that the logic is sound, and local explanations that individuals can act on.

SHAP: attributing a prediction to features

$$f(x) = \varphi 0 + \Sigma \text{ over features } \varphi i$$

(Lundberg and Lee, 2017)

$f(x)$ The model's output for this case, for example a log odds of default.

$\varphi 0$ The base value: the average model output across the reference data.

φi The Shapley value of feature i: its average marginal contribution across feature orderings.

Property Contributions add up exactly to the difference between this prediction and the base value.

CAUTIONS

SHAP explains the model, not the world: a large value does not mean the feature causes the outcome.

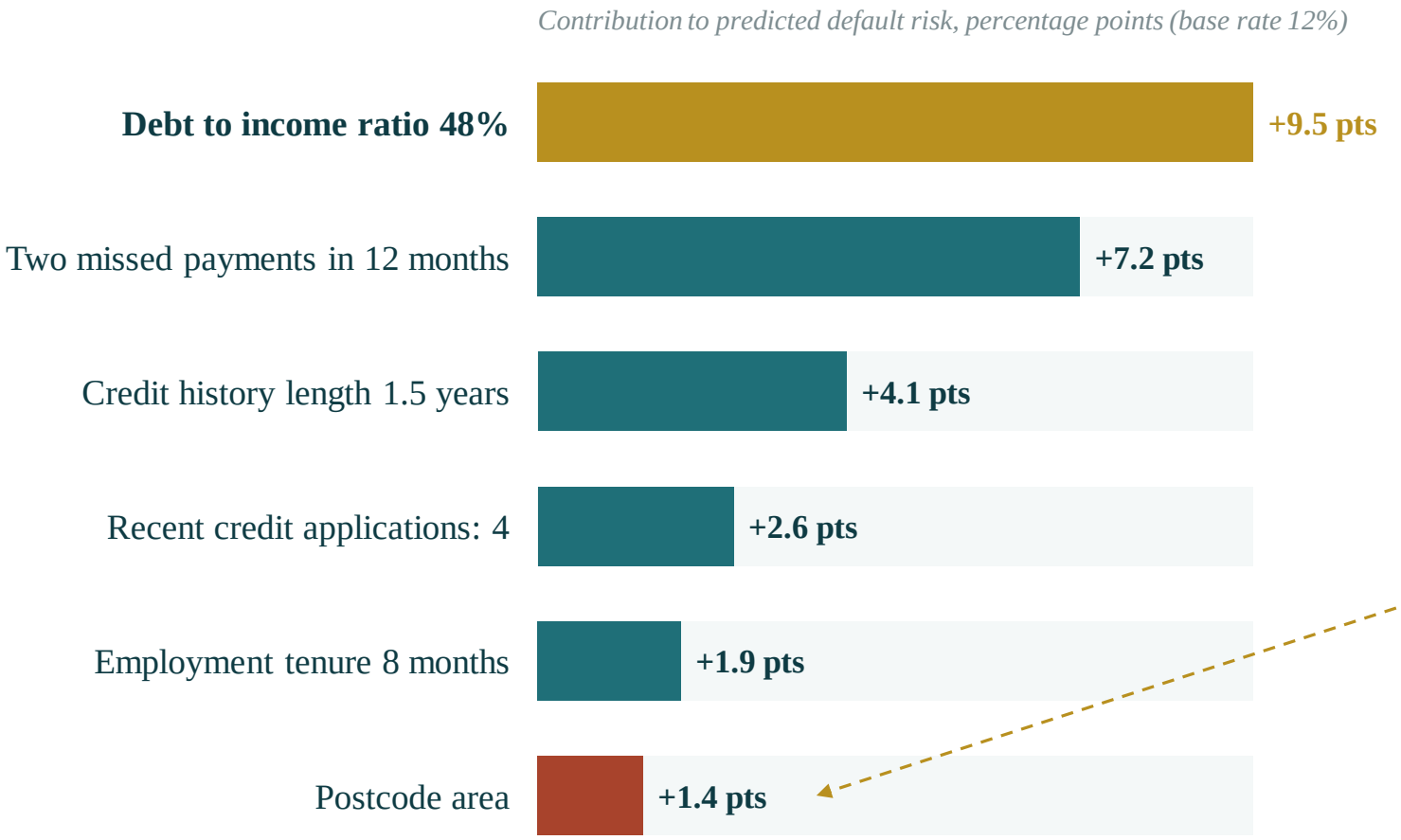
Correlated features can share or swap credit in ways that mislead.

Results depend on the reference dataset chosen.

Present SHAP to individuals only after translating it into plain reasons they can act on.

ILLUSTRATIVE DATA

A local explanation: why this loan was declined



1

Actionable reasons

Debt to income and missed payments dominate. These can be explained and the applicant can act on them.

2

Governance flag

Postcode contributes to risk. Check whether it is acting as a proxy for a protected characteristic before release.

Counterfactual explanations: what would change the outcome?

WACHTER, MITTELSTADT AND RUSSELL, 2017

A counterfactual explanation states the smallest change to the inputs that would have produced a different decision: your application would have been approved if your debt to income ratio had been below 40%. It helps people act without exposing the model.

1. **Actionable**
   Prefer changes the person can make, not immutable traits such as age.

2. **Plausible**
   Suggested values must be realistic and consistent with each other.

3. **Diverse**
   Offer more than one route where possible, so the explanation is not arbitrary.

4. **Honest**
   Do not imply that meeting the counterfactual guarantees approval if the model or policy may change.

Limits and failure modes of explainable AI

Unfaithful explanations

Post hoc methods approximate the model and may not reflect its true reasoning.

Instability

Small input changes can produce very different explanations for near identical cases.

Manipulability

Models can be engineered to produce reassuring explanations while relying on problematic features.

False reassurance

Explanations can increase trust in wrong outputs, worsening automation bias.

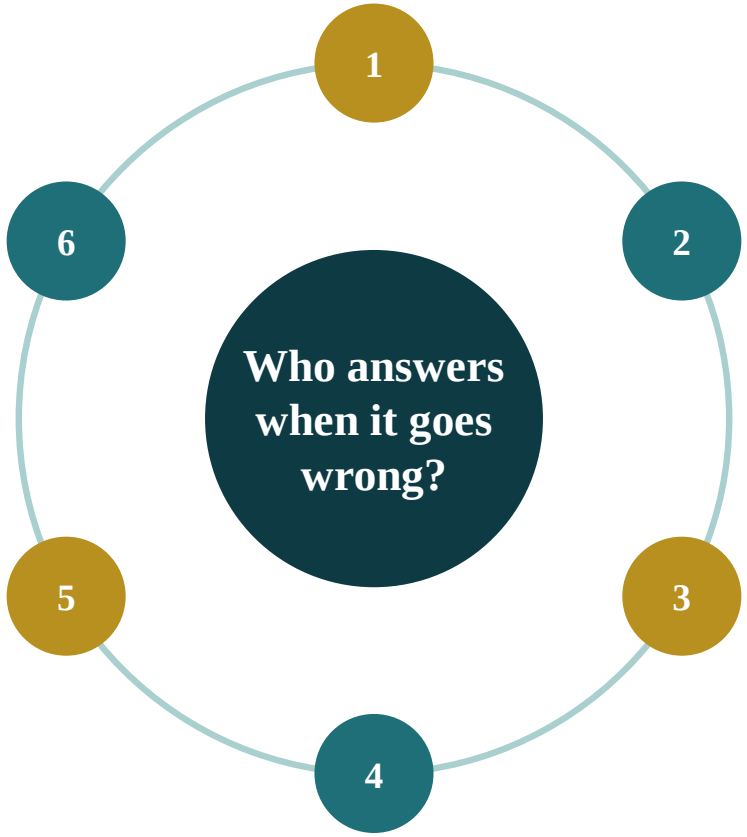
Overload

Technical detail overwhelms the people who most need a usable answer.

The alternative

For high stakes tabular decisions, an interpretable model often performs nearly as well (Rudin, 2019).

Accountability and the problem of many hands



1. **Data supplier**
   Provided training data of unknown quality.
2. **Model vendor**
   Built a general model under contractual limits.
3. **Developer**
   Fine tuned and integrated the model.
4. **Approver**
   Signed off release on the evidence presented.
5. **Operator**
   Relied on the output in a busy workflow.
6. **Executive**
   Set targets that rewarded automation.

Five mechanisms that make accountability real

Answerability	Named owner for each system	Duty to explain decisions	Board reporting
Traceability	Logs of inputs and outputs	Model and data versions	Approval records
Contestability	Accessible challenge route	Human review on request	Time limits for response
Redress	Correction of the decision	Compensation where due	Fix for others affected
Consequences	Performance objectives	Senior manager accountability	Regulatory sanctions

The Algorithmic Transparency Recording Standard

UK PUBLIC SECTOR

The UK Algorithmic Transparency Recording Standard requires central government departments and certain arm's length bodies to publish records of algorithmic tools that significantly influence decisions affecting the public. It is a public register model that private organisations can learn from.

1. **Tier 1**
   A short, non technical summary: what the tool does and why it is used.

2. **Tier 2**
   Detailed information: ownership, data, how it fits into the decision process, risks and mitigations.

3. **Benefit**
   Public scrutiny and internal discipline: writing the record exposes gaps in governance.

4. **Private sector lesson**
   A published AI register signals confidence and builds trust with customers and regulators.

Audit trails and logging: what to record

- ☑ Unique identifier for each decision or prediction.
- ☑ Human reviewer identity and action taken.
- ☑ Timestamp and system and model version used.
- ☑ Overrides and the recorded reason.
- ☑ Input data, or a secure reference to it.
- ☑ Notices given to the affected person.
- ☑ Output, score, confidence and any explanation shown.
- ☑ Challenges, outcomes and corrections made.

EU AI ACT ARTICLE 12

Logging by design

High risk systems must technically allow automatic recording of events over their lifetime, so that risks and substantial modifications can be identified.

Designing contestability and redress

01 Notify	02 Explain	03 Receive	04 Review	05 Respond	06 Learn
Tell the person that an automated or AI assisted decision was made, and how to challenge it.	Provide reasons and the key information used, in plain language.	Accept representations through accessible channels, including new information.	A competent human with authority reconsiders the decision afresh.	Communicate the outcome and reasons within a defined period.	Aggregate challenges to detect systematic model or process issues.

Law UK GDPR Articles 22C and 22D, as inserted by DUAA 2025, require information, representations, contest and human intervention for significant automated decisions.

EU AI Act Article 50: transparency obligations

Applicable from 2 August 2026, with the marking grace period for systems already on the market ending 2 December 2026.

Interacting with AI

Providers must design systems so people are informed they are interacting with AI, unless obvious from context.

Synthetic content marking

Providers of systems generating audio, image, video or text must mark outputs in a machine readable, detectable way.

Emotion and biometric notice

Deployers of emotion recognition or biometric categorisation must inform the people exposed.

Deepfakes and public interest text

Deployers must disclose deepfakes and AI generated text published to inform the public, subject to exceptions.

Explainability by design: a release checklist

- [ ] Explanation needs defined per audience before model selection.
- [ ] Simplest adequate model considered and documented.
- [ ] Global explanation reviewed for plausibility and lawful drivers.
- [ ] Local explanations tested for stability on near identical cases.
- [ ] Plain language reason codes reviewed by non specialists.
- [ ] Counterfactuals limited to actionable features.
- [ ] Explanations shown to reviewers include uncertainty.
- [ ] Contact route for human review included in every notice.
- [ ] Explanation quality monitored through complaints and appeals.
- [ ] Records retained to reproduce any explanation given.

Section 9 synthesis

> *Explanation is not an end in itself. It matters because it lets people understand, challenge and correct decisions, and because it makes someone answerable for them.*

Synthesis of Section 9

01

Match the audience

Individuals need actionable reasons; auditors need reproducible evidence.

02

Know the limits

Post hoc explanations can mislead; prefer interpretable models where stakes are high.

03

Close the loop

Logs, contest routes and redress turn transparency into accountability.

SECTION

10

Human Oversight and Human Centred Decision Making

Designing oversight that changes outcomes, rather than a signature that legitimises them.

IN THIS SECTION

- Levels of automation
- Article 14 requirements
- Override governance
- In, on and out of the loop
- Automation bias and trust
- A level grading case

Slides 178 to 194



Why human oversight, and why it so often fails



THE OVERSIGHT PARADOX

We add humans to catch machine errors, but the better the machine performs, the less attentive and the less empowered humans become. Oversight that is not designed for this paradox becomes a rubber stamp that shifts blame without reducing harm.

1 **Purpose**

Catch errors, handle novel cases, apply values and context the model lacks, and provide a point of accountability.

2 **Failure mode 1**

Reviewers lack time, information or authority to disagree with the system.

3 **Failure mode 2**

Automation bias: people over rely on outputs, especially under workload pressure.

4 **Failure mode 3**

Liability sponge: the human exists mainly to absorb blame for system design choices.

Ten levels of automation (Sheridan and Verplank, 1978)

Level	What the computer does	Typical AI analogue
1	Offers no assistance; the human does everything	Manual process
2 to 3	Offers a full set of alternatives, or narrows them to a few	Search and shortlisting tools
4	Suggests one alternative	Recommendation engine
5	Executes the suggestion only if the human approves	Human in the loop approval
6	Allows a restricted time to veto before acting	Auto approval with veto window
7	Acts automatically, then necessarily informs the human	Automated decision with notification
8 to 9	Informs the human only if asked, or if it decides to	Background automation
10	Decides and acts autonomously, ignoring the human	Fully autonomous agent

Human in, on and out of the loop

Human in the loop

A human must act on every case before the decision takes effect. Highest control, highest cost; at risk of rubber stamping at volume. Fits high stakes, low volume decisions.

Human on the loop

The system acts; humans monitor, sample and can intervene or stop it. Scales well if monitoring is strong and intervention is real.

Human out of the loop

No routine human involvement. Requires low impact, high reliability, strong monitoring and a legal basis for solely automated decisions.

EU AI Act Article 14: what human oversight must enable

- Understand the capacities and limitations of the system.
- Decide not to use, or to disregard, override or reverse an output.
- Monitor operation, detecting anomalies and unexpected performance.
- Intervene or interrupt the system through a stop button or similar.
- Remain aware of the tendency to over rely on outputs.
- Oversight measures proportionate to risk, autonomy and context.
- Correctly interpret outputs using available tools.
- Measures built in by the provider or implemented by the deployer.

BIOMETRIC IDENTIFICATION

Two person rule

For remote biometric identification systems, no action may be taken on an identification unless separately verified by at least two competent natural persons, subject to limited exceptions.

Automation bias: how people over trust machines

Decades of human factors research show predictable patterns when people supervise automation.

Omission

Errors of omission

Failing to notice a problem because the system did not flag it. Silence is taken as safety.

Commission

Errors of commission

Following an incorrect recommendation despite contrary evidence available to the person.

Drift

Skill degradation

Reviewers lose the expertise needed to judge outputs as manual practice declines.

Design response Show uncertainty, require reasons for agreement on high stakes cases, inject known test cases, rotate tasks and protect time for review.

Algorithm aversion and algorithm appreciation

Algorithm aversion

- **Finding:** People abandon an algorithm after seeing it err, even when it outperforms humans (Dietvorst et al., 2015).
- **Risk:** Useful tools ignored; inconsistent human judgement persists.
- **Response:** Allow modest human adjustment; show track records.

VS

Algorithm appreciation

- **Finding:** Lay people often weight algorithmic advice above human advice (Logg et al., 2019).
- **Risk:** Over reliance and failure to challenge wrong outputs.
- **Response:** Calibrate trust with uncertainty and performance feedback.

Goal Neither aversion nor appreciation: calibrated trust, where reliance matches the system's actual reliability in each context.

Five conditions for meaningful human review

Authority	Formal power to override, with no penalty for justified disagreement.
Competence	Training on the system's logic, limits and the domain itself.
Time	Workloads that allow genuine consideration of each case.
Information	Access to the inputs, key drivers, uncertainty and other relevant evidence.
Accountability	Reviewers record reasons and are accountable for their own judgement.

TEST

Could the reviewer say no?

If a reviewer has never overridden the system, or would be penalised for doing so, the review is probably not meaningful.

Designing decision support interfaces

Show uncertainty

Display confidence ranges, not just a single score or a traffic light.

Order matters

Consider letting reviewers form a view before revealing the model output for high stakes cases.

Show drivers

Present the main factors and the evidence behind them in plain language.

Flag novelty

Alert when a case is unlike the training data, where the model is least reliable.

Capture reasons

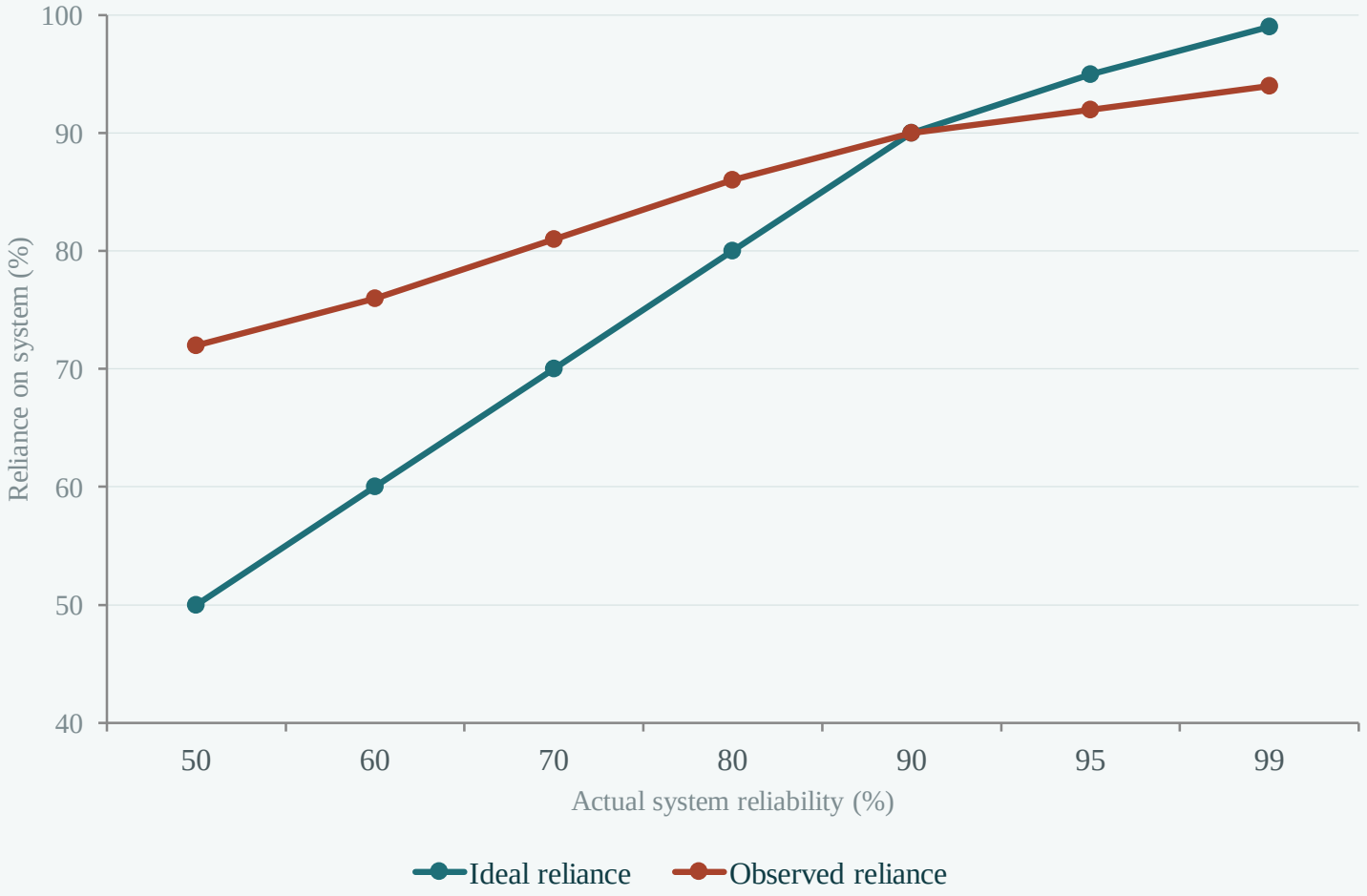
Make recording reasons for agreement and override quick and structured.

Avoid dark patterns

Do not default to acceptance or make overrides harder than agreement.

ILLUSTRATIVE DATA

Calibrated trust: matching reliance to reliability



Over trust zone

Where observed reliance exceeds reliability, errors pass unchecked. Typical for weaker systems.

Under trust zone

Where reliance falls below reliability, good outputs are wasted and inconsistency rises.

Govern by measurement

Track agreement and override rates against outcomes to locate each team on this chart.

Escalation thresholds and override governance

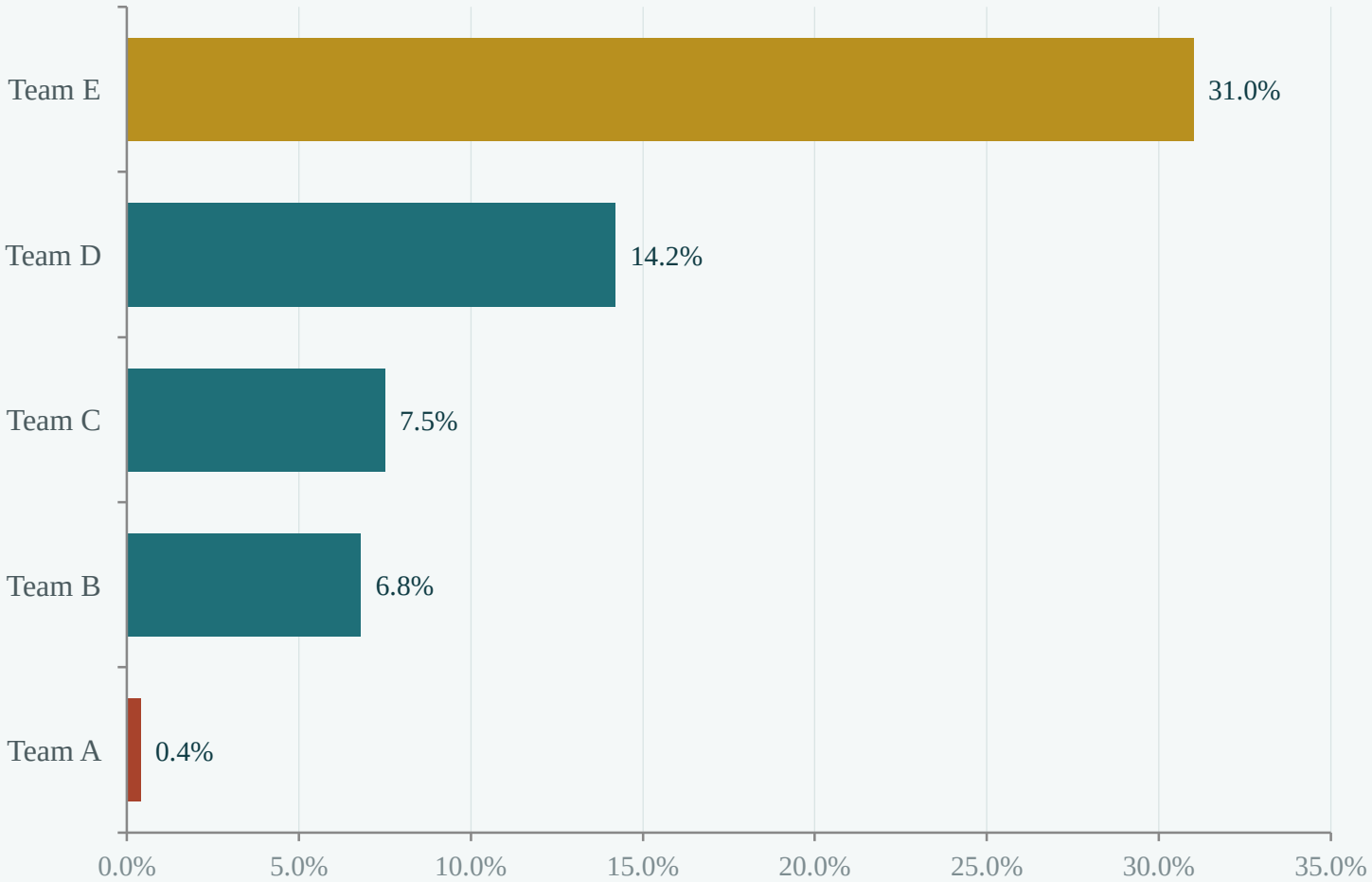
01 Confidence bands	02 Route	03 Override	04 Second check	05 Analyse
Define bands: auto proceed, human review, specialist review, and do not automate.	Send uncertain, novel or adverse decisions to the right level of reviewer.	Reviewer may override with a structured reason code and free text.	Sample overrides and agreements for quality review.	Feed override patterns back into model and policy improvement.



Principle Override data is among the most valuable governance evidence an organisation has. It shows where humans and models disagree, and who was right.

ILLUSTRATIVE DATA

Override analytics: what the numbers reveal



0.4%

Team A: rubber stamping?

Near zero overrides suggest reviewers are not exercising judgement, or lack authority to do so.

31%

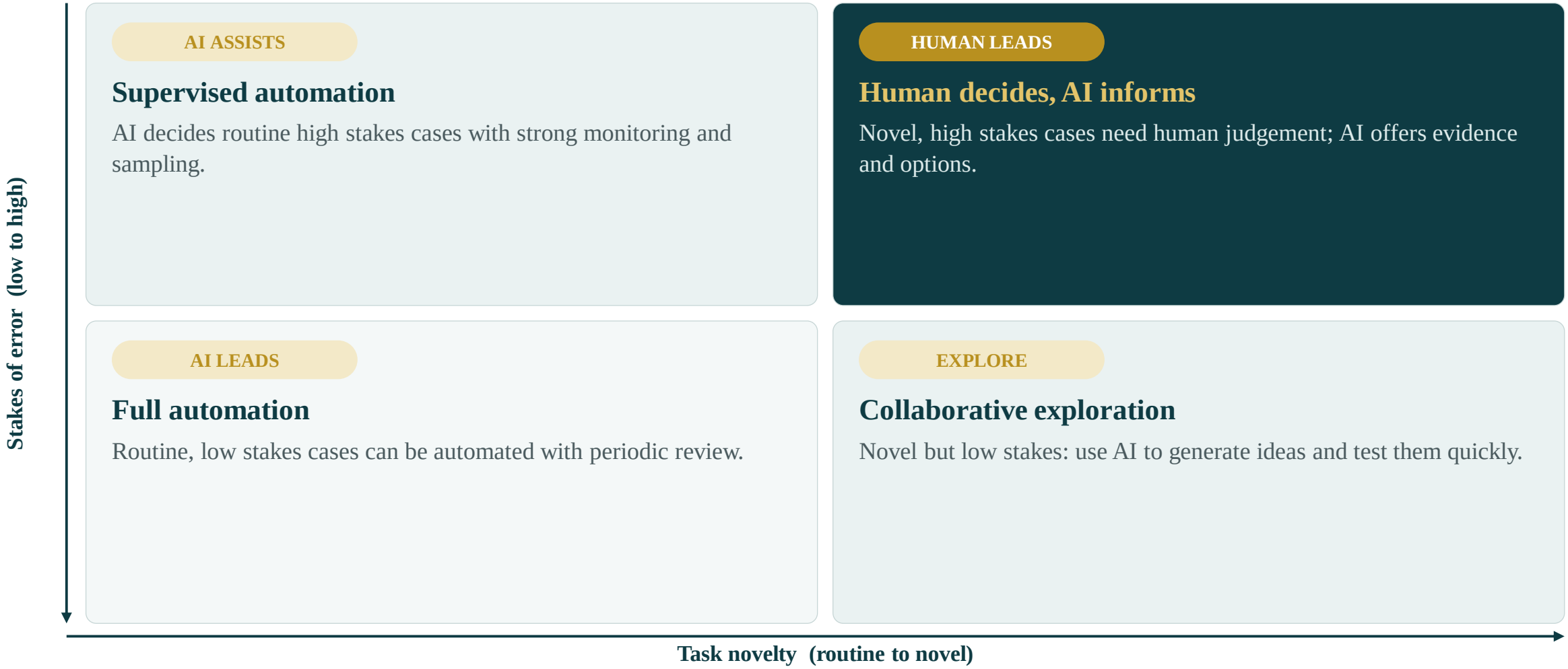
Team E: model mismatch?

Very high overrides suggest the model fits this context poorly, or reviewers distrust it.

Investigate both tails

Pair override rates with outcome accuracy to see whether humans or the model were right.

Human and AI teaming configurations



Cognitive load and alert fatigue

HUMAN FACTORS

Every alert competes for limited attention. Systems that generate too many low value alerts teach people to ignore all of them, including the one that matters. Alert design is a governance decision.

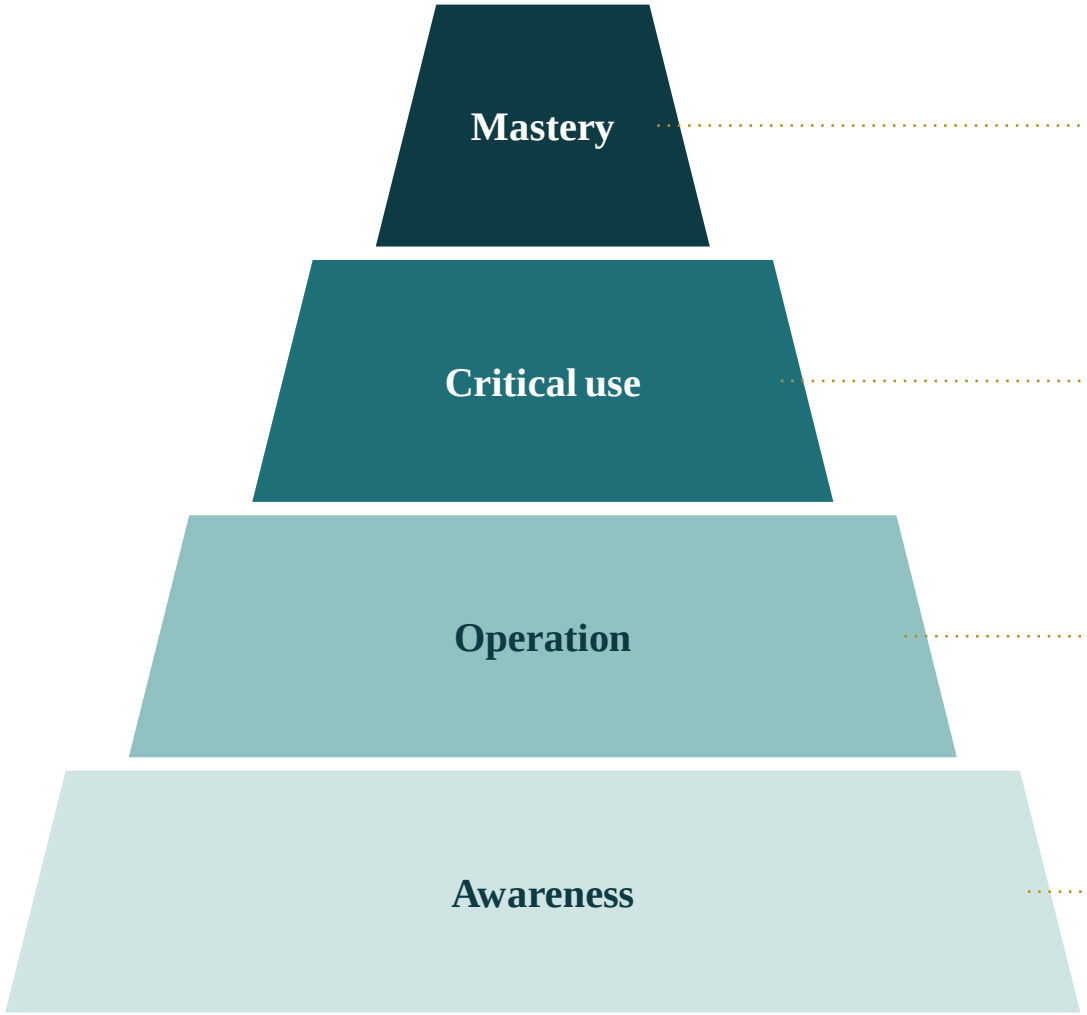
1. **Volume**
   Set alert thresholds with reviewer capacity in mind; an unreviewed alert is not a control.

2. **Precision**
   Track the proportion of alerts that lead to action; prune those that rarely do.

3. **Prioritisation**
   Rank by risk so the most consequential cases are seen first.

4. **Rest and rotation**
   Vigilance declines over time; schedule review work accordingly.

Building reviewer competence



Expert judgement

Knows when the system is out of its depth and handles novel cases independently.

Critical engagement

Interprets drivers and uncertainty; overrides with sound reasons.

Procedural competence

Follows workflows, records reasons and escalates correctly.

Basic awareness

Understands what the system does, its purpose and its known limits.

Case: the 2020 A level grading algorithm

England, August 2020
Education | Public sector
Ofqual standardisation model

~39%

of teacher assessed A level grades were lowered by the model before the government reversed course.

WHAT HAPPENED

With exams cancelled by the pandemic, a statistical model adjusted teacher assessed grades using each school's historical results. Results day caused widespread outrage, and within days the government reverted to teacher assessed grades.

DECISION FAILURE

Individual outcomes were driven by school history rather than individual evidence. Small cohorts, more common in independent schools, relied more on teacher grades, so the effects were uneven. There was no meaningful individual review before results were issued.

GOVERNANCE LESSON

Population level accuracy is not individual fairness. High stakes decisions about individuals need individual level evidence, a working appeal route before release, and testing of who wins and who loses.

Section 10 synthesis

> *Human oversight is not a person placed next to a machine. It is a designed capability: authority, competence, time and information, measured by whether humans actually change outcomes when the machine is wrong.*

Synthesis of Section 10

01

Choose the loop deliberately

In, on or out of the loop should follow from stakes and novelty.

02

Design against bias

Interfaces and workloads determine whether review is real.

03

Measure overrides

Override analytics show whether oversight works.

SECTION

11

Governing Generative and Agentic AI Systems

Open ended outputs, autonomous actions and layered supply chains require new decision controls.

IN THIS SECTION

- What changes with GenAI
- RAG and hallucination controls
- Agent autonomy and permissions
- Risk landscape and OWASP
- Evaluation and red teaming
- Provenance and acceptable use

Slides 195 to 213



What changes when AI generates and acts

Traditional predictive ML

- **Output:** A bounded score or class with a known label space.
- **Evaluation:** Ground truth metrics on held out test sets.
- **Supply chain:** Usually built in house on owned data.
- **Failure:** Wrong predictions, drift and biased error rates.
- **Control point:** Model release and decision threshold.

VS

Generative and agentic AI

- **Output:** Open ended text, code, images and actions in tools.
- **Evaluation:** Rubrics, human judgement, red teaming and scenario tests.
- **Supply chain:** Foundation model, prompts, retrieval data, tools and plugins.
- **Failure:** Hallucination, injection, leakage, harmful content, unintended actions.
- **Control point:** Every prompt, retrieval, tool call and action.

Implication Governance moves from approving a model once to constraining behaviour continuously at run time.

The generative AI risk landscape

	Likelihood	Impact on people	Legal exposure	Detectability	Overall
Hallucinated facts	Very high	High	Medium	High	High
Prompt injection	High	Very high	High	Very high	Very high
Sensitive data leakage	High	Very high	Very high	High	Very high
Copyright and IP	High	Medium	Very high	Medium	High
Harmful or biased content	Medium	Very high	High	Medium	High
Excessive agency in tools	Medium	Very high	High	Very high	Very high
Over reliance by users	Very high	High	Medium	Very high	High
Cost and resource overrun	High	Low	Low	Medium	Medium

Low Medium High Very high

DETECTABILITY

Hard to see is high risk

Detectability is scored inversely: higher means harder to detect. Injection and excessive agency combine high impact with low visibility, so they need preventive controls.

OWASP Top 10 for LLM applications (2025)

ID	Risk	Governance control
LLM01	Prompt injection	Separate instructions from untrusted content; least privilege tools; output checks
LLM02	Sensitive information disclosure	Data classification for prompts and retrieval; redaction; access controls
LLM03	Supply chain	Vet model and plugin sources; signed artefacts; vendor assessment
LLM04	Data and model poisoning	Provenance of training and retrieval data; anomaly detection
LLM05	Improper output handling	Treat outputs as untrusted input to downstream systems
LLM06	Excessive agency	Limit tool scope and autonomy; human approval for consequential actions
LLM07	System prompt leakage	Never place secrets or authorisation logic in prompts
LLM08	Vector and embedding weaknesses	Access control on vector stores; tenant isolation
LLM09	Misinformation	Grounding, citation, uncertainty signals and human review
LLM10	Unbounded consumption	Rate limits, quotas, cost monitoring and timeouts

Layered controls against hallucination

Use case design	Avoid open answers for high stakes facts	Constrain to approved tasks	Define acceptable error
Grounding	Retrieval from curated sources	Citations required	Refuse when unsupported
Generation	Structured outputs	Low temperature for factual tasks	Self consistency checks
Verification	Automated fact checks	Human review for consequential outputs	User feedback
Monitoring	Sampled quality audits	Groundedness metrics	Incident tracking

Governing retrieval augmented generation

RAG shifts much of the risk from the model to the knowledge base, which must be governed like any critical dataset.

01 Curate	02 Ingest	03 Authorise	04 Generate	05 Evaluate	06 Maintain
Approved sources with owners, currency dates and sensitivity labels.	Chunking and embedding pipelines versioned; personal data minimised.	Retrieval respects the user's access rights, document by document.	Answer only from retrieved content; cite sources; abstain when evidence is thin.	Measure retrieval relevance, faithfulness and answer correctness.	Remove outdated documents; reindex; track answer drift.

Defence in depth against prompt injection

Architecture	Isolate untrusted content	No secrets in prompts	Separate planner and executor
Permissions	Least privilege tools	Scoped, short lived credentials	Read before write
Filtering	Input classifiers	Output validation	Allow lists for actions
Human checkpoints	Approve consequential actions	Confirm external sends	Review payments
Detection	Log all tool calls	Anomaly alerts	Red team regularly

Data leakage and intellectual property

Confidential inputs

Staff paste sensitive data into public tools. Control: approved enterprise tools, data loss prevention and clear acceptable use rules.

Training on your data

Vendor terms may allow prompts to train models. Control: contractual opt outs and verified data handling.

Output ownership and infringement

Outputs may reproduce protected works. Control: provenance tools, similarity checks and indemnities where available.

Memorisation

Models can regurgitate personal data from training sets. Control: evaluation for memorisation and privacy preserving fine tuning.

Evaluation and red teaming as a continuous cycle



1 Define

Risk scenarios and acceptance criteria tied to the use case.

2 Build evals

Test sets for accuracy, safety, bias, robustness and refusals.

3 Red team

Adversarial testers probe for jailbreaks, injection and misuse.

4 Score and decide

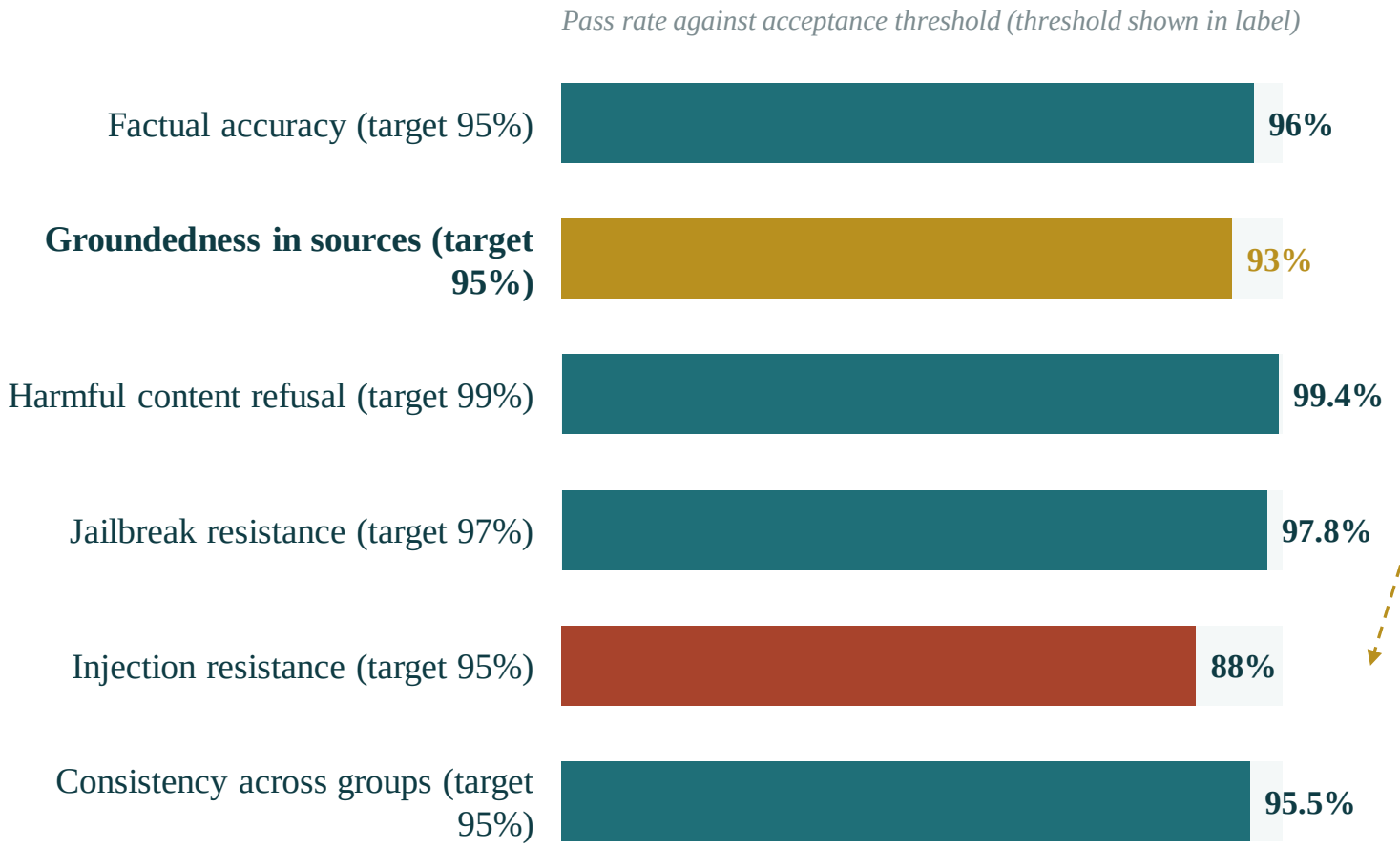
Compare against thresholds; approve, condition or block.

5 Monitor

Production sampling and user reports feed new test cases.

ILLUSTRATIVE DATA

A pre release evaluation scorecard



1 Release blocked

Injection resistance is well below threshold. Remediate tool permissions before release.

2 Conditional pass

Groundedness is just below target. Release only with citations and abstention enabled.

Levels of agent autonomy

Assistant **Autonomous agent**



LEVEL 1

Answers

Generates text for a human to use. No tool access.

LEVEL 2

Reads

Retrieves information through read only tools.

LEVEL 3

Proposes actions

Drafts actions a human approves before execution.

LEVEL 4

Acts within bounds

Executes defined actions autonomously with limits and logging.

LEVEL 5

Open autonomy

Plans and acts across systems with minimal oversight.

Governance controls for AI agents

- ☑ Registered identity for each agent, separate from human users.
- ☑ Human approval for irreversible or external actions.
- ☑ Explicit task scope and prohibited actions.
- ☑ Complete, tamper evident logs of plans and tool calls.
- ☑ Least privilege tool permissions and credentials.
- ☑ Kill switch and safe shutdown procedures.
- ☑ Spending, rate and action limits.
- ☑ Regular review of agent behaviour and permissions.

PRINCIPLE

Bounded autonomy

Grant an agent only the autonomy its task needs, for only as long as it needs it, with every action attributable and reversible where possible.

Tool permissioning: matching autonomy to consequence

Tool or action	Consequence	Autonomy allowed	Control
Search internal knowledge	Low	Autonomous	Access rights enforced
Draft an email or document	Low	Autonomous	Human sends
Send external communication	Medium	Human approval	Preview and confirm
Update a customer record	Medium	Within limits	Field allow list; audit log
Execute code in production	High	Human approval	Sandbox first; change control
Make a payment or refund	High	Human approval	Amount limits; dual control
Delete data or accounts	Critical	Not permitted	Human only process

Content provenance and watermarking

TRUST IN WHAT WE SEE

From 2 August 2026, EU AI Act Article 50 requires providers of generative systems to mark synthetic audio, image, video and text in a machine readable way, with the grace period for systems already on the market ending 2 December 2026.

1. **Watermarks**
   Signals embedded in content; can be robust or fragile, and are not yet universal.

2. **C2PA credentials**
   Cryptographically signed provenance metadata describing how content was made and edited.

3. **Detection**
   Classifiers estimate whether content is synthetic; useful but error prone.

4. **Governance**
   Combine marking, disclosure and verification workflows for published content.

GPAI provider and downstream deployer responsibilities

Foundation model provider

- **Documents:** Model capabilities, limitations, training content summary.
- **Informs:** Downstream providers enough to meet their obligations.
- **Tests:** Systemic risk models: evaluations and adversarial testing.
- **Reports:** Serious incidents for systemic risk models.

VS

Organisation building on the model

- **Assesses:** Fitness of the model for its own intended purpose.
- **Controls:** Prompts, retrieval, tools, guardrails and oversight.
- **Discloses:** Article 50 transparency to users and affected people.
- **Owns:** Decisions made with the system, including if it becomes high risk.

Key point Using a third party foundation model does not outsource accountability for the decisions your application makes.

A generative AI acceptable use policy: core clauses

- ☑ Use only approved tools for work purposes.
- ☑ Never enter restricted or special category data into unapproved tools.
- ☑ Verify facts, figures, citations and code before use.
- ☑ Disclose AI assistance where required or material.
- ☑ Do not use AI for final decisions about individuals without approval.
- ☑ Respect copyright, licences and confidentiality.
- ☑ Do not generate deceptive, discriminatory or harmful content.
- ☑ Report errors, incidents and suspected misuse promptly.
- ☑ Keep records where outputs inform business decisions.
- ☑ Complete AI literacy training before access.

Environmental footprint as a governance concern

Energy

Training and high volume inference consume significant electricity. Measure per use case and report.

Water

Data centre cooling draws on local water supplies, a concern in water stressed regions.

Proportionality

Prefer the smallest model that meets requirements; avoid generative AI where simpler methods suffice.

An operating rhythm for generative AI governance

Daily

Monitor

Automated safety filters, cost and usage alerts, incident triage.

Weekly

Sample

Quality review of sampled outputs and user feedback.

Monthly

Evaluate

Rerun evaluation suites; review agent permissions.

Quarterly

Red team

Structured adversarial testing; vendor model change review.

Annually

Reassess

Full impact reassessment, policy update and training refresh.

Section 11 synthesis

> *With generative and agentic AI, the decision is no longer only what the model predicts but what it is allowed to say and do. Governance must be expressed as permissions, limits and checks that operate at run time.*

Synthesis of Section 11

01

Govern the whole stack

Model, prompts, retrieval, tools and users all carry risk.

02

Bound the autonomy

Match agent permissions to the consequence of actions.

03

Evaluate continuously

Red teaming and production sampling replace one off validation.

SECTION

12

Operationalising Governance: MLOps, Metrics and Maturity

Turning policy into pipelines, dashboards, cadences and culture that scale with the AI portfolio.

IN THIS SECTION

- Governance as code
- Registry and release gates
- Maturity assessment
- Controls in the MLOps lifecycle
- KPIs, KRIs and dashboards
- Culture, SMEs and anti patterns

Slides 214 to 232



Governance as code



THE SHIFT

When governance requirements are expressed as automated checks in pipelines, compliance becomes the default path rather than an extra step. Evidence is generated as a by product of delivery, and reviewers focus on judgement rather than paperwork.

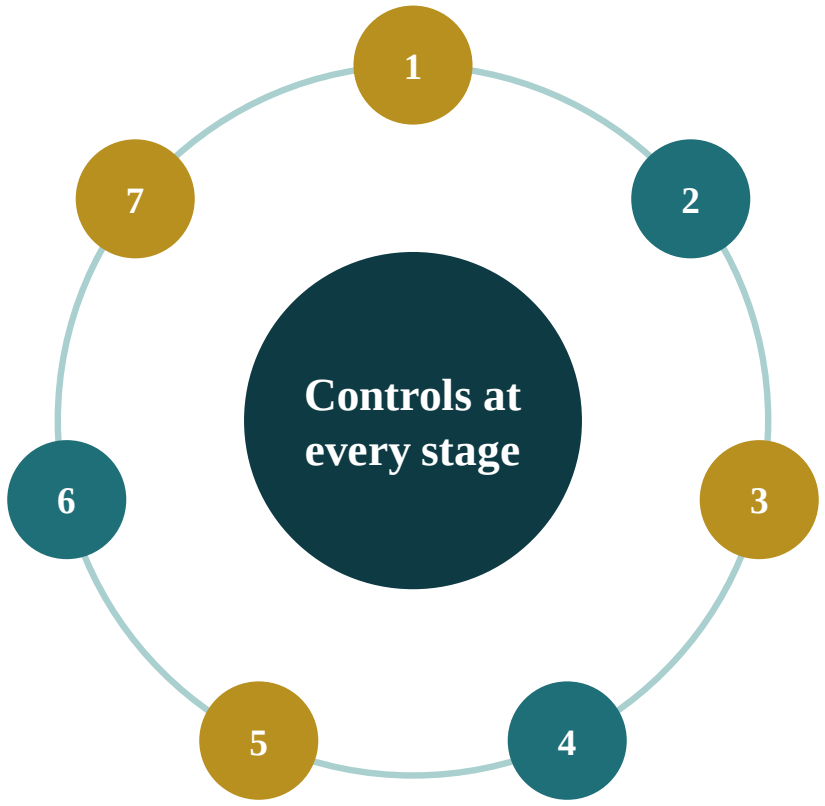
1. **Policy as code**
   Rules such as no special category features without approval enforced automatically at build time.

2. **Evidence by default**
   Test results, lineage and approvals captured in the registry without manual effort.

3. **Consistent enforcement**
   The same checks run for every model, every time, regardless of team.

4. **Human judgement preserved**
   Automation flags and blocks; people decide on exceptions and trade offs.

The MLOps lifecycle with embedded controls



1 Data ingestion

Contract checks, quality rules, lineage capture, sensitivity scanning.

2 Feature engineering

Feature store with owners; proxy and leakage checks.

3 Training

Experiment tracking; reproducible environments; data versioning.

4 Evaluation

Automated performance, fairness, robustness and explainability tests.

5 Approval

Risk tier routing; evidence pack; recorded sign off.

6 Deployment

Canary or shadow release; rollback ready; access controls.

7 Monitoring

Drift, performance, fairness and incident alerts feed back to training.

The model registry as a system of record

Registry element	Content	Governance use
Model identity	Name, version, owner, risk tier, status	Links to the AI inventory
Lineage	Training data versions, feature sets, code commit, environment	Reproducibility and audit
Evaluation evidence	Metrics overall and by subgroup, robustness and explainability results	Release decision and validation
Documentation	Model card, limitations, intended use, validation report	Deployer information and transparency
Approvals	Who approved, when, under which conditions	Accountability trail
Deployment history	Where deployed, traffic share, rollbacks	Incident investigation
Monitoring links	Dashboards, alert configuration, review dates	Ongoing oversight

Continuous integration and delivery gates for models

01 Code checks	02 Data checks	03 Model tests	04 Responsible AI tests	05 Risk routing	06 Progressive release
Unit tests, dependency scanning and policy as code rules.	Schema, quality thresholds and contract compliance.	Performance floors; no regression against the champion.	Subgroup gaps within limits; robustness and explanation checks.	Low tier auto approves; high tier waits for human sign off.	Shadow, canary then full rollout with automatic rollback.



Rule A failed gate blocks release by default. Exceptions require a named approver and an expiry date, recorded in the registry.

A five layer monitoring stack

Data	Schema and quality	Input drift (PSI)	Missingness by group
Model	Accuracy on labelled samples	Calibration	Prediction drift
Decision	Approval and refusal rates	Override rates	Threshold hits
Business	Outcomes and losses	Customer complaints	Service levels
Ethics and compliance	Fairness gaps	Explanation requests	Incidents and breaches

ILLUSTRATIVE DATA

Governance KPIs and KRIs for the board

A small, stable set of indicators, reported quarterly, gives the board a view of the AI portfolio.

96%

Inventory coverage

Share of known AI systems registered with owner and risk tier. Target 100%.

87%

Documentation currency

High risk systems with model card and validation reviewed in the last 12 months.

3

Fairness breaches

Production systems exceeding agreed group gap limits this quarter, all with open remediation.

11 days

Median time to remediate

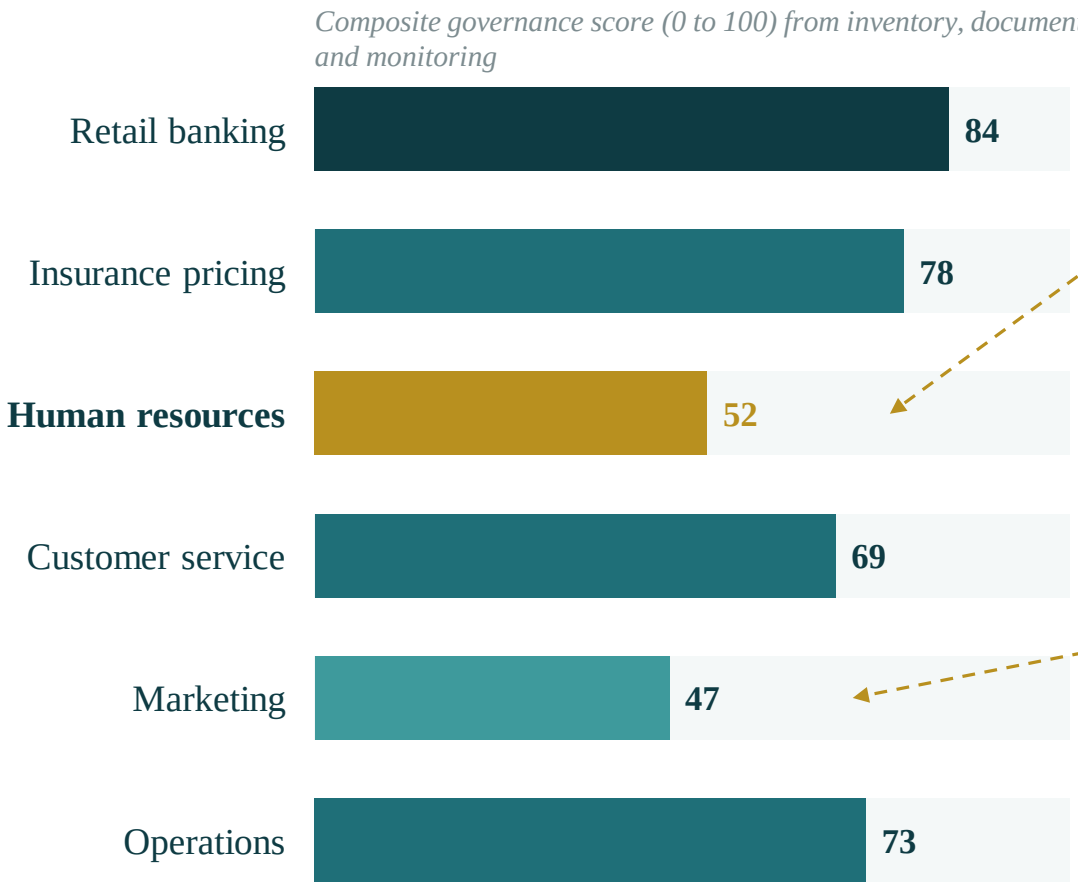
From detection of an AI incident to verified fix, against a target of 14 days.



Board question Which three systems carry the most residual risk, and what would make us stop using them?

ILLUSTRATIVE DATA

Dashboard view: portfolio health by business unit



1

Priority: human resources

Recruitment tools are Annex III high risk, yet governance scores are low. Focus remediation here before December 2027.

2

Low risk, low score

Marketing scores lowest but its uses are mostly low risk. Proportionate effort, not equal effort.

An AI governance maturity model

LEVEL 1

Ad hoc

No inventory; governance depends on individuals; issues found by accident.

LEVEL 2

Aware

Principles published; partial inventory; manual reviews for some projects.

LEVEL 3

Defined

Policy, risk tiering, standard templates and an AI council in operation.

LEVEL 4

Managed

Controls embedded in pipelines; metrics reported; independent validation.

LEVEL 5

Optimised

Continuous improvement; certification; governance a recognised source of advantage.

ILLUSTRATIVE DATA

Maturity self assessment across capabilities

	Current	Target 12 months	Target 24 months	Gap
Strategy and policy	3	4	5	2
Inventory and tiering	2	4	5	3
Data governance	3	4	4	1
Risk and validation	2	3	4	2
Fairness and explainability	1	3	4	3
Human oversight	2	3	4	2
Monitoring and incidents	2	4	4	2
Third party AI	1	3	4	3
Skills and culture	2	3	4	2

1 Ad hoc 2 Aware 3 Defined 4 Managed 5 Optimised

PRIORITIES

Biggest gaps first

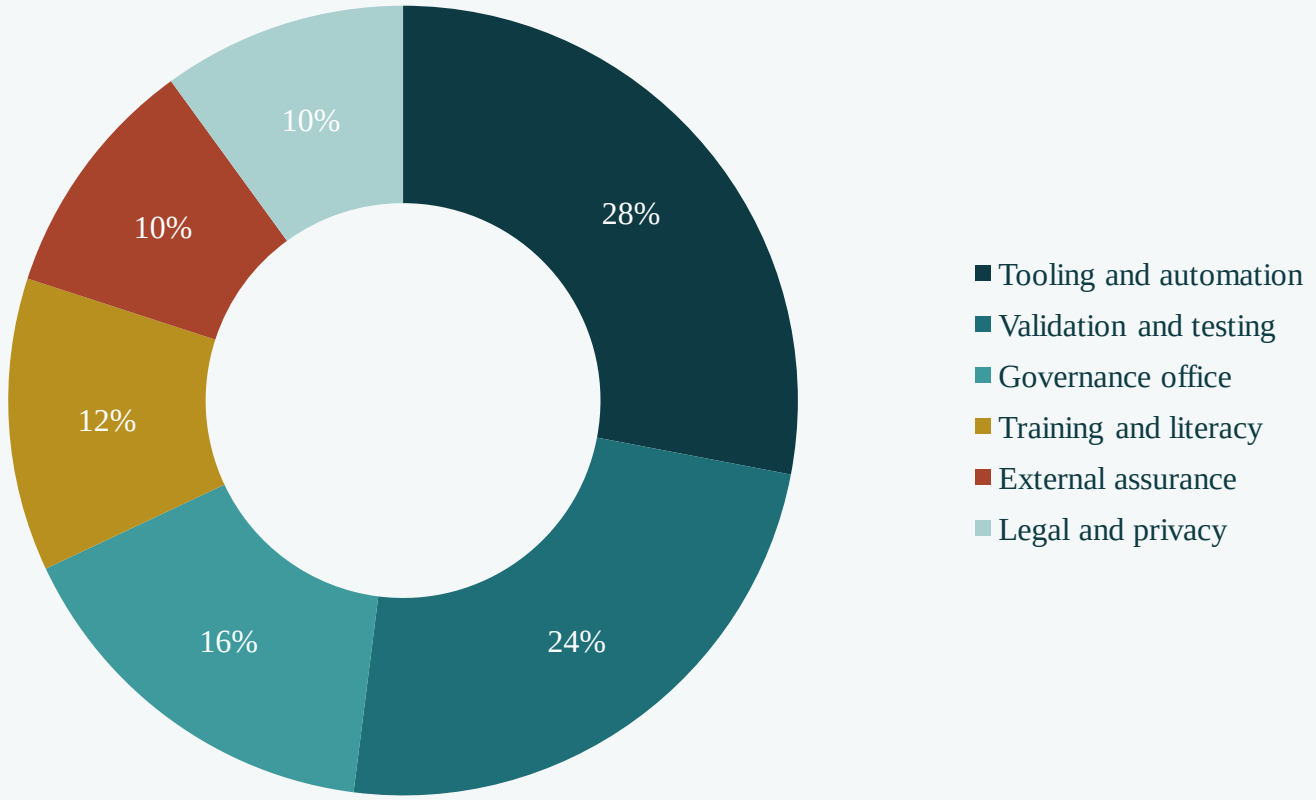
Inventory, fairness and third party AI show the largest gaps between current and target maturity. These become the first year programme.

Governance operating rhythm

Cadence	Activities	Forum	Output
Continuous	Automated gates, monitoring alerts, incident triage	Delivery teams	Alerts and tickets
Weekly	Intake triage, low risk approvals, alert review	Governance office	Triage log
Monthly	High risk approvals, KRI review, exception review	AI council	Decisions and conditions
Quarterly	Portfolio risk report, maturity tracking, red team results	Executive and board committee	Board report
Annually	Policy refresh, appetite review, internal audit, training refresh	Board	Approved policy and plan

ILLUSTRATIVE DATA

Resourcing a governance programme



52%

Build and test

Over half goes to automation and validation, the capabilities that scale with the portfolio.

Avoid a paper programme

Budgets weighted to committees and documents produce comfort, not control.

Rule of thumb

Scale governance spend with the number and risk of AI systems, not with headcount alone.

The governance tooling landscape

Catalogue and lineage

Data catalogues and lineage tools that link datasets to models and owners.

Experiment tracking and registry

Record runs, parameters, datasets and approvals as the system of record.

Responsible AI testing

Libraries for fairness metrics, explanations and robustness tests in pipelines.

Monitoring

Drift, performance and data quality monitoring with alerting.

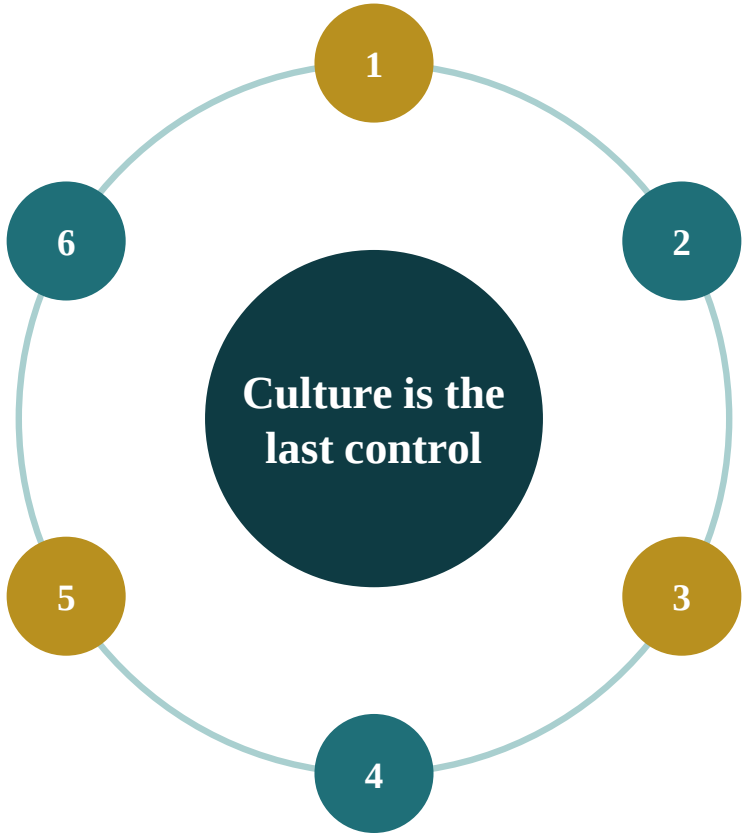
GRC platforms

Inventory, risk registers, assessments, policies and evidence management.

GenAI guardrails

Input and output filters, evaluation harnesses and agent permission layers.

Change management: making governance stick



1 Leadership signal
Executives visibly use governance and reward teams for raising risks.

2 Clear value
Show teams how governance prevents rework and unblocks deployment.

3 Easy path
Templates, automation and office hours make compliance the easiest route.

4 Skills
Role based training for builders, reviewers, owners and leaders.

5 Champions
Responsible AI champions embedded in each delivery team.

6 Feedback
Teams can challenge and improve the governance process itself.

Embedding governance in agile delivery

01 Backlog	02 Definition of ready	03 Sprint	04 Definition of done	05 Review
Governance requirements written as user stories with acceptance criteria.	Use case registered and risk tier known before sprint work begins.	Automated tests run on every change; documentation updated as code evolves.	Model card updated, tests passed, evidence in the registry.	Governance champion demonstrates evidence at the sprint review.



Result Governance becomes part of how work is done each sprint, not a phase at the end that delays release.

Measuring whether governance works

Level	Example measure	What it tells you
Input	Governance staff, budget, tooling coverage	Whether capacity exists
Process	Share of models through gates; time to approve	Whether the process runs and how efficiently
Output	Documentation completeness; tests passed	Whether evidence is produced
Outcome	Incidents, complaints, fairness gaps, regulatory findings	Whether harm is actually reduced
Value	Faster approvals, deals won, avoided losses	Whether governance enables the business



Warning Programmes often report inputs and outputs but not outcomes. Without outcome measures, governance cannot show that it reduces harm.

Common governance anti patterns

Ethics washing

Published principles with no standards, owners or enforcement behind them.

Rubber stamp committees

Approvals granted on slides without evidence or power to refuse.

Documentation theatre

Long templates completed after launch that nobody reads.

Late governance

Review only at the end, when changes are most expensive.

Shadow AI

Teams use unapproved tools because the approved path is too slow.

One size fits all

The same heavy process for a chatbot and a credit model.

Governance for SMEs and start ups

PROPORTIONATE BY DESIGN

Small organisations cannot run a large governance office, but they can make a few disciplined decisions early. A lightweight approach adopted at the start costs far less than retrofitting governance when a large customer or regulator asks for evidence.

1. **Week one**
   A one page AI policy, an inventory spreadsheet and a named accountable person.

2. **Per use case**
   A short intake form, risk tier and a model card template proportionate to risk.

3. **Engineering**
   Version data and models, log predictions and automate a few key tests.

4. **Customers**
   Prepare a governance summary for procurement questionnaires; it wins deals.

Section 12 synthesis

> *Governance scales when it is built into the machinery of delivery. Pipelines, registries and dashboards make good decisions the default and leave human judgement for the cases that need it.*

Synthesis of Section 12

01

Automate the routine

Policy as code and gates produce evidence by default.

02

Measure outcomes

Track whether harm falls, not only whether forms are filled.

03

Be proportionate

Effort follows risk, so the process stays credible.

SECTION

13

Case Studies: Lessons from Documented Failures

Ten public cases across justice, health, employment, welfare, finance and customer service.

IN THIS SECTION

- Justice and employment
- Public sector systems
- Customer facing AI
- Health and welfare
- Finance and trading
- Cross case patterns

Slides 233 to 250



The case portfolio

Case	Year	Domain	Core decision failure
COMPAS risk scores	2016	Criminal justice	Unequal error rates across racial groups; contested fairness criterion
Amazon recruiting tool	2018	Employment	Model learned historical gender bias from past hiring data
US health risk algorithm	2019	Healthcare	Cost used as a proxy for need, under serving Black patients
Dutch childcare benefits	2021	Welfare	Risk profiling and harsh fraud presumptions; nationality used as a risk factor
Robodebt	2016 to 2019	Welfare	Automated income averaging raised unlawful debts at scale
Post Office Horizon	1999 to 2015	Public sector IT	Presumed reliability of system data led to wrongful prosecutions
Zillow Offers	2021	Real estate	Pricing model scaled into a volatile market without adequate limits
Knight Capital	2012	Trading	Faulty deployment reactivated dead code; no automated kill switch
Air Canada chatbot	2024	Customer service	Chatbot misstated policy; firm denied responsibility
Apple Card	2019 to 2021	Consumer credit	Unexplained credit limit differences created a trust crisis

Case 1: COMPAS recidivism risk scores

United States, 2016
Criminal justice
ProPublica analysis of Broward County

44.9%

false positive rate for Black defendants, against 23.5% for white defendants, in the ProPublica analysis.

WHAT HAPPENED

A commercial risk assessment tool informed pretrial and sentencing decisions. Journalists matched scores to subsequent offending and found that error types differed sharply by race, while the vendor showed that scores were equally predictive across groups.

DECISION FAILURE

No public decision had been made about which fairness criterion the tool should satisfy. The tool was proprietary, so defendants and courts could not scrutinise its logic, and scores were used in settings beyond their original design.

GOVERNANCE LESSON

Choose and publish the fairness criterion for high stakes tools before deployment. Require transparency sufficient for affected people to challenge scores, and restrict use to validated purposes.

Case 2: an experimental recruiting tool

Amazon, reported 2018
Employment
Internal tool, never used as sole decider

10 yrs

of past CVs, mostly from men, were used to train the model, which learned to penalise terms associated with women.

WHAT HAPPENED

An experimental model rated job candidates by learning from a decade of submitted CVs. Engineers found it downgraded CVs containing words such as women's, as in women's chess club captain, and attempts to neutralise specific terms could not guarantee fairness. The project was abandoned.

DECISION FAILURE

Past hiring decisions were treated as ground truth for future merit. The label encoded historical bias, and removing explicit terms left other proxies intact.

GOVERNANCE LESSON

A positive example of internal testing catching harm before scale. The governance lesson is to question whether historical decisions are a valid label at all, and to be willing to stop.

Case 3: a widely used health risk algorithm

United States, 2019
Healthcare
Obermeyer et al., Science

2.6x

more Black patients would be identified for extra care if the label measured health need rather than cost (17.7% to 46.5%).

WHAT HAPPENED

A commercial algorithm identified patients for care management programmes by predicting future healthcare costs. Researchers showed that at the same risk score, Black patients were considerably sicker than white patients.

DECISION FAILURE

Cost was chosen as a proxy for need. Because less was spent on Black patients with equal need, the proxy encoded unequal access to care. The model predicted cost accurately; the framing was wrong.

GOVERNANCE LESSON

Govern the choice of target variable explicitly. Test whether the proxy behaves the same way across groups, and work with domain experts to align labels with the real objective.

Case 4: the Dutch childcare benefits scandal

Netherlands, 2013 to 2021
Welfare and tax administration
Toeslagenaffaire

2021

The Dutch government resigned in January 2021 after a parliamentary inquiry into the scandal.

WHAT HAPPENED

Tens of thousands of parents were wrongly accused of benefit fraud and ordered to repay large sums. A risk classification model used by the tax authority included nationality as an indicator. The Dutch data protection authority later fined the authority for discriminatory and unlawful processing.

DECISION FAILURE

Risk flags were treated as proof. Small administrative errors led to full repayment demands, families had little ability to understand or contest decisions, and accountability was diffused across the institution.

GOVERNANCE LESSON

Risk scores must never stand in for findings of fact. Discriminatory variables require legal review, and contestability must be real, timely and accessible, especially for people in vulnerable situations.

Case 5: Robodebt

Australia, 2016 to 2019
Welfare
Royal Commission report, July 2023

A$1.8bn

approximate value of the 2021 class action settlement, including debts written off, refunds and compensation.

WHAT HAPPENED

An automated scheme compared annual tax data with fortnightly welfare income by averaging, raising debts against hundreds of thousands of people. The Federal Court found in 2019 that debts based on averaging alone were not lawfully raised.

DECISION FAILURE

The core method was legally and statistically flawed, yet warnings were not acted upon. The burden of proof was shifted to recipients, human review was removed from debt raising, and accountability failed at senior levels.

GOVERNANCE LESSON

Validate the legality of the decision rule itself, not only the software. Never reverse the burden of proof through automation, and treat internal warnings as governance signals that require a recorded response.

Case 6: the Post Office Horizon scandal

United Kingdom, 1999 to 2015
Public sector IT and prosecution
Statutory public inquiry

900+

subpostmasters were prosecuted and convicted on the basis of evidence from the Horizon accounting system.

WHAT HAPPENED

Shortfalls shown by the Horizon system were treated as evidence of theft or false accounting. Known bugs and remote access to branch accounts were not disclosed, and convictions were later overturned in large numbers.

DECISION FAILURE

An institution presumed its system's data was reliable, refused to engage with evidence of errors and controlled the information needed to challenge it. Not an AI system, but a defining failure of data governance and accountability.

GOVERNANCE LESSON

Data from automated systems is evidence to be tested, not truth to be assumed. Disclose known defects, preserve independent audit access and give affected people the means to challenge system outputs.

Case 7: Zillow Offers

United States, 2021
Real estate
Algorithmic home buying

$304m

inventory write down reported for Q3 2021, as Zillow announced it would wind down the business and cut about a quarter of staff.

WHAT HAPPENED

Zillow used pricing models to buy homes directly and resell them. Rapid scaling coincided with a volatile market, and the company bought many homes at prices above what it could achieve on resale.

DECISION FAILURE

Forecasting error that was tolerable for advertising estimates became material when the model committed capital at scale. Volume targets outpaced the controls needed to detect and respond to model drift.

GOVERNANCE LESSON

Model risk rises with the consequence of the decision, not just model accuracy. Set exposure limits linked to model uncertainty, and stage scaling with explicit stop criteria.

Case 8: Knight Capital

United States, 1 August 2012
Automated trading
SEC enforcement action, 2013

$440m

trading loss in about 45 minutes after a faulty software deployment.

WHAT HAPPENED

New code was not deployed to one of eight servers, and a repurposed flag reactivated obsolete functionality. The system sent millions of unintended orders before staff could stop it.

DECISION FAILURE

Deployment relied on manual steps without independent verification. There were no adequate automated controls to detect and halt runaway behaviour, and alerts were not acted on in time.

GOVERNANCE LESSON

Release management and kill switches are governance controls. Automate deployment checks, retire dead code and define who may stop an automated system, and how quickly.

Case 9: the Air Canada chatbot

Canada, February 2024
Customer service
BC Civil Resolution Tribunal, Moffatt v Air Canada

Liable

The tribunal rejected the argument that the chatbot was responsible for its own words and held the airline liable.

WHAT HAPPENED

A customer asked the airline's chatbot about bereavement fares and was told he could apply for a refund after travel, contrary to the published policy. The airline refused the refund and argued it was not responsible for the chatbot's statements.

DECISION FAILURE

The chatbot was not grounded in authoritative policy text, and the organisation treated it as separate from its own representations to customers.

GOVERNANCE LESSON

Organisations own what their AI says. Ground customer facing systems in approved content, test them against policy and provide a clear human route for disputes.

Case 10: Apple Card credit limits

United States, 2019 to 2021
Consumer credit
New York DFS investigation

2021

The regulator found no unlawful discrimination, but the episode caused lasting reputational harm.

WHAT HAPPENED

Social media posts alleged that women received much lower credit limits than their husbands despite shared finances. The regulator investigated the underwriting and concluded there was no violation of fair lending law.

DECISION FAILURE

Customers and frontline staff could not explain individual decisions. In the absence of explanation, the public assumed bias, and the issuer could not reassure customers quickly.

GOVERNANCE LESSON

Lawful is not the same as trusted. Prepare explanations and escalation routes in advance, and test how decisions will look to customers who compare outcomes with each other.

Cross case pattern analysis

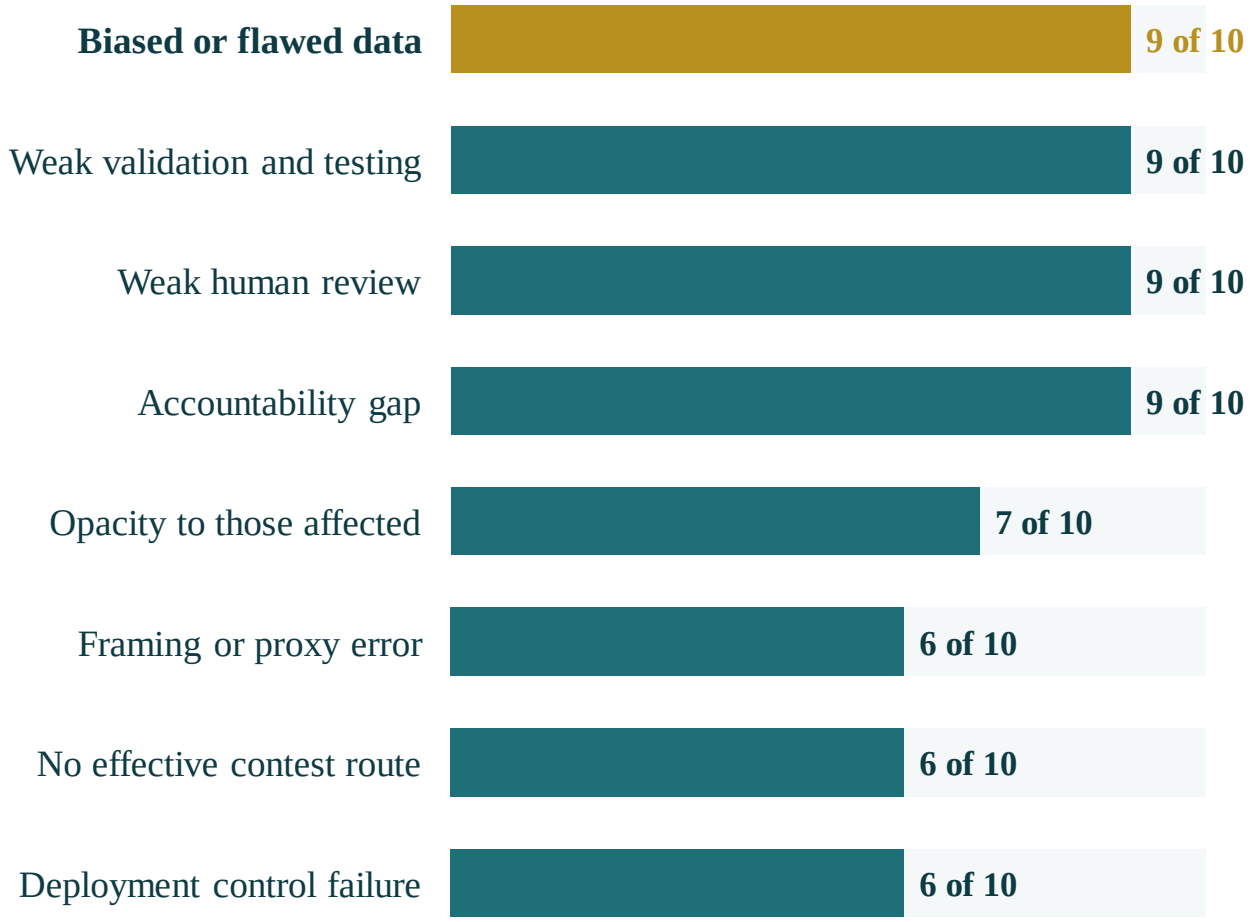
Author's coding of each case against eight failure modes, based on the public record.

	Framing or proxy	Biased data	Weak validation	Weak human review	No contest route	Deploy control	Accountability gap	Opacity
COMPAS	Contributing	Primary	Contributing	Contributing	Contributing		Contributing	Primary
Amazon	Contributing	Primary						
Health algorithm	Primary	Primary	Contributing	Contributing			Contributing	Contributing
Dutch benefits	Contributing	Primary	Contributing	Primary	Primary	Contributing	Primary	Primary
Robodebt	Primary	Primary	Primary	Primary	Primary	Contributing	Primary	Contributing
Horizon		Primary	Primary	Contributing	Primary	Contributing	Primary	Primary
Zillow	Contributing	Contributing	Primary	Contributing		Primary	Contributing	
Knight Capital			Primary	Contributing		Primary	Contributing	
Air Canada		Contributing	Primary	Contributing	Contributing	Contributing	Primary	Contributing
Apple Card		Contributing	Contributing	Contributing	Contributing		Contributing	Primary

Primary failure Contributing factor Not material

Which failures recur most often?

Number of the ten cases where the failure mode was primary or contributing



1

Failures compound

No case had a single cause. On average each case shows six of the eight failure modes.

2

Data is primary most often

Data problems were the primary failure in six cases, more than any other mode.

What good looks like: positive practices from the record

Stopping early

The recruiting tool was abandoned when testing revealed bias. Willingness to stop is a governance capability.

External scrutiny

Journalists and researchers exposed the COMPAS and health algorithm issues. Enabling external audit builds resilience.

Public registers

Algorithm registers in UK government and cities such as Amsterdam and Helsinki create accountability before harm.

Fixing the label

The health algorithm's developer worked with researchers to reduce bias by changing the target.

Independent inquiry

Royal commissions and statutory inquiries established facts and accountability where internal processes failed.

Clear legal precedent

Tribunals and courts have confirmed that organisations are responsible for automated decisions.

Counterfactual governance: which controls would have mattered

Case	Missing control	Likely effect
Health algorithm	Framing review of the target variable with subgroup proxy tests	Bias detected before deployment
Dutch benefits	Legal review of risk variables; human fact finding before sanctions	Discriminatory profiling prevented; harms contained
Robodebt	Legal validation of the decision rule; heeding internal warnings	Unlawful debts never raised
Horizon	Independent audit of system data; disclosure of known defects	Wrongful prosecutions avoided
Zillow	Exposure limits tied to model uncertainty; staged scaling	Losses capped at a tolerable level
Knight Capital	Automated deployment verification; kill switch	Incident stopped in seconds
Air Canada	Grounding in policy text; pre release testing	Accurate answers; no dispute

Lessons for decision making frameworks

Question the label	Most harms trace back to a target, proxy or historical decision treated as ground truth.
Decide on fairness explicitly	Where the criterion was never chosen, others chose it after the fact, in public.
Keep humans able to say no	Cases escalated when people could not understand or challenge outputs.
Control consequence, not only accuracy	Exposure limits and kill switches matter as much as model quality.
Make accountability unavoidable	Diffused responsibility allowed harms to continue long after warnings.

Section 13 synthesis

> *The record is consistent: AI and data failures are rarely failures of mathematics. They are failures to question framing, to test with care, to listen to warnings and to give affected people a voice.*

Synthesis of Section 13

01

Causes compound

Every case combined several failures across the lifecycle.

02

Data and validation dominate

Most cases involved flawed data and weak testing.

03

Accountability decides scale

Where no one owned the decision, harm persisted for years.

SECTION

14

An Integrated Framework, Roadmap and Future Directions

Bringing theory, regulation and evidence together into a framework organisations can adopt now.

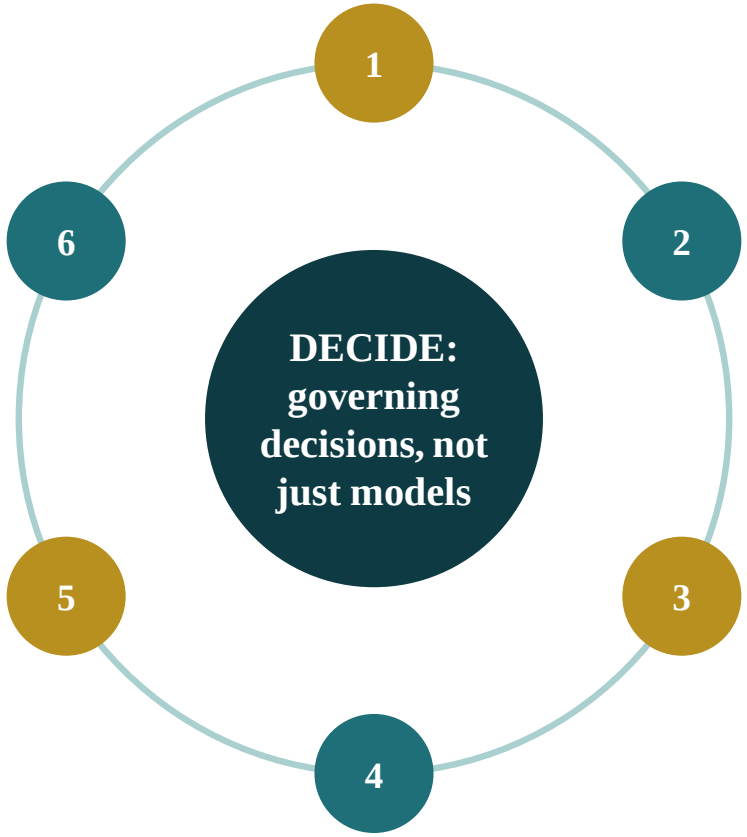
IN THIS SECTION

- The DECIDE framework
- Phased roadmap
- Emerging trends and scenarios
- Decision governance canvas
- Recommendations by audience
- Open questions and limits

Slides 251 to 266



The DECIDE framework for decision governance



1 Define

Frame the decision: purpose, target, proxy, affected people, alternatives including no AI.

2 Evaluate

Assess risk, fairness, legality and value with a fit for purpose decision framework.

3 Control

Set thresholds, automation level, oversight design and run time limits.

4 Inform

Explain to users, affected people and regulators; enable challenge.

5 Document

Record decisions, owners, evidence and trade offs as they are made.

6 Evolve

Monitor, learn from overrides and incidents, and revisit or retire.

DECIDE in detail: questions, tools and evidence

Stage	Key questions	Tools from this inquiry	Evidence
Define	What decision is this? Who is affected? Is the proxy valid?	Framing review, stakeholder map, Cynefin	Use case brief
Evaluate	What could go wrong, for whom, and how badly? Is it lawful?	Risk matrix, MCDA, EVPI, impact assessment	Risk assessment, DPIA, FRIA
Control	Where is the threshold? Who reviews? What are the limits?	t* = C(FP) / (C(FP) + C(FN)), automation levels	Oversight plan, controls
Inform	Who needs to know what, and how can they challenge?	Six explanation types, counterfactuals	Notices, model card
Document	Can we reconstruct who decided what and why?	Registry, lineage, decision log	Audit trail
Evolve	Is it still working, and still the right decision?	PSI, KRIs, override analytics, OODA	Monitoring and review records

The decision governance canvas

A one page canvas to complete for every material AI decision, reviewed at each stage gate.

1 Decision and purpose

What is decided, for whom, and why AI is appropriate.

2 Owner and rights

Who decides, who is consulted, who can veto.

3 Affected people

Groups affected, vulnerabilities and how they are heard.

4 Target and proxy

What is predicted, and its gap from the real goal.

5 Risk and legal status

Risk tier, EU AI Act category, lawful basis.

6 Fairness choice

Criterion chosen, rationale and accepted gaps.

7 Control design

Threshold, automation level, oversight, limits.

8 Explanation and redress

What people are told and how they contest.

9 Monitoring and exit

Signals, triggers, review date and retirement plan.

A phased roadmap to December 2027 and beyond

Months 0 to 3

Foundations

Appoint accountable executive; AI policy; complete inventory; prohibited use screen.

Months 3 to 9

Core controls

Risk tiering, intake workflow, templates, AI council, literacy programme.

Months 9 to 18

High risk readiness

Validation, fairness testing, oversight design and documentation for Annex III systems.

Months 18 to 24

Automation

Governance as code, registry, monitoring dashboards, KRIs to the board.

Beyond 24

Assurance

Internal audit, ISO/IEC 42001 certification, continuous improvement.

Roadmap deliverables and owners

Phase	Key deliverables	Lead owner	Success measure
Foundations	Policy, inventory, prohibited use screen, accountable executive	Chief AI or data officer	100% of known systems registered
Core controls	Tiering, intake, templates, council, literacy training	Governance office	All new use cases triaged
High risk readiness	Validation, fairness and oversight for Annex III systems	Model owners and validators	Evidence packs complete
Automation	Pipelines with gates, registry, monitoring and KRIs	ML platform lead	Gates on all production models
Assurance	Internal audit, certification, maturity reassessment	Internal audit and CAIO	Maturity level 4 achieved

Recommendations for boards

- **Own the appetite.** Approve a specific AI risk appetite with quantitative limits.
- **Name accountability.** Assign a senior executive accountable for AI governance.
- **Demand the inventory.** Review the high risk portfolio at least quarterly.
- **Fund the machinery.** Resource automation and validation, not only policies.
- **Seek independent assurance.** Commission internal audit of AI controls within 18 months.
- **Build literacy.** Ensure directors can challenge AI proposals with confidence.

BOARD TEST

Can the board answer?

Which AI systems would cause us the most harm if they failed tomorrow, and who would we hold accountable?

Recommendations for data science leaders

- [x] Make the decision inventory part of every project kick off.
- [x] Track override and appeal data as core evidence.
- [x] Institute a framing review before modelling begins.
- [x] Prefer interpretable models for high stakes tabular decisions.
- [x] Require documented thresholds with cost assumptions.
- [x] Plan retirement as carefully as release.
- [x] Choose fairness criteria explicitly with owners.
- [x] Treat vendor and foundation models as your own risk.
- [x] Build fairness, robustness and explanation tests into pipelines.
- [x] Invest in team skills in decision science and ethics.

Recommendations for practitioners

Write down your decisions	A short decision log for each project captures choices and alternatives while they are fresh.
Disaggregate everything	Report every key metric by relevant subgroup and at intersections where sample sizes allow.
Never accept defaults silently	Thresholds, class weights and exclusions should be deliberate and recorded.
Speak up early	Raise concerns about framing and data when change is still cheap.
Learn the law you touch	Know the basics of data protection, equality law and the AI Act for your domain.

Recommendations for policymakers and regulators

Clarify fairness expectations

Sector guidance on which fairness criteria apply to which decisions would reduce uncertainty and post hoc disputes.

Expand public registers

Extend algorithmic transparency records to high impact private sector uses, starting with essential services.

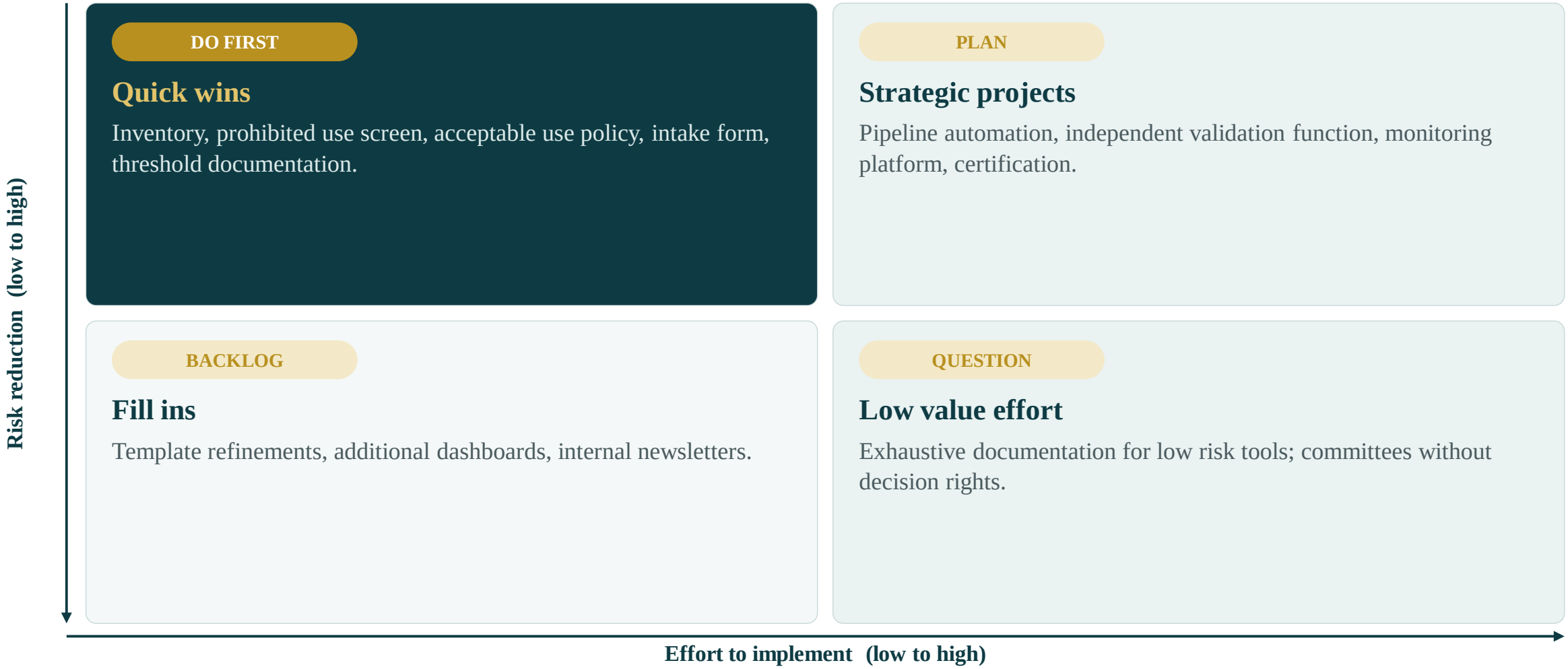
Align across borders

Mutual recognition of standards such as ISO/IEC 42001 lowers compliance cost for firms serving the UK and EU.

Strengthen redress

Ensure affected people can access explanations and remedies without prohibitive cost or delay.

Prioritising governance investments



Emerging trends shaping governance

Agentic AI at work

Agents acting across enterprise systems push governance toward identity, permissions and run time control.

Assurance markets

Growth of AI audit, certification and insurance products creates external incentives for good governance.

Provenance by default

Content credentials and watermarking become standard for published synthetic media.

Smaller, specialised models

Cost and sustainability pressures favour targeted models that are easier to evaluate.

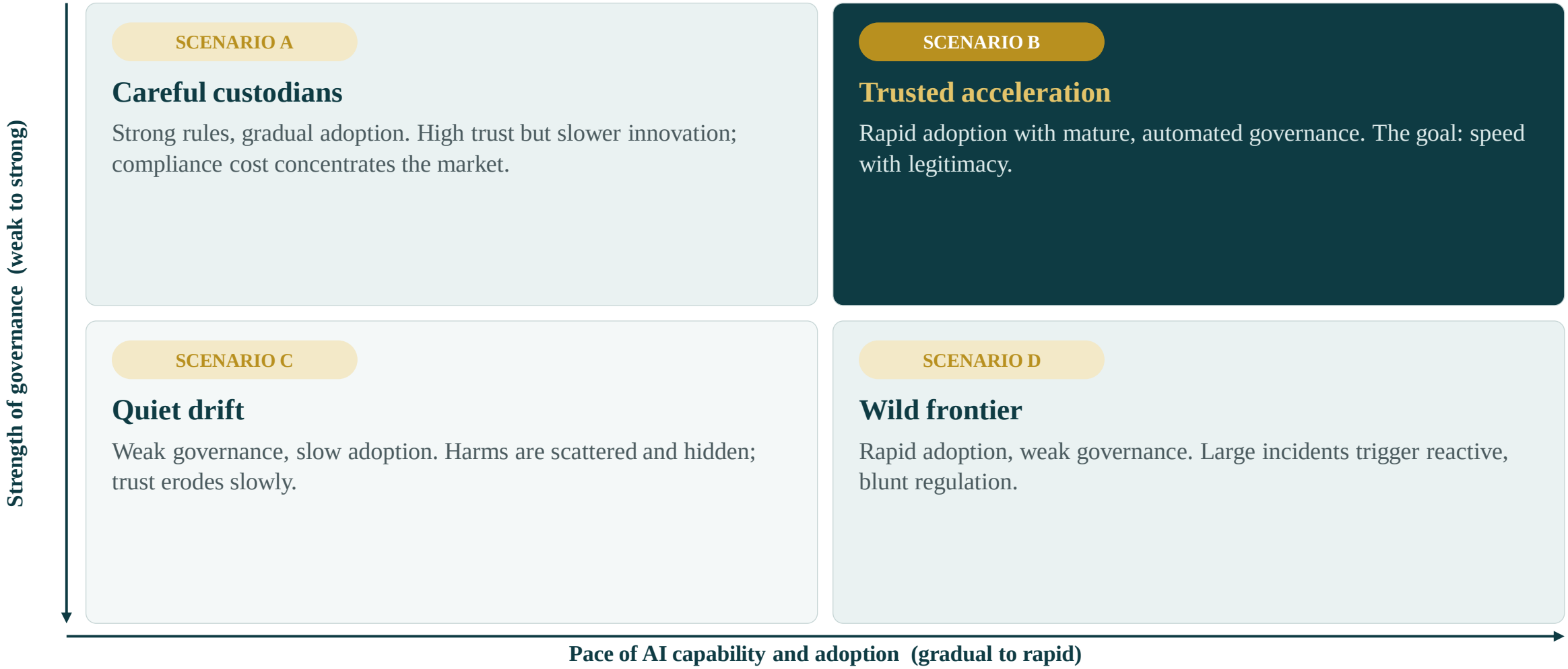
Litigation and precedent

Courts increasingly define liability for AI outputs, filling gaps left by legislation.

Regulatory divergence

Differences between EU, UK and US approaches require multi regime compliance design.

Four scenarios for 2030



Open research questions

Measuring meaningful oversight	How can we test empirically whether human review improves outcomes in a given deployment?
Accountability for agents	How should responsibility be allocated when autonomous agents interact with each other?
Fairness under drift	How should fairness criteria adapt as base rates and populations change over time?
Explaining foundation models	Can interpretability research give explanations faithful enough for legal use?
Value of governance	How can the economic value of governance be measured credibly?

Limitations of this inquiry

READ WITH CARE

This inquiry synthesises published research, regulation and public cases as at November 2026. Regulation and practice are moving quickly, and several conclusions rest on analytical judgement rather than controlled evidence.

1. **Regulatory change**
   Dates and obligations may change through further amendment, guidance or case law.

2. **Case selection**
   Public cases over represent visible failures; quiet successes are under reported.

3. **Illustrative data**
   Worked examples use constructed figures to teach methods, not to report findings.

4. **Not legal advice**
   Organisations should take legal advice on their specific obligations.

Section 14 synthesis

> *Define, Evaluate, Control, Inform, Document, Evolve. Governing decisions in this way turns compliance into competence, and competence into the trust that lets AI be used where it matters most.*

Synthesis of Section 14

01

One framework

DECIDE links decision science, regulation and operations.

02

Start now

Foundations and core controls take a year; December 2027 is close.

03

Every role matters

Boards, leaders, practitioners and policymakers each hold part of the answer.

Conclusion

> *Data science systems are decisions at scale. Governing them well means knowing what is being decided, deciding deliberately, sharing power with those affected, and keeping the humility to change course.*

Concluding statement of the inquiry

01

Answer to RQ1 and RQ2

Decisions span the lifecycle; framing and thresholds matter most. Match the framework to uncertainty and stakes.

02

Answer to RQ3 and RQ4

Regulation converges on a common core. Failures compound across data, validation, oversight and accountability.

03

Answer to RQ5

Embed governance in pipelines and roles with DECIDE, starting with inventory and risk tiering now.

Ten takeaways

1

Govern decisions

Not only models.

2

Question the proxy

Framing is where harm begins.

3

Thresholds are policy

Own and document them.

4

Choose fairness

Definitions conflict.

5

Know your inventory

You cannot govern the unseen.

6

Tier by risk

Effort follows impact.

7

Make oversight real

Authority, time, skill, data.

8

Bound agent autonomy

Permissions match consequence.

9

Automate controls

Evidence by default.

10

Start now

December 2027 is close.

One page governance checklist

- [x] **Why:** Board approved AI risk appetite and accountable executive.
- [x] **Decisions:** Decision inventory and owners for every material system.
- [x] **Frameworks:** Documented method for each high stakes choice.
- [x] **Data:** Quality, lineage and lawful basis for all training data.
- [x] **Architecture:** Policy stack, AI council and stage gates in place.
- [x] **Regulation:** EU AI Act role and risk category recorded per system.
- [x] **Risk:** Risk register, validation and KRIs with limits.
- [x] **Fairness:** Criterion chosen, tested and monitored.
- [x] **Transparency:** Explanations, logs and contest routes designed.
- [x] **Oversight:** Reviewers empowered; overrides analysed.
- [x] **GenAI:** Evaluations, red teaming and agent permissions.
- [x] **Operations:** Gates, registry and monitoring automated.
- [x] **Cases:** Lessons reviewed against own systems.
- [x] **Roadmap:** DECIDE canvas used; phased plan funded.

References I: decision science and fairness

No.	Reference
1	Simon, H. A. (1955). A Behavioral Model of Rational Choice. Quarterly Journal of Economics, 69(1).
2	Kahneman, D. (2011). Thinking, Fast and Slow. Farrar, Straus and Giroux.
3	Snowden, D. J. and Boone, M. E. (2007). A Leader's Framework for Decision Making. Harvard Business Review.
4	Saaty, T. L. (1980). The Analytic Hierarchy Process. McGraw Hill.
5	Vroom, V. H. and Yetton, P. W. (1973). Leadership and Decision Making. University of Pittsburgh Press.
6	Kleinberg, J., Mullainathan, S. and Raghavan, M. (2017). Inherent trade offs in the fair determination of risk scores. ITCS.
7	Chouldechova, A. (2017). Fair prediction with disparate impact. Big Data, 5(2).
8	Angwin, J., Larson, J., Mattu, S. and Kirchner, L. (2016). Machine Bias. ProPublica.
9	Obermeyer, Z., Powers, B., Vogeli, C. and Mullainathan, S. (2019). Dissecting racial bias in an algorithm used to manage the health of populations. Science, 366.
10	Buolamwini, J. and Gebru, T. (2018). Gender Shades: Intersectional Accuracy Disparities in Commercial Gender Classification. FAccT.
11	Suresh, H. and Guttag, J. (2021). A Framework for Understanding Sources of Harm throughout the Machine Learning Life Cycle. EAAMO.
12	Dietvorst, B., Simmons, J. and Massey, C. (2015). Algorithm aversion. Journal of Experimental Psychology: General.
13	Logg, J., Minson, J. and Moore, D. (2019). Algorithm appreciation. Organizational Behavior and Human Decision Processes.

References II: explainability, documentation and data

No.	Reference
14	Lundberg, S. and Lee, S. I. (2017). A Unified Approach to Interpreting Model Predictions. NeurIPS.
15	Ribeiro, M. T., Singh, S. and Guestrin, C. (2016). Why Should I Trust You? Explaining the Predictions of Any Classifier. KDD.
16	Wachter, S., Mittelstadt, B. and Russell, C. (2017). Counterfactual Explanations without Opening the Black Box. Harvard Journal of Law and Technology.
17	Rudin, C. (2019). Stop explaining black box machine learning models for high stakes decisions. Nature Machine Intelligence.
18	Mitchell, M. et al. (2019). Model Cards for Model Reporting. FAT* Conference.
19	Gebru, T. et al. (2021). Datasheets for Datasets. Communications of the ACM, 64(12).
20	ICO and The Alan Turing Institute (2020). Explaining decisions made with AI.
21	Sheridan, T. B. and Verplank, W. L. (1978). Human and Computer Control of Undersea Teleoperators. MIT.
22	Parasuraman, R. and Manzey, D. (2010). Complacency and Bias in Human Use of Automation. Human Factors, 52(3).
23	DAMA International (2017). DAMA DMBOK: Data Management Body of Knowledge, 2nd edition.
24	Dehghani, Z. (2022). Data Mesh: Delivering Data Driven Value at Scale. O'Reilly.
25	Cavoukian, A. (2009). Privacy by Design: The 7 Foundational Principles. Information and Privacy Commissioner of Ontario.
26	OWASP Foundation (2024). OWASP Top 10 for LLM Applications, 2025 edition.

References III: law, standards and cases

No.	Reference
27	Regulation (EU) 2024/1689 (Artificial Intelligence Act), as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI).
28	Data (Use and Access) Act 2025 (UK); UK GDPR; Data Protection Act 2018; Equality Act 2010.
29	DSIT (2023). A pro innovation approach to AI regulation. White paper, and 2024 government response.
30	NIST (2023). AI Risk Management Framework 1.0; NIST (2024). Generative AI Profile.
31	ISO/IEC 42001:2023; ISO/IEC 23894:2023; ISO/IEC 38507:2022; ISO/IEC 42005:2025; ISO/IEC 5259 series.
32	Prudential Regulation Authority (2023). SS1/23 Model risk management principles for banks.
33	Board of Governors of the Federal Reserve System (2011). SR Letter 11 7: Guidance on Model Risk Management.
34	OECD (2019, revised 2024). Recommendation of the Council on Artificial Intelligence.
35	Institute of Internal Auditors (2020). The IIA's Three Lines Model.
36	Royal Commission into the Robodebt Scheme (2023). Report. Commonwealth of Australia.
37	US SEC (2013). Order instituting proceedings: Knight Capital Americas LLC.
38	Moffatt v. Air Canada, 2024 BCCRT 149; NYDFS (2021). Report on Apple Card investigation.
39	Post Office Horizon IT Inquiry (UK); Dutch parliamentary inquiry report Ongekend onrecht (2020).

Appendix: acronyms

Acronym	Meaning	Acronym	Meaning
ADM	Automated decision making	KRI	Key risk indicator
AHP	Analytic Hierarchy Process	MCDA	Multi criteria decision analysis
AIMS	AI management system (ISO/IEC 42001)	MLOps	Machine learning operations
CAIO	Chief AI Officer	PET	Privacy enhancing technology
DPIA	Data protection impact assessment	PPV	Positive predictive value
DUAA	Data (Use and Access) Act 2025	PSI	Population stability index
EVPI	Expected value of perfect information	RAG	Retrieval augmented generation
FPR	False positive rate	RMF	Risk Management Framework (NIST)
FRIA	Fundamental rights impact assessment	SHAP	Shapley additive explanations
GPAI	General purpose AI	TPR	True positive rate



DATA AND AI GOVERNANCE | NOVEMBER 2026

Thank you

Questions, challenge and discussion are the first act of good governance.

Anthony Chinedu Echem
Machine Learning Engineer and Data Scientist